Center for Internet Security®

CIS Benchmarks™

CIS Microsoft Windows Server 2003 Benchmark [imported]

v3.1.0 – 12-03-2013

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

ARCHIVE

Table of Contents

Terms of Use *1*
Table of Contents *2*
Overview *9*
Intended Audience 9
Consensus Guidance 10
Typographical Conventions 11
Recommendation Definitions *12*
Title 12
Assessment Status 12
Automated 12
Manual 12
Profile 12
Description 12
Rationale Statement 12
Impact Statement 13
Audit Procedure 13
Remediation Procedure 13
Default Value 13
References 13
CIS Critical Security Controls® (CIS Controls®) 13
Additional Information 13
Profile Definitions 14
Acknowledgements 15
Recommendations *16*
1 Computer Configuration 16
1.1 Windows Settings 16
1.1.1 Security Settings 16
1.1.1.1.1.1 Configure 'Maximum lifetime for service ticket' (Manual) 17
1.1.1.1.1.2 Configure 'Enforce user logon restrictions' (Manual) 18
1.1.1.1.1.3 Configure 'Maximum lifetime for user ticket' (Manual) 19
1.1.1.1.1.4 Configure 'Maximum tolerance for computer clock synchronization' (Manual) 20
1.1.1.1.1.5 Configure 'Maximum lifetime for user ticket renewal' (Manual) 22
1.1.1.1.2.1 Set 'Reset account lockout counter after' to '15' or more (Automated) 24
1.1.1.1.2.2 Set 'Account lockout duration' to '15' or greater (Automated) 26
1.1.1.1.2.3 Set 'Account lockout threshold' is set to '6' or fewer (Automated) 28
1.1.1.1.3.1 Set 'Maximum password age' to '60' or less (Automated) 31
1.1.1.1.3.2 Set 'Enforce password history' to '24' or more (Automated) 33

ARCHIVE

1.1.1.1.3.3 Set 'Store passwords using reversible encryption' to 'Disabled' (Automated) 35
1.1.1.1.3.4 Set 'Minimum password age' to '1' or more (Automated) 36
1.1.1.1.3.5 Set 'Password must meet complexity requirements' to 'Enabled' (Automated) 38
1.1.1.1.3.6 Set 'Minimum password length' to '14' or more (Automated) 40
1.1.1.2.1.1 Set 'Domain controller: Allow server operators to schedule tasks' to 'Disabled' (Automated) ...43
1.1.1.2.1.2 Set 'Accounts: Guest account status' to 'Disabled' (Automated) 45
1.1.1.2.1.3 Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated) 47
1.1.1.2.1.4 Set 'Domain controller: Refuse machine account password changes' to 'Disabled' (Automated) 49
1.1.1.2.1.5 Set 'Accounts: Administrator account status' to 'Disabled' (Automated).....50
1.1.1.2.1.6 Set 'System objects: Default owner for objects created by members of the Administrators group' to 'Object creator' (Automated).....52
1.1.1.2.1.7 Set 'Network access: Shares that can be accessed anonymously' to 'None' (Automated) 54
1.1.1.2.1.8 Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated) 56
1.1.1.2.1.9 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated) 58
1.1.1.2.1.10 Set 'Devices: Prevent users from installing printer drivers' to 'Enabled' (Automated).....60
1.1.1.2.1.11 Set 'Devices: Unsigned driver installation behavior' to 'Warn but allow installation' (Automated) 62
1.1.1.2.1.12 Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated) 64
1.1.1.2.1.13 Set 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved (recommended)' to 'Enabled' (Automated).....65
1.1.1.2.1.14 Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated) 67
1.1.1.2.1.15 Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '90' (Automated).....69
1.1.1.2.1.16 Set 'MSS: (SynAttackProtect) Syn attack protection level (protects against DoS)' to 'Connections time out sooner if a SYN attack is detected' (Automated) 71
1.1.1.2.1.17 Set 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' to 'Enabled' (Automated).....73
1.1.1.2.1.18 Set 'MSS: (AutoShareServer) Enable Administrative Shares (recommended except for highly secure environments)' to 'Enabled' (Automated).....75
1.1.1.2.1.19 Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated) 77
1.1.1.2.1.20 Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated) 79
1.1.1.2.1.21 Set 'Microsoft network server: Amount of idle time required before suspending session' to '15' (Automated) 81
1.1.1.2.1.22 Set 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' to 'Enabled' (Automated).....82
1.1.1.2.1.23 Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual) 84
1.1.1.2.1.24 Set 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' to '300000 or 5 minutes (recommended)' (Automated).....86
1.1.1.2.1.25 Set 'Shutdown: Allow system to be shut down without having to log on' to 'Disabled' (Automated) 88
1.1.1.2.1.26 Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated) 90
1.1.1.2.1.27 Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated) 91
1.1.1.2.1.28 Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual).....94
1.1.1.2.1.29 Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual) 97
1.1.1.2.1.30 Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated) 99

ARCHIVE

1.1.1.2.1.31 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated) 101
1.1.1.2.1.32 Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated) 103
1.1.1.2.1.33 Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual) 105
1.1.1.2.1.34 Set 'System settings: Optional subsystems' to '' (Automated) 107
1.1.1.2.1.35 Set 'Devices: Allowed to format and eject removable media' to 'Administrators' (Automated) 109
1.1.1.2.1.36 Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated) 111
1.1.1.2.1.37 Set 'Interactive logon: Prompt user to change password before expiration' to '14' (Automated) 113
1.1.1.2.1.38 Set 'Domain member: Maximum machine account password age' to '30' (Automated) 114
1.1.1.2.1.39 Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated) 115
1.1.1.2.1.40 Configure 'Interactive logon: Display user information when the session is locked' (Manual) 117
1.1.1.2.1.41 Set 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' to '3' (Automated) 119
1.1.1.2.1.42 Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated) 121
1.1.1.2.1.43 Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated) 123
1.1.1.2.1.44 Configure 'Domain controller: LDAP server signing requirements' (Manual) 125
1.1.1.2.1.45 Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated) 127
1.1.1.2.1.46 Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated) 129
1.1.1.2.1.47 Configure 'Interactive logon: Message title for users attempting to log on' (Manual) 131
1.1.1.2.1.48 Configure 'Interactive logon: Message text for users attempting to log on' (Manual) 133
1.1.1.2.1.49 Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated) 135
1.1.1.2.1.50 Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated) 137
1.1.1.2.1.51 Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated) 139
1.1.1.2.1.52 Set 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' to 'Enabled' (Automated) 141
1.1.1.2.1.53 Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated) 143
1.1.1.2.1.54 Set 'Network access: Remotely accessible registry paths and sub-paths' to 'System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Sof (Automated) 145
1.1.1.2.1.55 Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual) 147
1.1.1.2.1.56 Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated) 149
1.1.1.2.1.57 Set 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' to 'Disabled' (Automated) 151
1.1.1.2.1.58 Set 'MSS: (TcpMaxConnectResponseRetransmissions) SYN-ACK retransmissions when a connection request is not acknowledged' to '3 & 6 seconds, half-open connections dropped after 21 seconds' (Automated) 153
1.1.1.2.1.59 Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated) 155

ARCHIVE

1.1.1.2.1.60 Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated) 157
1.1.1.2.1.61 Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated) 158
1.1.1.2.1.62 Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' or better (Automated) 160
1.1.1.2.1.63 Set 'Devices: Allow undock without having to log on' to 'Disabled' (Automated) 162
1.1.1.2.1.64 Set 'Audit: Audit the access of global system objects' to 'Disabled' (Automated) 164
1.1.1.2.1.65 Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Enabled' (Automated) 166
1.1.1.2.1.66 Set 'Interactive logon: Require smart card' to 'Disabled' (Automated) 168
1.1.1.2.1.67 Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual) 170
1.1.1.2.1.68 Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated) 172
1.1.1.2.1.69 Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated) 174
1.1.1.2.1.70 Set 'Network access: Remotely accessible registry paths' to 'System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion' (Automated) 176
1.1.1.2.1.71 Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '0' (Automated) 178
1.1.1.2.1.72 Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual) 180
1.1.1.2.1.73 Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated) 182
1.1.1.2.1.74 Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated) 184
1.1.1.2.1.75 Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated) 185
1.1.1.2.1.76 Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated) 187
1.1.1.2.1.77 Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated) 189
1.1.1.2.1.78 Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated) 191
1.1.1.2.1.79 Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Enabled' (Automated) 193
1.1.1.2.1.80 Set 'Network access: Do not allow storage of credentials or .NET Passports for network authentication' to 'Enabled' (Automated) 195
1.1.1.2.1.81 Set 'MSS: (EnableDeadGWDetect) Allow automatic detection of dead network gateways (could lead to DoS)' to 'Disabled' (Automated) 197
1.1.1.2.1.82 Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Disabled' (Automated) 198
1.1.1.2.1.83 Set 'Audit: Audit the use of Backup and Restore privilege' to 'Disabled' (Automated) 200
1.1.1.2.1.84 Set 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' to 'Disabled' (Automated) 202
1.1.1.2.1.85 Set 'MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.' to 'Only ISAKMP is exempt (recommended for Windows Server 2003)' (Automated) 204
1.1.1.2.2.1 Set 'Audit directory service access' to 'Failure' (Automated) 207
1.1.1.2.2.2 Set 'Audit account logon events' to 'Success, Failure' (Automated) 209
1.1.1.2.2.3 Set 'Audit logon events' to 'Success, Failure' (Automated) 211
1.1.1.2.2.4 Set 'Audit process tracking' to 'No Auditing' (Automated) 213
1.1.1.2.2.5 Set 'Audit account management' to 'Success, Failure' (Automated) 215
1.1.1.2.2.6 Set 'Audit policy change' to 'Success' (minimum) or 'Success and Failure' (Automated) 218
1.1.1.2.2.7 Set 'Audit system events' to 'Success' (minimum) or 'Success and Failure' (Automated) 220
1.1.1.2.2.8 Set 'Audit privilege use' to 'Failure' (minimum) or 'Success and Failure' (Automated) 222
1.1.1.2.2.9 Configure 'Audit object access' (Manual) 224
1.1.1.2.3.1 Set 'Allow log on through Terminal Services' to 'Administrators' (Automated) 227

ARCHIVE

1.1.1.2.3.2 Set 'Allow log on through Terminal Services' to 'Administrators, Remote desktop Users' (Automated) 229
1.1.1.2.3.3 Set 'Take ownership of files or other objects' to 'Administrators' (Automated) 231
1.1.1.2.3.4 Set 'Enable computer and user accounts to be trusted for delegation' to 'Administrators' (Automated) 232
1.1.1.2.3.5 Configure 'Enable computer and user accounts to be trusted for delegation' (Manual) 233
1.1.1.2.3.6 Set 'Remove computer from docking station' to 'Administrators' (Automated) 234
1.1.1.2.3.7 Configure 'Create permanent shared objects' (Manual) 236
1.1.1.2.3.8 Set 'Debug programs' to 'Administrators' (Automated) 237
1.1.1.2.3.9 Configure 'Load and unload device drivers' (Manual) 239
1.1.1.2.3.10 Set 'Adjust memory quotas for a process' to 'Administrators, LOCAL SERVICE, NETWORK SERVICE' (Automated) 240
1.1.1.2.3.11 Configure 'Generate security audits' (Manual) 242
1.1.1.2.3.12 Set 'Shut down the system' to 'Administrators' (Automated) 243
1.1.1.2.3.13 Configure 'Increase scheduling priority' (Manual) 245
1.1.1.2.3.14 Set 'Replace a process level token' to 'LOCAL SERVICE, NETWORK SERVICE' (Automated) 246
1.1.1.2.3.15 Configure 'Add workstations to domain' (Manual) 247
1.1.1.2.3.16 Configure 'Change the system time' (Manual) 249
1.1.1.2.3.17 Configure 'Restore files and directories' (Manual) 251
1.1.1.2.3.18 Configure 'Create a token object' (Manual) 253
1.1.1.2.3.19 Configure 'Synchronize directory service data' (Manual) 255
1.1.1.2.3.20 Set 'Profile system performance' to 'Administrators' (Automated) 256
1.1.1.2.3.21 Configure 'Access this computer from the network' (Manual) 258
1.1.1.2.3.22 Set 'Profile single process' to 'Administrators' (Automated) 260
1.1.1.2.3.23 Configure 'Impersonate a client after authentication' (Manual) 262
1.1.1.2.3.24 Set 'Create a pagefile' to 'Administrators' (Automated) 264
1.1.1.2.3.25 Set 'Deny log on as a batch job' to 'Guests' (Automated) 265
1.1.1.2.3.26 Set 'Deny log on through Terminal Services' to 'Guests' (Automated) 267
1.1.1.2.3.27 Configure 'Act as part of the operating system' (Manual) 269
1.1.1.2.3.28 Configure 'Back up files and directories' (Manual) 270
1.1.1.2.3.29 Set 'Log on as a service' to 'NETWORK SERVICE' (Automated) 271
1.1.1.2.3.30 Set 'Deny access to this computer from the network' to 'ANONYMOUS LOGON, Guests' (Automated) 273
1.1.1.2.3.31 Configure 'Perform volume maintenance tasks' (Manual) 275
1.1.1.2.3.32 Configure 'Deny log on locally' (Manual) 276
1.1.1.2.3.33 Set 'Allow log on locally' to 'Administrators' (Automated) 278
1.1.1.2.3.34 Configure 'Create global objects' (Manual) 280
1.1.1.2.3.35 Configure 'Bypass traverse checking' (Manual) 281
1.1.1.2.3.36 Configure 'Deny log on as a service' (Manual) 283
1.1.1.2.3.37 Set 'Manage auditing and security log' to 'Administrators' (Automated) 285
1.1.1.2.3.38 Configure 'Lock pages in memory' (Manual) 286
1.1.1.2.3.39 Configure 'Force shutdown from a remote system' (Manual) 287
1.1.1.2.3.40 Set 'Modify firmware environment values' to 'Administrators' (Automated) 288
1.1.1.2.3.41 Configure 'Log on as a batch job' (Manual) 289
1.1.1.3.1 Set 'Retention method for system log' to 'Overwrites events as needed' (Automated) 292
1.1.1.3.2 Set 'Maximum application log size' to '16384' (Automated) 294
1.1.1.3.3 Set 'Retention method for security log' to 'Overwrites events as needed' (Automated) 296
1.1.1.3.4 Set 'Maximum system log size' to '16384' (Automated) 298
1.1.1.3.5 Set 'Maximum security log size' to '81920' (Automated) 300
1.1.1.3.6 Set 'Retention method for application log' to 'Overwrites events as needed' (Automated) 302
1.1.1.3.7 Configure 'Retain system log' (Manual) 304
1.1.1.3.8 Configure 'Retain security log' (Manual) 305

ARCHIVE

1.1.1.3.9 Configure 'Retain application log' (Manual) 306
1.2 Administrative Templates 307
1.2.1 Network 307
1.2.1.1.1.1.1 Configure 'Windows Firewall: Allow ICMP exceptions' (Manual) 308
1.2.1.1.1.1.2 Configure 'Windows Firewall: Define inbound port exceptions' (Manual) 310
1.2.1.1.1.1.3 Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual) 312
1.2.1.1.1.1.4 Configure 'Windows Firewall: Allow local program exceptions' (Manual) 313
1.2.1.1.1.1.5 Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual) 315
1.2.1.1.1.1.6 Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual) 317
1.2.1.1.1.1.7 Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual) 319
1.2.1.1.1.1.8 Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual) 320
1.2.1.1.1.1.9 Configure 'Windows Firewall: Define inbound program exceptions' (Manual) 322
1.2.1.1.1.1.10 Configure 'Windows Firewall: Allow local port exceptions' (Manual) 324
1.2.1.1.1.1.11 Configure 'Windows Firewall: Prohibit notifications' (Manual) 326
1.2.1.1.1.1.12 Configure 'Windows Firewall: Do not allow exceptions' (Manual) 328
1.2.1.1.1.1.13 Configure 'Windows Firewall: Protect all network connections' (Manual) 330
1.2.1.1.1.2.1 Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual) 332
1.2.1.1.1.2.2 Configure 'Windows Firewall: Do not allow exceptions' (Manual) 334
1.2.1.1.1.2.3 Configure 'Windows Firewall: Allow local program exceptions' (Manual) 336
1.2.1.1.1.2.4 Configure 'Windows Firewall: Allow local port exceptions' (Manual) 338
1.2.1.1.1.2.5 Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual) 340
1.2.1.1.1.2.6 Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual) 342
1.2.1.1.1.2.7 Configure 'Windows Firewall: Allow ICMP exceptions' (Manual) 344
1.2.1.1.1.2.8 Configure 'Windows Firewall: Prohibit notifications' (Manual) 346
1.2.1.1.1.2.9 Configure 'Windows Firewall: Define inbound port exceptions' (Manual) 348
1.2.1.1.1.2.10 Configure 'Windows Firewall: Protect all network connections' (Manual) 350
1.2.1.1.1.2.11 Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual) 351
1.2.1.1.1.2.12 Configure 'Windows Firewall: Define inbound program exceptions' (Manual) 352
1.2.1.1.1.2.13 Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual) 354
1.2.2 System 356
1.2.2.1.1 Configure 'Offer Remote Assistance' (Manual) 357
1.2.2.1.2 Configure 'Solicited Remote Assistance' (Manual) 359
1.2.2.2.1.1 Configure 'Turn off Windows Update device driver searching' (Manual) 362
1.2.2.2.1.2 Configure 'Turn off Search Companion content file updates' (Manual) 364
1.2.2.2.1.3 Configure 'Turn off Internet download for Web publishing and online ordering wizards' (Manual) 365
1.2.2.2.1.4 Configure 'Turn off the Windows Messenger Customer Experience Improvement Program' (Manual) 366
1.2.2.2.1.5 Configure 'Turn off printing over HTTP' (Manual) 367
1.2.2.2.1.6 Configure 'Turn off the "Publish to Web" task for files and folders' (Manual) 368
1.2.2.2.1.7 Configure 'Turn off downloading of print drivers over HTTP' (Manual) 369
1.2.2.3.1 Configure 'Registry policy processing' (Manual) 371
1.2.2.3.2 Configure 'Do not apply during periodic background processing' (Manual) 373
1.2.2.3.3 Configure 'Process even if the Group Policy objects have not changed' (Manual) 374
1.2.2.4.1 Set 'RPC Endpoint Mapper Client Authentication' to 'Enabled' (Manual) 376
1.2.2.4.2 Set 'Restrictions for Unauthenticated RPC clients' to 'Enabled:Authenticated' (Automated) 377
1.2.2.5.1 Configure 'Do not process the legacy run list' (Manual) 380
1.2.2.5.2 Configure 'Do not process the run once list' (Manual) 382
1.2.3 Windows Components 384
1.2.3.1.1 Set 'Turn off Autoplay' to 'Enabled:All drives' (Automated) 385
1.2.3.2.1 Configure 'Configure Automatic Updates' (Manual) 388

ARCHIVE

1.2.3.2.2 Configure 'Specify intranet Microsoft update service location' (Manual) 390
1.2.3.2.3 Configure 'Set the intranet statistics server' (Manual) 392
1.2.3.2.4 Configure 'Set the intranet update service for detecting updates' (Manual) 393
1.2.3.2.5 Configure 'No auto-restart with logged on users for scheduled automatic updates installations' (Manual).....394
1.2.3.2.6 Configure 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' (Manual) 396
1.2.3.2.7 Configure 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' (Manual) 398
1.2.3.2.8 Configure 'Reschedule Automatic Updates scheduled installations' (Manual) 400
1.2.3.3.1 Configure 'Do not allow Windows Messenger to be run' (Manual) 403
1.2.3.4.1.1 Configure 'Do not allow passwords to be saved' (Manual).....405
1.2.3.4.2.1.1 Configure 'Do not allow drive redirection' (Manual).....407
1.2.3.4.2.2.1 Configure 'Allow users to connect remotely using Remote Desktop Services' (Manual).....409
1.2.3.4.2.3.1 Configure 'Set client connection encryption level' (Manual) 412
1.2.3.4.2.3.2 Configure 'Always prompt for password upon connection' (Manual) 413
1.2.3.5.1.1 Configure 'Report operating system errors' (Manual).....416
1.2.3.5.2 Configure 'Display Error Notification' (Manual).....418
1.2.3.6.1 Configure 'Disable remote Desktop Sharing' (Manual).....421
1.2.3.7.1 Set 'Always install with elevated privileges' to 'Disabled' (Automated) 423
1.2.3.8.1 Configure 'Require trusted path for credential entry.' (Manual) 426

Appendix: Summary Table 427

Appendix: Change History 446

ARCHIVE

Overview

This is the archive of the CIS Microsoft Windows Server 2003 [imported] v3.1.0 Benchmark. CIS encourages you to migrate to a more recent, supported version of this technology.

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key **component** of a comprehensive cybersecurity program.

This document, CIS Microsoft Windows Server 2003 Benchmark v3.1.0, provides prescriptive guidance for establishing a secure configuration posture for CIS Microsoft Windows Server 2003. To obtain the latest version of this guide, please visit http://benchmarks.cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This document is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft Windows Server 2003.

ARCHIVE

Consensus Guidance

This CIS Benchmark was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

ARCHIVE

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

ARCHIVE

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

ARCHIVE

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

ARCHIVE

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - Domain Controller**

  Items in this profile apply to Domain Controllers and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

- **Level 1 - Member Server**

  Items in this profile apply to Member Servers and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

ARCHIVE

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Microsoft's Security Compliance Management Toolkit was an excellent resource in the development of this Benchmark. CIS also extends special recognition to the development teams of those resources. Readers are encouraged to download the toolkit to access many great resources, including tools such as GPOAccelerator and DCM Configuration Packs, which aid in the rapid deployment of security configuration policies

Contributor
Jordan Rakoske

ARCHIVE

Recommendations

1 Computer Configuration

1.1 Windows Settings

1.1.1 Security Settings

1.1.1.1 Account Policies

1.1.1.1.1 Kerberos Policy

ARCHIVE

1.1.1.1.1.1 Configure 'Maximum lifetime for service ticket' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This security setting determines the maximum amount of time (in minutes) that a granted session ticket can be used to access a particular service. The setting must be greater than 10 minutes and less than or equal to the setting for Maximum lifetime for user ticket. If a client presents an expired session ticket when it requests a connection to a server, the server returns an error message. The client must request a new session ticket from the Kerberos V5 Key Distribution Center (KDC). Once a connection is authenticated, however, it no longer matters whether the session ticket remains valid. Session tickets are used only to authenticate new connections with servers. Ongoing operations are not interrupted if the session ticket that is used to authenticate the connection expires during the connection. Default: 600 minutes (10 hours).

Rationale:

If you configure the value for the Maximum lifetime for service ticket setting too high, then users might be able to access network resources outside of their logon hours. Also, users whose accounts were disabled might have continued access to network services with valid service tickets that were issued before their accounts were disabled.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Kerberos Policy\Maximum lifetime for service ticket
```

References:

1. CCE-3237-5

ARCHIVE

1.1.1.1.1.2 Configure 'Enforce user logon restrictions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Kerberos policy settings determine Kerberos-related attributes of domain user accounts, such as the Maximum lifetime for user ticket and Enforce user logon restrictions settings. However, these policy settings are not used for stand-alone client computers because they do not participate in a domain.

Rationale:

If you disable this policy setting, users could receive session tickets for services that they no longer have the right to use because the right was removed after they logged on.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Kerberos Policy\Enforce user logon restrictions
```

References:

1. CCE-3700-2

ARCHIVE

1.1.1.1.1.3 Configure 'Maximum lifetime for user ticket' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This security setting determines the maximum amount of time (in hours) that a user's ticket-granting ticket (TGT) may be used. When a user's TGT expires, a new one must be requested or the existing one must be renewed. Default: 10 hours.

Rationale:

If you configure the value for the Maximum lifetime for user ticket setting too high, then users might be able to access network resources outside of their logon hours. Also, users whose accounts were disabled might continue to have access to network services with valid service tickets that were issued before their accounts were disabled.

Impact:

Reducing this setting from the default value reduces the likelihood that the TGT will be used to access resources that the user does not have rights to. However, it will require more frequent requests to the KDC for TGTs on behalf of users. Most KDCs can support a value of four hours without too much additional burden.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Kerberos Policy\Maximum lifetime for user ticket
```

References:

1. CCE-3625-1

ARCHIVE

1.1.1.1.1.4 Configure 'Maximum tolerance for computer clock synchronization' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

Many security services, especially authentication, rely on an accurate computer clock to perform their jobs. You should ensure computer time is accurate and that all servers in your organization use the same time source. The Windows Server 2003 W32Time service provides time synchronization for Windows Server 2003 and Microsoft Windows XPbased computers that run in an Active Directory domain. The W32Time service synchronizes the clocks of Windows Server 2003based computers with the domain controllers in a domain. This synchronization is necessary for the Kerberos protocol and other authentication protocols to work properly. To function correctly, a number of Windows Server family components rely on accurate and synchronized time. If the clocks are not synchronized on the clients, the Kerberos authentication protocol might deny access to users. Another important benefit that time synchronization provides is event correlation on all of the clients in your enterprise. Synchronized clocks on the clients in your environment ensure that you can correctly analyze events that take place in uniform sequence on those clients throughout the organization. The W32Time service uses the Network Time Protocol (NTP) to synchronize clocks on computers that run Windows Server 2003. In a Windows Server 2003 forest, time is synchronized by default in the following manner: . The primary domain controller (PDC) emulator operations master in the forest root domain is the authoritative time source for the organization. . All PDC operation masters in other domains in the forest follow the hierarchy of domains when they select a PDC emulator with which to synchronize their time. . All domain controllers in a domain synchronize their time with the PDC emulator operations master in their domain as their inbound time partner. . All member servers and client desktop computers use the authenticating domain controller as their inbound time partner. To ensure that the time is accurate, the PDC emulator in the forest root domain can be synchronized to an authoritative time source, such as a reliable NTP source or a highly accurate clock on your network. Note that NTP synchronization uses UDP port 123 traffic. Before you synchronize with an external server, you should weigh the benefits of opening this port against the potential security risk. Also, if you synchronize with an external server that you do not control, you risk configuring your servers with the incorrect time. The external server could be compromised or spoofed by an attacker to maliciously manipulate the clocks on your computers. As explained earlier, the Kerberos authentication protocol requires synchronized computer clocks. If they are not synchronized, a denial of service may occur.

ARCHIVE

Rationale:

To prevent "replay attacks," the Kerberos authentication protocol uses time stamps as part of its protocol definition. For time stamps to work properly, the clocks of the client and the domain controller need to be closely synchronized. Because the clocks of two computers are often not synchronized, administrators can use this policy to establish the maximum acceptable difference to Kerberos between a client clock and a domain controller clock. If the difference between the client clock and the domain controller clock is less than the maximum time difference specified in this setting, any time stamp that is used in a session between the two computers is considered to be authentic.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Kerberos Policy\Maximum tolerance for computer clock synchronization
```

Default Value:

5

References:

1. CCE-3396-9

ARCHIVE

1.1.1.1.1.5 Configure 'Maximum lifetime for user ticket renewal' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting determines the period of time (in days) during which a user's ticket-granting ticket (TGT) can be renewed. To prevent replay attacks, the Kerberos authentication protocol uses time stamps as part of its protocol definition. For time stamps to work properly, the clocks of the client and the domain controller need to be synchronized as closely as possible. Because the clocks of two computers are often not synchronized, administrators can use this policy to establish the maximum elapsed time within which a Kerberos negotiation must complete; the elapsed time is computed from the timestamps. The value of this setting limits the maximum time difference that can be tolerated between the domain controller and the client computer.

Rationale:

If the value for the Maximum lifetime for user ticket renewal setting is too high, users might be able to renew very old user tickets.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Kerberos Policy\Maximum lifetime for user ticket renewal
```

References:

1. CCE-7606-7

ARCHIVE

1.1.1.1.2 Account Lockout Policy

ARCHIVE

1.1.1.1.2.1 Set 'Reset account lockout counter after' to '15' or more (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the length of time before the Account lockout threshold resets to zero. The default value for this policy setting is Not Defined. If the Account lockout threshold is defined, this reset time must be less than or equal to the value for the Account lockout duration setting.

If you leave this policy setting at its default value or configure the value to an interval that is too long, your environment could be vulnerable to a DoS attack. An attacker could maliciously perform a number of failed logon attempts on all users in the organization, which will lock out their accounts. If no policy were determined to reset the account lockout, it would be a manual task for administrators. Conversely, if a reasonable time value is configured for this policy setting, users would be locked out for a set period until all of the accounts are unlocked automatically.

Rationale:

Users can accidentally lock themselves out of their accounts if they mistype their password multiple times. To reduce the chance of such accidental lockouts, the Reset account lockout counter after setting determines the number of minutes that must elapse before the counter that tracks failed logon attempts and triggers lockouts is reset to 0.

Impact:

If you do not configure this policy setting or if the value is configured to an interval that is too long, a denial of service (DoS) attack could occur. An attacker could maliciously attempt to log on to each user's account numerous times and lock out their accounts as described in the preceding paragraphs. If you do not configure the Reset account lockout counter after setting, administrators would have to manually unlock all accounts. If you configure this policy setting to a reasonable value the users would be locked out for some period, after which their accounts would unlock automatically. Be sure that you notify users of the values used for this policy setting so that they will wait for the lockout timer to expire before they call the help desk about their inability to log on.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Reset account lockout counter` after is set to `15` or more.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Account Lockout Policy\Reset account lockout counter after
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Reset account lockout counter after` as recommended.

References:

1. CCE-3574-1

ARCHIVE

1.1.1.1.2.2 Set 'Account lockout duration' to '15' or greater (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the length of time that must pass before a locked account is unlocked and a user can try to log on again. The setting does this by specifying the number of minutes a locked out account will remain unavailable. If the value for this policy setting is configured to 0, locked out accounts will remain locked out until an administrator manually unlocks them.

Although it might seem like a good idea to configure the value for this policy setting to a high value, such a configuration will likely increase the number of calls that the help desk receives to unlock accounts locked by mistake. Users should be aware of the length of time a lock remains in place, so that they realize they only need to call the help desk if they have an extremely urgent need to regain access to their computer.

Rationale:

A denial of service (DoS) condition can be created if an attacker abuses the Account lockout threshold and repeatedly attempts to log on with a specific account. Once you configure the Account lockout threshold setting, the account will be locked out after the specified number of failed attempts. If you configure the Account lockout duration setting to 0, then the account will remain locked out until an administrator unlocks it manually.

Impact:

Although it may seem like a good idea to configure this policy setting to never automatically unlock an account, such a configuration can increase the number of requests that your organization's help desk receives to unlock accounts that were locked by mistake.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Account lockout duration` is set to `15` or more.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Account Lockout Policy\Account lockout duration
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Account lockout duration` as recommended.

References:

1. CCE-2627-8

ARCHIVE

1.1.1.1.2.3 Set 'Account lockout threshold' is set to '6' or fewer (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the number of failed logon attempts before a lock occurs. Authorized users can lock themselves out of an account by mistyping their password or by remembering it incorrectly, or by changing their password on one computer while logged on to another computer. The computer with the incorrect password will continuously try to authenticate the user, and because the password it uses to authenticate is incorrect, a lock occurs. To avoid accidental lockout of authorized users, set the account lockout threshold to a high number. The default value for this policy setting is 0 invalid logon attempts, which disables the account lockout feature.

Because it is possible for an attacker to use this lockout state as a denial of service (DoS) by triggering a lockout on a large number of accounts, your organization should determine whether to use this policy setting based on identified threats and the risks you want to mitigate. There are two options to consider for this policy setting.

• Configure the value for Account lockout threshold to 0 to ensure that accounts will not be locked out. This setting value will prevent a DoS attack that attempts to lock out accounts in your organization. It will also reduce help desk calls, because users will not be able to lock themselves out of their accounts accidentally. However, this setting value will not prevent a brute force attack. The following defenses should also be considered:

• A password policy that forces all users to have complex passwords made up of 8 or more characters.

• A robust auditing mechanism, which will alert administrators when a series of account lockouts occurs in the environment. For example, the auditing solution should monitor for security event 539, which is a logon failure. This event identifies that there was a lock on the account at the time of the logon attempt.

The second option is:

• Configure the value for Account lockout threshold to a value that provides users with the ability to mistype their password several times, but locks out the account if a brute force password attack occurs. This configuration will prevent accidental account lockouts and reduce help desk calls, but will not prevent a DoS attack.

ARCHIVE

Rationale:

Password attacks can use automated methods to try millions of password combinations for any user account. The effectiveness of such attacks can be almost eliminated if you limit the number of failed logons that can be performed.

However, a denial of service (DoS) attack could be performed on a domain that has an account lockout threshold configured. An attacker could programmatically attempt a series of password attacks against all users in the organization. If the number of attempts is greater than the account lockout threshold, the attacker might be able to lock out every account.

Impact:

If this policy setting is enabled, a locked-out account will not be usable until it is reset by an administrator or until the account lockout duration expires. This setting will likely generate a number of additional help desk calls. In fact, locked accounts cause the greatest number of calls to the help desk in many organizations.

If you enforce this setting an attacker could cause a denial of service condition by deliberately generating failed logons for multiple user, therefore you should also configure the Account Lockout Duration to a relatively low value such as 15 minutes.

If you configure the Account Lockout Threshold to 0, there is a possibility that an attacker's attempt to discover passwords with a brute force password attack might go undetected if a robust audit mechanism is not in place.

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Account lockout threshold` is set to 6 or less.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Account Lockout Policy\Account lockout threshold
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Account lockout threshold` as recommended.

References:

1. CCE-3551-9

ARCHIVE

1.1.1.1.3 Password Policy

ARCHIVE

1.1.1.1.3.1 Set 'Maximum password age' to '60' or less (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting defines how long a user can use their password before it expires.

Values for this policy setting range from 0 to 999 days. If you set the value to 0, the password will never expire. The default value for this policy setting is 42 days.

Because attackers can crack passwords, the more frequently you change the password the less opportunity an attacker has to use a cracked password. However, the lower this value is set, the higher the potential for an increase in calls to help desk support due to users having to change their password or forgetting which password is current.

Rationale:

The longer a password exists the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user, or by the user sharing the password. Configuring the Maximum password age setting to 0 so that users are never required to change their passwords is a major security risk because that allows a compromised password to be used by the malicious user for as long as the valid user is authorized access.

Impact:

If the Maximum password age setting is too low, users are required to change their passwords very often. Such a configuration can reduce security in the organization, because users might write their passwords in an insecure location or lose them. If the value for this policy setting is too high, the level of security within an organization is reduced because it allows potential attackers more time in which to discover user passwords or to use compromised accounts.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Maximum password age` is set to 60 or less.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Maximum password age
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Maximum password age` as recommended.

References:

1. CCE-3530-3

ARCHIVE

1.1.1.1.3.2 Set 'Enforce password history' to '24' or more (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the number of renewed, unique passwords that have to be associated with a user account before you can reuse an old password. The value for this policy setting must be between 0 and 24 passwords. The default value for Windows Vista is 0 passwords, but the default setting in a domain is 24 passwords. To maintain the effectiveness of this policy setting, use the Minimum password age setting to prevent users from repeatedly changing their password.

Rationale:

The longer a user uses the same password, the greater the chance that an attacker can determine the password through brute force attacks. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced.

If you specify a low number for this policy setting, users will be able to use the same small number of passwords repeatedly. If you do not also configure the Minimum password age setting, users might repeatedly change their passwords until they can reuse their original password.

Impact:

The major impact of this configuration is that users must create a new password every time they are required to change their old one. If users are required to change their passwords to new unique values, there is an increased risk of users who write their passwords somewhere so that they do not forget them. Another risk is that users may create passwords that change incrementally (for example, password01, password02, and so on) to facilitate memorization but make them easier to guess. Also, an excessively low value for the Minimum password age setting will likely increase administrative overhead, because users who forget their passwords might ask the help desk to reset them frequently.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Enforce password history` is set to a value of `24` or greater.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Enforce password history
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Enforce password history` as recommended.

References:

1. CCE-3446-2

ARCHIVE

1.1.1.1.3.3 Set 'Store passwords using reversible encryption' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines whether the operating system stores passwords in a way that uses reversible encryption, which provides support for application protocols that require knowledge of the user's password for authentication purposes. Passwords that are stored with reversible encryption are essentially the same as plaintext versions of the passwords.

Rationale:

Enabling this policy setting allows the operating system to store passwords in a weaker format that is much more susceptible to compromise and weakens your system security.

Impact:

If your organization uses either the CHAP authentication protocol through remote access or IAS services or Digest Authentication in IIS, you must configure this policy setting to Enabled. This setting is extremely dangerous to apply through Group Policy on a user-by-user basis, because it requires the appropriate user account object to be opened in Active Directory Users and Computers.

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Store passwords using reversible encryption` is set to `Disabled`.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Store passwords using reversible encryption
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Store passwords using reversible encryption` as recommended.

References:

1. CCE-2644-3

ARCHIVE

1.1.1.1.3.4 Set 'Minimum password age' to '1' or more (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the number of days that you must use a password before you can change it. The range of values for this policy setting is between 1 and 999 days. (You may also set the value to 0 to allow immediate password changes.) The default value for this setting is 0 days.

Rationale:

Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise. Unfortunately, passwords are compromised and if an attacker is targeting a specific individual user account, with foreknowledge of data about that user, reuse of old passwords can cause a security breach. To address password reuse a combination of security settings is required. Using this policy setting with the Enforce password history setting prevents the easy reuse of old passwords. For example, if you configure the Enforce password history setting to ensure that users cannot reuse any of their last 12 passwords, they could change their password 13 times in a few minutes and reuse the password they started with, unless you also configure the Minimum password age setting to a number that is greater than 0. You must configure this policy setting to a number that is greater than 0 for the Enforce password history setting to be effective.

Impact:

If an administrator sets a password for a user but wants that user to change the password when the user first logs on, the administrator must select the User must change password at next logon check box, or the user will not be able to change the password until the next day.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Minimum password age` is set to `1` or more.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Minimum password age
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Minimum password age` as recommended.

Default Value:

0

References:

1. CCE-3548-5

ARCHIVE

1.1.1.1.3.5 Set 'Password must meet complexity requirements' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting checks all new passwords to ensure that they meet basic requirements for strong passwords.

When this policy is enabled, passwords must meet the following minimum requirements:

• Not contain the user's account name or parts of the user's full name that exceed two consecutive characters

• Be at least six characters in length

• Contain characters from three of the following four categories:

• English uppercase characters (A through Z)

• English lowercase characters (a through z)

• Base 10 digits (0 through 9)

• Non-alphabetic characters (for example, !, $, #, %)

• A catch-all category of any Unicode character that does not fall under the previous four categories. This fifth category can be regionally specific.

Each additional character in a password increases its complexity exponentially. For instance, a seven-character, all lower-case alphabetic password would have 267 (approximately 8 x 109 or 8 billion) possible combinations. At 1,000,000 attempts per second (a capability of many password-cracking utilities), it would only take 133 minutes to crack. A seven-character alphabetic password with case sensitivity has 527 combinations. A seven-character case-sensitive alphanumeric password without punctuation has 627 combinations. An eight-character password has 268 (or 2 x 1011) possible combinations. Although this might seem to be a large number, at 1,000,000 attempts per second it would take only 59 hours to try all possible passwords. Remember, these times will significantly increase for passwords that use ALT characters and other special keyboard characters such as "!" or "@". Proper use of the password settings can help make it difficult to mount a brute force attack.

Rationale:

Passwords that contain only alphanumeric characters are extremely easy to discover with several publicly available tools.

ARCHIVE

Impact:

If the default password complexity configuration is retained, additional help desk calls for locked-out accounts could occur because users might not be accustomed to passwords that contain non-alphabetic characters. However, all users should be able to comply with the complexity requirement with minimal difficulty.

If your organization has more stringent security requirements, you can create a custom version of the Passfilt.dll file that allows the use of arbitrarily complex password strength rules. For example, a custom password filter might require the use of non-upper row characters. (Upper row characters are those that require you to hold down the SHIFT key and press any of the digits between 1 and 0.) A custom password filter might also perform a dictionary check to verify that the proposed password does not contain common dictionary words or fragments.

Also, the use of ALT key character combinations can greatly enhance the complexity of a password. However, such stringent password requirements can result in unhappy users and an extremely busy help desk. Alternatively, your organization could consider a requirement for all administrator passwords to use ALT characters in the 0128â€“0159 range. (ALT characters outside of this range can represent standard alphanumeric characters that would not add additional complexity to the password.)

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Password must meet complexity requirements` is set to `Enabled`.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Password must meet complexity requirements
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Password must meet complexity requirements` as recommended.

References:

1. CCE-3442-1

ARCHIVE

1.1.1.1.3.6 Set 'Minimum password length' to '14' or more (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "pass phrase" is a better term than "password." In Microsoft Windows 2000 or later, pass phrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a $5 milkshake" is a valid pass phrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length.

In enterprise environments, ensure that the value for the Minimum password length setting is configured to 8 characters. This policy setting is long enough to provide adequate security. In high security environments, configure the value to 12 characters.

Rationale:

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

Impact:

Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave the information in an insecure location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase the volume of help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about pass phrases, which are often easier to remember and, due to the larger number of character combinations, much harder to discover.

Note: Older versions of Windows such as Windows 98 and Windows NT® 4.0 do not support passwords that are longer than 14 characters. Computers that run these older operating systems are unable to authenticate with computers or domains that use accounts that require long passwords.

ARCHIVE

Audit:

Using Group Policy Management Console, or a similar tool, navigate to the following path and check whether `Minimum password length` is set to `14` or more.

```
Computer Configuration\Windows Settings\Security Settings\Account
Policies\Password Policy\Minimum password length
```

Remediation:

Navigate to the Group Policy UI path expressed in the Audit procedure and set `Minimum password length` as recommended.

References:

1. CCE-3424-9

ARCHIVE

1.1.1.2 Local Policies

1.1.1.2.1 Security Options

ARCHIVE

1.1.1.2.1.1 Set 'Domain controller: Allow server operators to schedule tasks' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting determines whether members of the Server Operators group are allowed to submit jobs by means of the AT schedule facility. The impact of this policy setting configuration should be small for most organizations. Users, including those in the Server Operators group, will still be able to create jobs by means of the Task Scheduler Wizard, but those jobs will run in the context of the account with which the user authenticates when they set up the job. Note: An AT Service Account can be modified to select a different account rather than the LOCAL SYSTEM account. To change the account, open System Tools, click Scheduled Tasks, and then click Accessories folder. Then click AT Service Account on the Advanced menu.

Rationale:

If you enable this policy setting, jobs that are created by server operators by means of the AT service will execute in the context of the account that runs that service. By default, that is the local SYSTEM account. If you enable this policy setting, server operators could perform tasks that SYSTEM is able to do but that they would typically not be able to do, such as add their account to the local Administrators group.

Impact:

The impact should be small for most organizations. Users (including those in the Server Operators group) will still be able to create jobs by means of the Task Scheduler Wizard. However, those jobs will run in the context of the account that the user authenticates with when setting up the job.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:SubmitControl
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain controller: Allow server operators to
schedule tasks
```

References:

1. CCE-3479-3

ARCHIVE

1.1.1.2.1.2 Set 'Accounts: Guest account status' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines whether the Guest account is enabled or disabled. The Guest account allows unauthenticated network users to gain access to the system. Note that this setting will have no impact when applied to the domain controller organizational unit via group policy because domain controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings.

Rationale:

The default Guest account allows unauthenticated network users to log on as Guest with no password. These unauthorized users could access any resources that are accessible to the Guest account over the network. This capability means that any network shares with permissions that allow access to the Guest account, the Guests group, or the Everyone group will be accessible over the network, which could lead to the exposure or corruption of data.

Impact:

All network users will need to authenticate before they can access shared resources. If you disable the Guest account and the Network Access: Sharing and Security Model option is set to Guest Only, network logons, such as those performed by the Microsoft Network Server (SMB Service), will fail. This policy setting should have little impact on most organizations because it is the default setting in Microsoft Windows® 2000, Windows XP, and later versions of Windows.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Accounts: Guest account status
```

References:

1. CCE-2908-2

ARCHIVE

1.1.1.2.1.3 Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether local accounts that are not password protected can be used to log on from locations other than the physical computer console. If you enable this policy setting, local accounts that have blank passwords will not be able to log on to the network from remote client computers. Such accounts will only be able to log on at the keyboard of the computer.

Rationale:

Blank passwords are a serious threat to computer security and should be forbidden through both organizational policy and suitable technical measures. In fact, the default settings for Windows Server 2003 Active Directory® directory service domains require complex passwords of at least seven characters. However, if users with the ability to create new accounts bypass your domain-based password policies, they could create accounts with blank passwords. For example, a user could build a stand-alone computer, create one or more accounts with blank passwords, and then join the computer to the domain. The local accounts with blank passwords would still function. Anyone who knows the name of one of these unprotected accounts could then use it to log on.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:LimitBlankPasswordUse
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Accounts: Limit local account use of blank
passwords to console logon only
```

Default Value:

Not defined

References:

1. CCE-3357-1

ARCHIVE

1.1.1.2.1.4 Set 'Domain controller: Refuse machine account password changes' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This security setting determines whether domain controllers will refuse requests from member computers to change computer account passwords. By default, member computers change their computer account passwords every 30 days. If enabled, the domain controller will refuse computer account password change requests. If it is enabled, this setting does not allow a domain controller to accept any changes to a computer account's password. Default: This policy is not defined, which means that the system treats it as Disabled.

Rationale:

If you enable this policy setting on all domain controllers in a domain, domain members will not be able to change their computer account passwords, and those passwords will be more susceptible to attack.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:Refu
sePasswordChange
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain controller: Refuse machine account password
changes
```

References:

1. CCE-3605-3

ARCHIVE

1.1.1.2.1.5 Set 'Accounts: Administrator account status' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server

Description:

This policy setting enables or disables the Administrator account during normal operation. When a computer is booted into safe mode, the Administrator account is always enabled, regardless of how this setting is configured. Note that this setting will have no impact when applied to the domain controller organizational unit via group policy because domain controllers have no local account database. It can be configured at the domain level via group policy, similar to account lockout and password policy settings.

Rationale:

In some organizations, it can be a daunting management challenge to maintain a regular schedule for periodic password changes for local accounts. Therefore, you may want to disable the built-in Administrator account instead of relying on regular password changes to protect it from attack. Another reason to disable this built-in account is that it cannot be locked out no matter how many failed logons it accrues, which makes it a prime target for brute force attacks thattempt to guess passwords. Also, this account has a well-known security identifier (SID) and there are third-party tools that allow authentication by using the SID rather than the account name. This capability means that even if you rename the Administrator account, an attacker could launch a brute force attack by using the SID to log on.

Impact:

Maintenance issues can arise under certain circumstances if you disable the Administrator account. For example, if the secure channel between a member computer and the domain controller fails in a domain environment for any reason and there is no other local Administrator account, you must restart in safe mode to fix the problem that broke the secure channel. If the current Administrator password does not meet the password requirements, you will not be able to re-enable the Administrator account after it is disabled. If this situation occurs, another member of the Administrators group must set the password on the Administrator account with the Local Users and Groups tool.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Accounts: Administrator account status
```

Default Value:

Enabled

References:

1. CCE-8049-9

ARCHIVE

1.1.1.2.1.6 Set 'System objects: Default owner for objects created by members of the Administrators group' to 'Object creator' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the Administrators group or an object creator is the default owner of any system objects that are created. When system objects are created, the ownership will reflect which account created the object rather than the more generic Administrators group.

Rationale:

If you configure this policy setting to Administrators group, it will be impossible to hold individuals accountable for the creation of new system objects.

Impact:

When system objects are created, the ownership will reflect which account created the object instead of the more generic Administrators group. A consequence of this policy setting is that objects will become orphaned when user accounts are deleted. For example, when a member of the information technology group leaves, any objects that they created anywhere in the domain will have no owner. This situation could become an administrative burden as administrators have to manually take ownership of orphaned objects to update their permissions. This potential burden can be minimized if you can ensure that Full Control is always assigned to new objects for a domain group such as Domain Admins.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:nodefaultadminowner
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System objects: Default owner for objects created
by members of the Administrators group
```

Default Value:

Administrators

References:

1. CCE-2947-0

ARCHIVE

1.1.1.2.1.7 Set 'Network access: Shares that can be accessed anonymously' to 'None' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines which network shares can be accessed by anonymous users. The default configuration for this policy setting has little effect because all users have to be authenticated before they can access shared resources on the server. Note: It can be very dangerous to add other shares to this Group Policy setting. Any network user can access any shares that are listed, which could exposure or corrupt sensitive data. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

It is very dangerous to enable this setting. Any shares that are listed can be accessed by any network user, which could lead to the exposure or corruption of sensitive data.

Impact:

There should be little impact because this is the default configuration. Only authenticated users will have access to shared resources on the server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
NullSessionShares
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `None`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Shares that can be accessed
anonymously
```

Default Value:

COMCFG DFS$

References:

1. CCE-3592-3

ARCHIVE

1.1.1.2.1.8 Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines what happens when the smart card for a logged-on user is removed from the smart card reader.

Rationale:

Users sometimes forget to lock their workstations when they are away from them, allowing the possibility for malicious users to access their computers. If smart cards are used for authentication, the computer should automatically lock itself when the card is removed to ensure that only the user with the smart card is accessing resources using those credentials..

Impact:

If you select Force Logoff, users will have to re-insert their smart cards and re-enter their PINs when they return to their workstations. Enforcing this setting on computers used by people who must log onto multiple computers in order to perform their duties could be frustrating and lower productivity. For example, if network administrators are limited to a single account but need to log into several computers simultaneously in order to effectively manage the network enforcing this setting will limit them to logging onto one computer at a time. For these reasons it is recommended that this setting only be enforced on workstations used for purposes commonly associated with typical users such as document creation and email.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:scremoveoption
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Smart card removal behavior
```

References:

1. CCE-3674-9

ARCHIVE

1.1.1.2.1.9 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which behaviors are allowed for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI. The possible values for the Network security: Minimum session security for NTLM SSP based (including secure RPC) clients setting are: . Require message confidentiality. This option is only available in Windows XP and Windows Server 2003, the connection will fail if encryption is not negotiated. Encryption converts data into a form that is not readable until decrypted. . Require message integrity. This option is only available in Windows XP and Windows Server 2003, the connection will fail if message integrity is not negotiated. The integrity of a message can be assessed through message signing. Message signing proves that the message has not been tampered with; it attaches a cryptographic signature that identifies the sender and is a numeric representation of the contents of the message. . Require 128-bit encryption. The connection will fail if strong encryption (128-bit) is not negotiated. . Require NTLMv2 session security. The connection will fail if the NTLMv2 protocol is not negotiated. . Not Defined.

Rationale:

You can enable all of the options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. In other words, these options help protect against man-in-the-middle attacks.

ARCHIVE

Impact:

Client applications that are enforcing these settings will be unable to communicate with older servers that do not support them. This setting could impact Windows Clustering when applied to servers running Windows Server 2003, see "How to apply more restrictive security settings on a Windows Server 2003-based cluster server" at http://support.microsoft.com/default.aspx?scid=kb;en-us;891597 and "You receive an "Error 0x8007042b" error message when you add or join a node to a cluster if you use NTLM version 2 in Windows Server 2003" at http://support.microsoft.com/kb/890761/ for more information on possible issues and how to resolve them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0:NTLMMinClientS
ec
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `537395248`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network security: Minimum session security for NTLM
SSP based (including secure RPC) clients
```

Default Value:

No minimum

References:

1. CCE-3614-5

ARCHIVE

1.1.1.2.1.10 Set 'Devices: Prevent users from installing printer drivers' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

It is feasible for a attacker to disguise a Trojan horse program as a printer driver. The program may appear to users as if they must use it to print, but such a program could unleash malicious code on your computer network. To reduce the possibility of such an event, only administrators should be allowed to install printer drivers. However, because laptops are mobile devices, laptop users may occasionally need to install a printer driver from a remote source to continue their work. Therefore, this policy setting should be disabled for laptop users, but always enabled for desktop users.

Rationale:

It may be appropriate in some organizations to allow users to install printer drivers on their own workstations. However, you should allow only Administrators, not users, to do so on servers, because printer driver installation on a server may unintentionally cause the computer to become less stable. A malicious user could install inappropriate printer drivers in a deliberate attempt to damage the computer, or a user might accidentally install malicious software that masquerades as a printer driver.

Impact:

Only users with Administrative, Power User, or Server Operator privileges will be able to install printers on the servers. If this policy setting is enabled but the driver for a network printer already exists on the local computer, users can still add the network printer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Print\Providers\LanMan
Print Services\Servers:AddPrinterDrivers
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Prevent users from installing printer
drivers
```

Default Value:

Enabled

References:

1. CCE-3769-7

ARCHIVE

1.1.1.2.1.11 Set 'Devices: Unsigned driver installation behavior' to 'Warn but allow installation' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines what happens when an attempt is made to install a device driver (by means of Setup API) that has not been approved and signed by the Windows Hardware Quality Lab (WHQL). Depending on how you configure it, this policy setting will prevent the installation of unsigned drivers or warn the administrator that an unsigned driver is about to be installed. The Devices: Unsigned driver installation behavior setting can be used to prevent the installation of drivers that have not been certified to run on Windows Server 2003 with SP1. One potential problem with this configuration is that unattended installation scripts will fail when they attempt to install unsigned drivers.

Rationale:

This policy setting will not prevent a method that is used by some attack tools in which malicious .sys files are copied and registered to start as system services.

Impact:

Users with sufficient privileges to install device drivers will be able to install unsigned device drivers. However, this capability could result in stability problems for servers. Another potential problem with a Warn but allow installation configuration is that unattended installation scripts will fail if they attempt to install unsigned drivers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Driver Signing:Policy
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `01`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Unsigned driver installation behavior
```

References:

1. CCE-3787-9

ARCHIVE

1.1.1.2.1.12 Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting makes the Recovery Console SET command available, which allows you to set the following recovery console environment variables: . AllowWildCards. Enables wildcard support for some commands (such as the DEL command). . AllowAllPaths. Allows access to all files and folders on the computer. . AllowRemovableMedia. Allows files to be copied to removable media, such as a floppy disk. . NoCopyPrompt. Does not prompt when overwriting an existing file.

Rationale:

An attacker who can cause the system to restart into the Recovery Console could steal sensitive data and leave no audit or access trail.

Impact:

Users who have started a server through the Recovery Console and logged in with the built-in Administrator account will not be able to copy files and folders to a floppy disk.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Setup\RecoveryConsole:setcommand
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Recovery console: Allow floppy copy and access to
all drives and all folders
```

References:

1. CCE-3676-4

ARCHIVE

1.1.1.2.1.13 Set 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved (recommended)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (DisableSavePassword) Prevent the dial-up password from being saved (recommended) in the SCE. By default, Windows will offer the option to save passwords for dial-up and VPN connections, which is not desirable on a server. You can add this registry value to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanServer\Parameters\ subkey.

Rationale:

An attacker who steals a mobile userâ€ s computer could automatically connect to the organizationâ€ s network if the Save This Password check box is enabled for the dial-up entry.

Impact:

Users wonâ€ t be able to automatically store their logon credentials for dial-up and VPN connections.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\RasMan\Parameters:Disabl
eSavePassword
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (DisableSavePassword) Prevent the dial-up
password from being saved (recommended)
```

References:

1. CCE-3757-2

ARCHIVE

1.1.1.2.1.14 Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

When enabled, this policy setting restricts anonymous access to only those shares and pipes that are named in the Network access: Named pipes that can be accessed anonymously and Network access: Shares that can be accessed anonymously settings. This policy setting controls null session access to shares on your computers by adding RestrictNullSessAccess with the value 1 in the HKLM\System \CurrentControlSet\Services\LanManServer\Parameters registry key. This registry value toggles null session shares on or off to control whether the server service restricts unauthenticated clients' access to named resources. Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment.

Rationale:

Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment.

Impact:

You can enable this policy setting to restrict null session access for unauthenticated users to all server pipes and shared folders except those that are listed in the NullSessionPipes and NullSessionShares entries. If you choose to enable this setting and are supporting Windows NT 4.0 domains, you should check if any of the named pipes are required to maintain trust relationships between the domains, and then add the pipe to the Network access: Named pipes that can be accessed anonymously setting. Previous to the release of Windows Server 2003 with Service Pack 1 (SP1) some named pipes were allowed anonymous access by default, but with the increased hardening in Windows Server 2003 with SP1 more pipes must be explicitly added if needed.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
restrictnullsessaccess
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Restrict anonymous access to Named
Pipes and Shares
```

Default Value:

Not Defined

References:

1. CCE-8091-1

ARCHIVE

1.1.1.2.1.15 Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '90' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry WarningLevel was added to the template file in the HKEY_LOCAL_MACHINE\ SYSTEM\CurrentControlSet\Services\Eventlog\Security\ registry key. The entry appears as MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning in the SCE. This setting can generate a security audit in the Security event log when the log reaches a user-defined threshold. Note If log settings are configured to Overwrite events as needed or Overwrite events older than x days, this event will not be generated.

Rationale:

If the Security log reaches 90 percent of its capacity and the computer has not been configured to overwrite events as needed, more recent events will not be written to the log. If the log reaches its capacity and the computer has been configured to shut down when it can no longer record events to the Security log, the computer will shut down and will no longer be available to provide network services.

Impact:

This setting will generate an audit event when the Security log reaches the 90 percent-full threshold unless the log is configured to overwrite events as needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security:Warnin
gLevel
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `90`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (WarningLevel) Percentage threshold for the
security event log at which the system will generate a warning
```

References:

1. CCE-8479-8

ARCHIVE

1.1.1.2.1.16 Set 'MSS: (SynAttackProtect) Syn attack protection level (protects against DoS)' to 'Connections time out sooner if a SYN attack is detected' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (SynAttackProtect) Syn attack protection level (protects against DoS) in the SCE. This entry causes TCP to adjust retransmission of SYN-ACKs. When you configure this entry, the overhead of incomplete transmissions in a connect request (SYN) attack is reduced. You can use this entry to configure Windows to send router discovery messages as broadcasts instead of multicasts, as described in RFC 1256. By default, if router discovery is enabled, router discovery solicitations are sent to the all-routers multicast group (224.0.0.2). Not applicable to Windows Vista or Windows Server 2008.

Rationale:

In a SYN flood attack, the attacker sends a continuous stream of SYN packets to a server. The server leaves the half-open connections open until it is overwhelmed and is no longer able to respond to legitimate requests

Impact:

This value adds more delays to connection indications, and TCP connection requests quickly time out when a SYN attack is in progress. If you configure this registry entry, the scalable windows and TCP parameters that are configured on each adapter (including Initial Round Trip Time (RTT) and window size), socket options no longer work. When the computer is attacked, the scalable windows (RFC 1323) and per adapter configured TCP parameters (Initial RTT, window size) options on any socket can no longer be enabled. The reasons these options cannot be enabled is because when protection is functioning, the route cache entry is not queried before the SYN-ACK is sent and the Winsock options are not available at this stage of the connection.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:SynAtta
ckProtect
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (SynAttackProtect) Syn attack protection level
(protects against DoS)
```

References:

1. CCE-3616-0

ARCHIVE

1.1.1.2.1.17 Set 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether digital certificates are processed when software restriction policies are enabled and a user or process attempts to run software with an .exe file name extension. It enables or disables certificate rules (a type of software restriction policies rule). With software restriction policies, you can create a certificate rule that will allow or disallow the execution of Authenticode®-signed software, based on the digital certificate that is associated with the software. For certificate rules to take effect in software restriction policies, you must enable this policy setting.

Rationale:

Software restriction policies help to protect users and computers because they can prevent the execution of unauthorized code, such as viruses and Trojans horses.

Impact:

If you enable certificate rules, software restriction policies check a certificate revocation list (CRL) to ensure that the softwareâ€ s certificate and signature are valid. This checking process may negatively affect performance when signed programs start. To disable this feature you can edit the software restriction policies in the desired GPO. On the Trusted Publishers Properties dialog box, clear the Publisher and Timestamp check boxes.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Safer\CodeIdentifiers:
AuthenticodeEnabled
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System settings: Use Certificate Rules on Windows
Executables for Software Restriction Policies
```

References:

1. CCE-7936-8

ARCHIVE

1.1.1.2.1.18 Set 'MSS: (AutoShareServer) Enable Administrative Shares (recommended except for highly secure environments)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (AutoShareServer) Enable Administrative Shares (not recommended except for highly secure environments) in the SCE. For additional information, see the Microsoft Knowledge Base article How to remove administrative shares in Windows Server 2008 at http://support.microsoft.com/kb/954422/en-us.

Rationale:

Because these built-in administrative shares are well-known and present on most Windows computers, malicious users often target them for brute-force attacks to guess passwords as well as other types of attacks.

Impact:

If you delete these shares you could cause problems for administrators and programs or services that rely on these shares. For example, both Microsoft Systems Management Server (SMS) and Microsoft Operations Manager require administrative shares for correct installation and operation. Also, many third-party network backup applications require administrative shares.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanServer\Parameters:
AutoShareServer
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (AutoShareServer) Enable Administrative Shares
(recommended except for highly secure environments)
```

Default Value:

Enabled

References:

1. CCE-5026-0

ARCHIVE

1.1.1.2.1.19 Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the virtual memory pagefile is cleared when the system is shut down. When this policy setting is enabled, the system pagefile is cleared each time that the system shuts down properly. If you enable this security setting, the hibernation file (Hiberfil.sys) is zeroed out when hibernation is disabled on a portable computer system. It will take longer to shut down and restart the computer, and will be especially noticeable on computers with large paging files.

Rationale:

Important information that is kept in real memory may be written periodically to the page file to help Windows handle multitasking functions. An attacker who has physical access to a server that has been shut down could view the contents of the paging file. The attacker could move the system volume into a different computer and then analyze the contents of the paging file. Although this process is time consuming, it could expose data that is cached from random access memory (RAM) to the paging file. Caution: An attacker who has physical access to the server could bypass this countermeasure by simply unplugging the server from its power source.

Impact:

It will take longer to shut down and restart the server, especially on servers with large paging files. For a server with 2 gigabytes (GB) of RAM and a 2-GB paging file, this policy setting could increase the shutdown process by 20 to 30 minutes, or more. For some organizations, this downtime violates their internal service level agreements. Therefore, use caution before you implement this countermeasure in your environment.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager\Memory
Management:ClearPageFileAtShutdown
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Shutdown: Clear virtual memory pagefile
```

Default Value:

Disabled

References:

1. CCE-3593-1

ARCHIVE

1.1.1.2.1.20 Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a domain member can periodically change its computer account password. If you enable this policy setting, the domain member will be prevented from changing its computer account password. If you disable this policy setting, the domain member can change its computer account password as specified by the Domain Member: Maximum machine account password age setting, which by default is every 30 days. Computers that cannot automatically change their account passwords are potentially vulnerable, because an attacker might be able to determine the password for the system's domain account.

Rationale:

The default configuration computers that belong to a domain is that they are automatically required to change the passwords for their accounts every 30 days. If you disable this policy setting, computers will retain the same passwords as their computer accounts. Computers that are no longer able to automatically change their account password are at risk from an attacker who could determine the password for the computer's domain account.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:disa
blepasswordchange
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Disable machine account password
changes
```

References:

1. CCE-8592-8

ARCHIVE

1.1.1.2.1.21 Set 'Microsoft network server: Amount of idle time required before suspending session' to '15' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to specify the amount of continuous idle time that must pass in an SMB session before the session is suspended because of inactivity. Administrators can use this policy setting to control when a computer suspends an inactive SMB session. If client activity resumes, the session is automatically reestablished. A value of 0 will disconnect an idle session as quickly as possible. The maximum value is 99999, which is 208 days; in effect, this value disables the setting.

Rationale:

Each SMB session consumes server resources, and numerous null sessions will slow the server or possibly cause it to fail. An attacker could repeatedly establish SMB sessions until the server's SMB services become slow or unresponsive.

Impact:

There will be little impact because SMB sessions will be re-established automatically if the client resumes activity.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
autodisconnect
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `15`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network server: Amount of idle time
required before suspending session
```

References:

1. CCE-3761-4

ARCHIVE

1.1.1.2.1.22 Set 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry NoNameReleaseOnDemand was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netbt\ Parameters\ registry key. The entry appears as MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers in the SCE. NetBIOS over TCP/IP is a network protocol that among other things provides a way to easily resolve NetBIOS names that are registered on Windowsbased systems to the IP addresses that are configured on those systems. This setting determines whether the computer releases its NetBIOS name when it receives a name-release request.

Rationale:

The NetBT protocol is designed not to use authentication, and is therefore vulnerable to spoofing. Spoofing makes a transmission appear to come from a user other than the user who performed the action. A malicious user could exploit the unauthenticated nature of the protocol to send a name-conflict datagram to a target computer, which would cause the computer to relinquish its name and not respond to queries. The result of such an attack could be to cause intermittent connectivity issues on the target computer, or even to prevent the use of Network Neighborhood, domain logons, the NET SEND command, or additional NetBIOS name resolution. For more information, see the Microsoft Knowledge Base article "MS00-047: NetBIOS Vulnerability May Cause Duplicate Name on the Network Conflicts" at http://support.microsoft.com/default.aspx?kbid=269239.

Impact:

An attacker could send a request over the network and query a computer to release its NetBIOS name. As with any change that could affect applications, it is recommended that you test this change in a non-production environment before you change the production environment.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netbt\Parameters:NoNameR
eleaseOnDemand
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (NoNameReleaseOnDemand) Allow the computer to
ignore NetBIOS name release requests except from WINS servers
```

Default Value:

Enabled

References:

1. CCE-2817-5

ARCHIVE

1.1.1.2.1.23 Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a CD-ROM is accessible to both local and remote users simultaneously. If you enable this policy setting, only the interactively logged-on user is allowed to access removable CD-ROM media. When this policy setting is enabled and no one is logged on interactively, the CD-ROM is accessible over the network.

Rationale:

A remote user could potentially access a mounted CD that contains sensitive information. This risk is small, because CD drives are not automatically made available as shared drives; administrators must deliberately choose to share the drive. However, administrators may wish to deny network users the ability to view data or run applications from removable media on the server.

Impact:

Users who connect to the server over the network will not be able to use any CD drives that are installed on the server whenever anyone is logged on to the local console of the server. System tools that require access to the CD drive will fail. For example, the Volume Shadow Copy service attempts to access all CD and floppy disk drives that are present on the computer when it initializes, and if the service cannot access one of these drives, it will fail. This condition will cause the Windows Backup tool to fail if volume shadow copies were specified for the backup job. Any non-Microsoft backup products that use volume shadow copies will also fail. This policy setting would not be suitable for a computer that serves as a CD jukebox for network users.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:AllocateCDRoms
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Restrict CD-ROM access to locally logged-
on user only
```

Default Value:

Disabled

References:

1. CCE-3694-7

ARCHIVE

1.1.1.2.1.24 Set 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' to '300000 or 5 minutes (recommended)' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry KeepAliveTime was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\ registry key. The entry appears as MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds (300,000 is recommended) in the SCE. This value controls how often TCP attempts to verify that an idle connection is still intact by sending a keep-alive packet. If the remote computer is still reachable, it acknowledges the keep-alive packet.

Rationale:

An attacker who is able to connect to network applications could establish numerous connections to cause a denial of service (DoS) condition.

Impact:

Keep-alive packets are not sent by default by Windows. However, some applications may configure the TCP stack flag that requests keep-alive packets. For such configurations, you can lower this value from the default setting of two hours to five minutes to disconnect inactive sessions more quickly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:KeepAli
veTime
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `300000`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (KeepAliveTime) How often keep-alive packets
are sent in milliseconds
```

References:

1. CCE-2812-6

ARCHIVE

1.1.1.2.1.25 Set 'Shutdown: Allow system to be shut down without having to log on' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a computer can be shut down when a user is not logged on. If this policy setting is enabled, the shutdown command is available on the Windows logon screen. It is recommended to disable this policy setting to restrict the ability to shut down the computer to users with credentials on the system.

Rationale:

Users who can access the console locally could shut down the computer. Attackers could also walk to the local console and restart the server, which would cause a temporary denial of service (DoS) condition. Attackers could also shut down the server and leave all of its applications and services unavailable.

Impact:

Operators will have to log on to servers to shut them down or restart them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
ShutdownWithoutLogon
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Shutdown: Allow system to be shut down without
having to log on
```

Default Value:

Disabled

ARCHIVE

References:

1. CCE-3448-8

ARCHIVE

1.1.1.2.1.26 Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the account name of the last user to log on to the client computers in your organization will be displayed in each computer's respective Windows logon screen. Enable this policy setting to prevent intruders from collecting account names visually from the screens of desktop or laptop computers in your organization.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Terminal Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

Users will not see their user name or domain name when unlocking their computer, they will have to enter that information.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
DontDisplayLastUserName
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Do not display last user name
```

References:

1. CCE-3527-9

ARCHIVE

1.1.1.2.1.27 Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

LAN Manager (LM) is a family of early Microsoft client/server software that allows users to link personal computers together on a single network. Network capabilities include transparent file and print sharing, user security features, and network administration tools. In Active Directory domains, the Kerberos protocol is the default authentication protocol. However, if the Kerberos protocol is not negotiated for some reason, Active Directory will use LM, NTLM, or NTLMv2. LAN Manager authentication includes the LM, NTLM, and NTLM version 2 (NTLMv2) variants, and is the protocol that is used to authenticate all Windows clients when they perform the following operations: . Join a domain . Authenticate between Active Directory forests . Authenticate to down-level domains . Authenticate to computers that do not run Windows 2000, Windows Server 2003, or Windows XP) . Authenticate to computers that are not in the domain The possible values for the Network security: LAN Manager authentication level setting are: . Send LM & NTLM responses . Send LM & NTLM — use NTLMv2 session security if negotiated . Send NTLM responses only . Send NTLMv2 responses only . Send NTLMv2 responses only\refuse LM . Send NTLMv2 responses only\refuse LM & NTLM . Not Defined The Network security: LAN Manager authentication level setting determines which challenge/response authentication protocol is used for network logons. This choice affects the authentication protocol level that clients use, the session security level that the computers negotiate, and the authentication level that servers accept as follows: . Send LM & NTLM responses. Clients use LM and NTLM authentication and never use NTLMv2 session security. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Send LM & NTLM use NTLMv2 session security if negotiated. Clients use LM and NTLM authentication and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Send NTLM response only. Clients use NTLM authentication only and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Send NTLMv2 response only. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Send NTLMv2 response only\refuse LM. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers refuse LM (accept only NTLM and NTLMv2 authentication). . Send NTLMv2 response only\refuse LM & NTLM. Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it. Domain controllers refuse LM and NTLM (accept only NTLMv2 authentication).

ARCHIVE

These settings correspond to the levels discussed in other Microsoft documents as follows: . Level 0 Send LM and NTLM response; never use NTLMv2 session security. Clients use LM and NTLM authentication, and never use NTLMv2 session security. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Level 1 Use NTLMv2 session security if negotiated. Clients use LM and NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Level 2 Send NTLM response only. Clients use only NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Level 3 Send NTLMv2 response only. Clients use NTLMv2 authentication, and use NTLMv2 session security if the server supports it. Domain controllers accept LM, NTLM, and NTLMv2 authentication. . Level 4 Domain controllers refuse LM responses. Clients use NTLM authentication, and use NTLMv2 session security if the server supports it. Domain controllers refuse LM authentication, that is, they accept NTLM and NTLMv2. . Level 5 Domain controllers refuse LM and NTLM responses (accept only NTLMv2). Clients use NTLMv2 authentication, use and NTLMv2 session security if the server supports it. Domain controllers refuse NTLM and LM authentication (they accept only NTLMv2).

Rationale:

In Windows Vista, this setting is undefined. However, in Windows 2000, Windows Server 2003, and Windows XP clients are configured by default to send LM and NTLM authentication responses (Windows 95-based and Windows 98-based clients only send LM). The default setting on servers allows all clients to authenticate with servers and use their resources. However, this means that LM responses—the weakest form of authentication response—are sent over the network, and it is potentially possible for attackers to sniff that traffic to more easily reproduce the user's password. The Windows 95, Windows 98, and Windows NT operating systems cannot use the Kerberos version 5 protocol for authentication. For this reason, in a Windows Server 2003 domain, these computers authenticate by default with both the LM and NTLM protocols for network authentication. You can enforce a more secure authentication protocol for Windows 95, Windows 98, and Windows NT by using NTLMv2. For the logon process, NTLMv2 uses a secure channel to protect the authentication process. Even if you use NTLMv2 for earlier clients and servers, Windows-based clients and servers that are members of the domain will use the Kerberos authentication protocol to authenticate with Windows Server 2003 domain controllers.

Impact:

Clients that do not support NTLMv2 authentication will not be able to authenticate in the domain and access domain resources by using LM and NTLM. Note: For information about a hotfix to ensure that this setting works in networks that include Windows NT 4.0-based computers along with Windows 2000, Windows XP, and Windows Server 2003-based computers, see article 305379, Authentication Problems in Windows 2000 with NTLM 2 Levels Above 2 in a Windows NT 4.0 Domain, in the Microsoft Knowledge Base (http://go.microsoft.com/fwlink/?LinkId=100907).

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:LmCompatibilityLevel
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `5`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network security: LAN Manager authentication level
```

Default Value:

Send NTLM response only

References:

1. CCE-3703-6

ARCHIVE

1.1.1.2.1.28 Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users or groups might access DCOM application remotely or locally. This setting is used to control the attack surface of the computer for DCOM applications. You can use this policy setting to specify access permissions to all the computers to particular users for DCOM applications in the enterprise. When you specify the users or groups that are to be given permission, the security descriptor field is populated with the Security Descriptor Definition Language representation of those groups and privileges. If the security descriptor is left blank, the policy setting is defined in the template, but it is not enforced. Users and groups can be given explicit Allow or Deny privileges on both local access and remote access. The registry settings that are created as a result of enabling the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting take precedence over (have higher priority) the previous registry settings in this area. RpcSs checks the new registry keys in the Policies section for the computer restrictions, and these registry entries take precedence over the existing registry keys under OLE. This means that previously existing registry settings are no longer effective, and if you make changes to the existing settings, the computer access permissions for any users are not changed. You should take care to correctly configure their list of users and groups. The possible values for this policy setting are: Blank. This represents the local security policy way of deleting the policy enforcement key. This value deletes the policy and then sets it as Not defined state. The Blank value is set by using the ACL editor and emptying the list, and then pressing OK. SDDL. This is the Security Descriptor Definition Language representation of the groups and privileges you specify when you enable this policy. Not Defined. This is the default value. Note If the administrator is denied permission to access DCOM applications due to the changes made to DCOM in SP2, the administrator can use the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting to manage DCOM access to the computer. The administrator can specify which users and groups can access the DCOM application on the computer both locally and remotely by using this setting. This will restore control of the DCOM application to the administrator and users. To do this, open the DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax setting, and click Edit Security. Specify the groups you want to include and the computer access permissions for those groups. This defines the setting and sets the appropriate SDDL value.

ARCHIVE

Rationale:

Many COM applications include some security-specific code (for example, to call CoInitializeSecurity) but use weak settings that often allow unauthenticated access to the process. Administrators cannot override these settings to force stronger security in earlier versions of Windows without modifying the application. An attacker could attempt to exploit weak security in an individual application by attacking it through COM calls. Also, COM infrastructure includes the Remote Procedure Call System Service (RPCSS), a system service that runs during computer startup and always runs after that. This service manages activation of COM objects and the running object table, and provides helper services to DCOM remoting. It exposes RPC interfaces that can be called remotely. Because some COM servers allow unauthenticated remote access, these interfaces can be called by anyone, including unauthenticated users. As a result, RPCSS can be attacked by malicious users who use remote, unauthenticated computers.

Impact:

Windows operating systems implement default COM ACLs when they are installed. Modifying these ACLs from the default may cause some applications or components that communicate by using DCOM to fail. If you implement a COM server and you override the default security settings, confirm that the application-specific call permissions ACL assigns correct permission to appropriate users. If it does not, you need to change your application-specific permission ACL to provide appropriate users with activation rights so that applications and Windows components that use DCOM do not fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\windows
NT\DCOM:MachineAccessRestriction
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\DCOM: Machine Access Restrictions in Security
Descriptor Definition Language (SDDL) syntax
```

Default Value:

Not defined

ARCHIVE

References:

1. CCE-7773-5

ARCHIVE

1.1.1.2.1.29 Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry Hidden was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Lanmanserver\Parameters\ registry key. The entry appears as MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments) in the SCE. You can configure a computer so that it does not send announcements to browsers on the domain. If you do so, you hide the computer from the Browse list, which means that the computer will stop announcing itself to other computers on the same network. An attacker who knows the name of a computer can more easily gather additional information about the system. You can enable this setting to remove one method that an attacker might use to gather information about computers on the network. Also, this setting can help reduce network traffic when enabled. However, the security benefits of this setting are small because attackers can use alternative methods to identify and locate potential targets. For this reason, Microsoft recommends to configure this setting to Enabled in high security environments, and to configure it to Not Defined in enterprise environments. For additional information, see the Knowledge Base article 321710, HOW TO: Hide a Windows 2000-Based Computer from the Browser List.

Rationale:

An attacker who knows the name of a computer can more easily gather additional information about the computer. If you enable this entry, you remove one method that an attacker might use to gather information about computers on the network. Also, if you enable this entry you can help reduce network traffic. However, the vulnerability is small because attackers can use alternative methods to identify and locate potential targets.

Impact:

The computer will no longer appear on the Browser list or in Network Neighborhood on other computers on the same network.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Lanmanserver\Parameters:
Hidden
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (Hidden) Hide Computer From the Browse List
(not recommended except for highly secure environments)
```

Default Value:

Disabled

References:

1. CCE-8380-8

ARCHIVE

1.1.1.2.1.30 Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry AutoAdminLogon was added to the template file in the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\ registry key. The entry appears as MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended) in the Security Configuration Editor. This setting is separate from the Welcome screen feature in Windows XP and Windows Vista; if that feature is disabled, this setting is not disabled. If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks to which the computer is connected. Also, if you enable automatic logon, the password is stored in the registry in plaintext, and the specific registry key that stores this value is remotely readable by the Authenticated Users group. For additional information, see the Knowledge Base article 315231, How to turn on automatic logon in Windows XP.

Rationale:

If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks that the computer is connected to. Also, if you enable automatic logon, the password is stored in the registry in plaintext. The specific registry key that stores this setting is remotely readable by the Authenticated Users group. As a result, this entry is appropriate only if the computer is physically secured and if you ensure that untrusted users cannot remotely see the registry.

Impact:

None. By default this entry is not enabled.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:AutoAdminLogon
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (AutoAdminLogon) Enable Automatic Logon (not
recommended)
```

References:

1. CCE-3690-5

ARCHIVE

1.1.1.2.1.31 Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which behaviors are allowed for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI. The possible values for the Network security: Minimum session security for NTLM SSP based (including secure RPC) servers setting are: . Require message confidentiality. This option is only available in Windows XP and Windows Server 2003, the connection will fail if encryption is not negotiated. Encryption converts data into a form that is not readable until decrypted. . Require message integrity. This option is only available in Windows XP and Windows Server 2003, the connection will fail if message integrity is not negotiated. The integrity of a message can be assessed through message signing. Message signing proves that the message has not been tampered with; it attaches a cryptographic signature that identifies the sender and is a numeric representation of the contents of the message. . Require 128-bit encryption. The connection will fail if strong encryption (128-bit) is not negotiated. . Require NTLMv2 session security. The connection will fail if the NTLMv2 protocol is not negotiated. . Not Defined.

Rationale:

You can enable all of the options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. That is, these options help protect against man-in-the-middle attacks.

ARCHIVE

Impact:

Server applications that are enforcing these settings will be unable to communicate with older servers that do not support them. This setting could impact Windows Clustering when applied to servers running Windows Server 2003, see "How to apply more restrictive security settings on a Windows Server 2003-based cluster server" at http://support.microsoft.com/default.aspx?scid=kb;en-us;891597 and "You receive an "Error 0x8007042b" error message when you add or join a node to a cluster if you use NTLM version 2 in Windows Server 2003" at http://support.microsoft.com/kb/890761/ for more information on possible issues and how to resolve them.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0:NTLMMinServerS
ec
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `537395248`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network security: Minimum session security for NTLM
SSP based (including secure RPC) servers
```

Default Value:

No minimum

References:

1. CCE-3759-8

ARCHIVE

1.1.1.2.1.32 Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether case insensitivity is enforced for all subsystems. The Microsoft Win32® subsystem is case insensitive. However, the kernel supports case sensitivity for other subsystems, such as the Portable Operating System Interface for UNIX (POSIX). Because Windows is case insensitive (but the POSIX subsystem will support case sensitivity), failure to enforce this policy setting makes it possible for a user of the POSIX subsystem to create a file with the same name as another file by using mixed case to label it. Such a situation can block access to these files by another user who uses typical Win32 tools, because only one of the files will be available.

Rationale:

Because Windows is case-insensitive but the POSIX subsystem will support case sensitivity, failure to enable this policy setting would make it possible for a user of that subsystem to create a file with the same name as another file but with a different mix of upper and lower case letters. Such a situation could potentially confuse users when they try to access such files from normal Win32 tools because only one of the files will be available.

Impact:

All subsystems will be forced to observe case insensitivity. This configuration may confuse users who are familiar with any UNIX-based operating systems that is case-sensitive.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session
Manager\Kernel:ObCaseInsensitive
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System objects: Require case insensitivity for non-
Windows subsystems
```

References:

1. CCE-3714-3

ARCHIVE

1.1.1.2.1.33 Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users or groups might launch or activate DCOM applications remotely or locally. This setting is used to control the attack surface of the computer for DCOM applications. You can use this Group Policy setting to grant access to all the computers to particular users for DCOM application in the enterprise. When you define this setting, and specify the users or groups that are to be given permission, the security descriptor field is populated with the Security Descriptor Definition Language representation of those groups and privileges. If the security descriptor is left blank, the policy setting is defined in the template, but it is not enforced. Users and groups can be given explicit Allow or Deny privileges on local launch, remote launch, local activation, and remote activation. The registry settings that are created as a result of this policy take precedence over the previous registry settings in this area. RpcSs checks the new registry keys in the Policies section for the computer restrictions; these entries take precedence over the existing registry keys under OLE. The possible values for this Group Policy setting are: Blank. This represents the local security policy way of deleting the policy enforcement key. This value deletes the policy and then sets it to Not defined state. The Blank value is set by using the ACL editor and emptying the list, and then pressing OK. SDDL. This is the Security Descriptor Definition Language representation of the groups and privileges you specify when you enable this policy. Not Defined. This is the default value. Note If the administrator is denied access to activate and launch DCOM applications due to the changes made to DCOM in SP2, this policy setting can be used for controlling the DCOM activation and launch to the computer. The administrator can specify which users and groups can launch and activate DCOM applications on the computer both locally and remotely by using the DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax policy setting. This restores control of the DCOM application to the administrator and specified users. To do this, open the DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax setting, and click Edit Security. Specify the groups you want to include and the computer launch permissions for those groups. This defines the setting and sets the appropriate SDDL value.

ARCHIVE

Rationale:

Many COM applications include some security-specific code (for example, to call CoInitializeSecurity) but use weak settings that often allow unauthenticated access to the process. Administrators cannot override these settings to force stronger security in earlier versions of Windows without modifying the application. An attacker could attempt to exploit weak security in an individual application by attacking it through COM calls. Also, COM infrastructure includes the RPCSS, a system service that runs during computer startup and always runs after that. This service manages activation of COM objects and the running object table and provides helper services to DCOM remoting. It exposes RPC interfaces that can be called remotely. Because some COM servers allow unauthenticated remote component activation

Impact:

Windows operating systems implement default COM ACLs when they are installed. Modifying these ACLs from the default may cause some applications to components that communicate by using DCOM to fail. If you implement a COM server and you override the default security settings, confirm that the application-specific launch permissions ACL assigns activation permission to appropriate users. If it does not, you need to change your application-specific launch permission ACL to provide appropriate users with activation rights so that applications and Windows components that use DCOM do not fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\windows
NT\DCOM:MachineLaunchRestriction
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\DCOM: Machine Launch Restrictions in Security
Descriptor Definition Language (SDDL) syntax
```

Default Value:

Not defined

References:

1. CCE-8561-3

ARCHIVE

1.1.1.2.1.34 Set 'System settings: Optional subsystems' to '' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which subsystems are used to support applications in your environment. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

The POSIX subsystem is an Institute of Electrical and Electronic Engineers (IEEE) standard that defines a set of operating system services. The POSIX subsystem is required if the server supports applications that use that subsystem. The POSIX subsystem introduces a security risk that relates to processes that can potentially persist across logons. If a user starts a process and then logs out, there is a potential that the next user who logs on to the computer could access the previous user's process. This potential is dangerous, because anything the second user does with that process will be performed with the privileges of the first user.

Impact:

Applications that rely on the POSIX subsystem will no longer operate. For example, Microsoft Services for Unix (SFU) installs an updated version of the POSIX subsystem that is required, so you would need to reconfigure this setting in a Group Policy for any servers that use SFU.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session
Manager\SubSystems:optional
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to ``.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System settings: Optional subsystems
```

References:

1. CCE-17448-2

ARCHIVE

1.1.1.2.1.35 Set 'Devices: Allowed to format and eject removable media' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines who is allowed to format and eject removable media. You can use this policy setting to prevent unauthorized users from removing data on one computer to access it on another computer on which they have local administrator privileges.

Rationale:

Users may be able to move data on removable disks to a different computer where they have administrative privileges. The user could then take ownership of any file, grant themselves full control, and view or modify any file. The fact that most removable storage devices will eject media by pressing a mechanical button diminishes the advantage of this policy setting.

Impact:

Only Administrators will be able to format and eject removable media. If users are in the habit of using removable media for file transfers and storage, they will need to be informed of the change in policy.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:AllocateDASD
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Allowed to format and eject removable
media
```

Default Value:

Administrators

References:

1. CCE-3586-5

ARCHIVE

1.1.1.2.1.36 Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether packet signing is required by the SMB client component. If you enable this policy setting, the Microsoft network client computer cannot communicate with a Microsoft network server unless that server agrees to sign SMB packets. In mixed environments with legacy client computers, set this option to Disabled because these computers will not be able to authenticate or gain access to domain controllers. However, you can use this policy setting in Windows 2000 or later environments. Note When Windows Vistabased computers have this policy setting enabled and they connect to file or print shares on remote servers, it is important that the setting is synchronized with its companion setting, Microsoft network server: Digitally sign communications (always), on those servers. For more information about these settings, see the Microsoft network client and server: Digitally sign communications (four related settings) section in Chapter 5 of the Threats and Countermeasures guide.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then forward themso that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by the Windows operating systems. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

ARCHIVE

Impact:

The Windows 2000 and later implementations of the SMB file and print sharing protocol support mutual authentication, which protect against session hijacking attacks and support message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: http://support.microsoft.com/default.aspx/kb/950876/.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parame
ters:RequireSecuritySignature
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network client: Digitally sign
communications (always)
```

References:

1. CCE-3652-5

ARCHIVE

1.1.1.2.1.37 Set 'Interactive logon: Prompt user to change password before expiration' to '14' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines how far in advance users are warned that their password will expire. It is recommended that you configure this policy setting to 14 days to sufficiently warn users when their passwords will expire.

Rationale:

It is recommended that user passwords be configured to expire periodically. Users will need to be warned that their passwords are going to expire, or they may inadvertently be locked out of the computer when their passwords expire. This condition could lead to confusion for users who access the network locally, or make it impossible for users to access your organizationâ€ s network through dial-up or virtual private network (VPN) connections.

Impact:

Users will see a dialog box prompt to change their password each time that they log on to the domain when their password is configured to expire in 14 or fewer days.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:passwordexpirywarning
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `14`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Prompt user to change password
before expiration
```

References:

1. CCE-3804-2

ARCHIVE

1.1.1.2.1.38 Set 'Domain member: Maximum machine account password age' to '30' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the maximum allowable age for a computer account password. By default, domain members automatically change their domain passwords every 30 days. If you increase this interval significantly or set it to 0 so that the computers no longer change their passwords, an attacker would have more time to undertake a brute force attack against one of the computer accounts.

Rationale:

In Active Directorybased domains, each computer has an account and password just like every user. By default, the domain-joined computers automatically change their domain password every 30 days. If you increase this interval significantly, or set it to 0 so that the computers no longer change their passwords, an attacker will have more time to undertake a brute force attack to guess the password of one or more computer accounts.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `30`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Maximum machine account password age
```

References:

1. CCE-2984-3

ARCHIVE

1.1.1.2.1.39 Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry SafeDllSearchMode was added to the template file in the HKEY_LOCAL_MACHINE\ SYSTEM\CurrentControlSet\Control\Session Manager\ registry key. The entry appears as MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended) in the SCE. The DLL search order can be configured to search for DLLs that are requested by running processes in one of two ways: . Search folders specified in the system path first, and then search the current working folder. . Search current working folder first, and then search the folders specified in the system path. When enabled, the registry value is set to 1. With a setting of 1, the system first searches the folders that are specified in the system path and then searches the current working folder. When disabled the registry value is set to 0 and the system first searches the current working folder and then searches the folders that are specified in the system path.

Rationale:

If a user unknowingly executes hostile code that was packaged with additional files that include modified versions of system DLLs, the hostile code could load its own versions of those DLLs and potentially increase the type and degree of damage the code can render.

Impact:

Applications will be forced to search for DLLs in the system path first. For applications that require unique versions of these DLLs that are included with the application, this entry could cause performance or stability problems.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session
Manager:SafeDllSearchMode
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (SafeDllSearchMode) Enable Safe DLL search
mode (recommended)
```

Default Value:

Enabled

References:

1. CCE-3778-8

ARCHIVE

1.1.1.2.1.40 Configure 'Interactive logon: Display user information when the session is locked' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the account name of the last user to log on to the client computers in your organization can display in each computer's respective Windows logon screen. If you enable this policy setting, intruders cannot collect account names visually from the screens of desktop or laptop computers in your organization.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Terminal Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

Users will always have to type their user names when they log on to the servers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
DontDisplayLockedUserId
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Display user information when
the session is locked
```

Default Value:

Not defined

ARCHIVE

References:

1. CCE-17461-5

ARCHIVE

1.1.1.2.1.41 Set 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' to '3' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry TCPMaxDataRetransmissions was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip \Parameters\ registry key. The entry appears as MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default) in the SCE. This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection.

Rationale:

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:TcpMaxD
ataRetransmissions
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `3`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (TcpMaxDataRetransmissions) How many times
unacknowledged data is retransmitted (3 recommended, 5 is default)
```

References:

1. CCE-7613-3

ARCHIVE

1.1.1.2.1.42 Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a domain member should attempt to negotiate whether all secure channel traffic that it initiates must be digitally signed. Digital signatures protect the traffic from being modified by anyone who captures the data as it traverses the network. Microsoft recommends to configure the Domain member: Digitally sign secure channel data (when possible) setting to Enabled.

Rationale:

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticatedâ€and sensitive information such as passwords are encryptedâ€but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

ARCHIVE

Impact:

Digital encryption and signing of the â€œsecure channelâ€• is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 with Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following: â€¢ The ability to create or delete trust relationships with clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled. â€¢ Logons from clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled. â€¢ The ability to authenticate other domainsâ€ users from a domain controller running a version of Windows earlier than Windows NT 4.0 with SP6a in a trusted domain will be disabled. You can enable this policy setting after you eliminate all Windows 9x clients from the domain and upgrade all Windows NT 4.0 servers and domain controllers from trusted/trusting domains to Windows NT 4.0 with SP6a. You can enable the other two policy settings, Domain member: Digitally encrypt secure channel data (when possible) and Domain member: Digitally encrypt sign channel data (when possible), on all computers in the domain that support them and clients running versions of Windows earlier than Windows NT 4.0 with SP6a and applications that run on these versions of Windows will not be affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:sign
securechannel
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Digitally sign secure channel data
(when possible)
```

References:

1. CCE-3514-7

ARCHIVE

1.1.1.2.1.43 Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a domain member should attempt to negotiate encryption for all secure channel traffic that it initiates. If you enable this policy setting, the domain member will request encryption of all secure channel traffic. If you disable this policy setting, the domain member will be prevented from negotiating secure channel encryption. Microsoft recommends to configure the Domain member: Digitally encrypt secure channel data (when possible) setting to Enabled.

Rationale:

When a computer running Windows NT, Windows 2000, or later versions of Windows joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticated—and sensitive information such as passwords are encrypted—but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

Impact:

Digital encryption and signing of the â€œsecure channelâ€• is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following:

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:seal
securechannel
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Digitally encrypt secure channel
data (when possible)
```

References:

1. CCE-3796-0

ARCHIVE

1.1.1.2.1.44 Configure 'Domain controller: LDAP server signing requirements' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting determines whether the Lightweight Directory Access Protocol (LDAP) server requires LDAP clients to negotiate data signing.

Rationale:

Unsigned network traffic is susceptible to man-in-the-middle attacks. In such attacks, an intruder captures packets between the server and the client, modifies them, and then forwards them to the client. Where LDAP servers are concerned, an attacker could cause a client to make decisions that are based on false records from the LDAP directory. To lower the risk of such an intrusion in an organizationâ€ s network, you can implement strong physical security measures to protect the network infrastructure. Also, you could implement Internet Protocol security (IPsec) authentication header mode (AH), which performs mutual authentication and packet integrity for IP traffic to make all types of man-in-the-middle attacks extremely difficult.

Impact:

Clients that do not support LDAP signing will be unable to run LDAP queries against the domain controllers. All Windows 2000â€based computers in your organization that are managed from Windows Server 2003â€based or Windows XPâ€based computers and that use Windows NTÂ® Challenge/Response (NTLM) authentication must have Windows 2000 Service Pack 3 (SP3) installed. Alternatively, these clients must have a registry change. For information about this registry change, see article 325465, Windows 2000 domain controllers require SP3 or later when using Windows Server 2003 administration tools, in the Microsoft Knowledge Base (http://go.microsoft.com/fwlink/?LinkId=100900). Also, some non-Microsoft operating systems do not support LDAP signing. If you enable this policy setting, client computers that use those operating systems may be unable to access domain resources.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\NTDS\Parameters:ldapserv
erintegrity
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain controller: LDAP server signing requirements
```

References:

1. CCE-3801-8

ARCHIVE

1.1.1.2.1.45 Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Disable this policy setting to prevent the SMB redirector from sending plaintext passwords during authentication to third-party SMB servers that do not support password encryption. It is recommended that you disable this policy setting unless there is a strong business case to enable it. If this policy setting is enabled, unencrypted passwords will be allowed across the network.

Rationale:

If you enable this policy setting, the computer can transmit passwords in plaintext across the network to other computers that offer SMB services. These other computers may not use any of the SMB security mechanisms that are included with recent versions Windows.

Impact:

Some very old applications and operating systems such as MS-DOS, Windows for Workgroups 3.11, and Windows 95a may not be able to communicate with the servers in your organization by means of the SMB protocol.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parame
ters:EnablePlainTextPassword
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network client: Send unencrypted password
to third-party SMB servers
```

References:

1. CCE-2870-4

ARCHIVE

1.1.1.2.1.46 Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether users must press CTRL+ALT+DEL before they log on. If you enable this policy setting, users can log on without this key combination. If you disable this policy setting, users must press CTRL+ALT+DEL before they log on to Windows unless they use a smart card for Windows logon. A smart card is a tamper-proof device that stores security information.

Rationale:

Microsoft developed this feature to make it easier for users with certain types of physical impairments to log on to computers that run Windows. If users are not required to press CTRL+ALT+DEL, they are susceptible to attacks thattempt to intercept their passwords. If CTRL+ALT+DEL is required before logon, user passwords are communicated by means of a trusted path. An attacker could install a Trojan horse program that looks like the standard Windows logon dialog box and capture the user's password. The attacker would then be able to log on to the compromised account with whatever level of privilege that user has.

Impact:

Unless they use a smart card to log on, users will have to simultaneously press three keys before the logon dialog box will display.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
DisableCAD
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Do not require CTRL+ALT+DEL
```

Default Value:

Disabled

References:

1. CCE-3060-1

ARCHIVE

1.1.1.2.1.47 Configure 'Interactive logon: Message title for users attempting to log on' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you use this setting, if appropriate to your environment and your organization's business requirements, to help protect end user computers. This policy setting allows text to be specified in the title bar of the window that users see when they log on to the system.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process.

Impact:

Users will see a message in a dialog box before they can log on to the server console. Note that Windows XP and later versions of Windows support logon banners that can exceed 512 characters in length and that can also contain carriage-return line-feed sequences. However, Windows 2000-based clients cannot interpret and display these messages. You must use a Windows 2000-based computer to create a logon message policy that applies to Windows 2000-based computers. If you inadvertently create a logon message policy on a Windows Vista-based or Windows XP Professional-based computer and you discover that it does not display properly on Windows 2000-based computers, do the following: Change the setting to Not Defined, and then change the setting to the desired value by using a Windows 2000-based computer. Important: If you do not reconfigure this setting to Not Defined before reconfiguring the setting using a Windows 2000-based computer, the changes will not take effect properly.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
LegalNoticeCaption
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Message title for users
attempting to log on
```

References:

1. CCE-2790-4

ARCHIVE

1.1.1.2.1.48 Configure 'Interactive logon: Message text for users attempting to log on' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you use this setting, if appropriate to your environment and your organization's business requirements, to help protect end user computers. This policy setting specifies a text message that displays to users when they log on.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process. This text is often used for legal reasons—for example, to warn users about the ramifications of misusing company information or to warn them that their actions may be audited. Note: Any warning that you display should first be approved by your organization's legal and human resources representatives.

Impact:

Users will see a message in a dialog box before they can log on to the server console. Note that Windows XP and later versions of Windows support logon banners that can exceed 512 characters in length and that can also contain carriage-return line-feed sequences. However, Windows 2000-based clients cannot interpret and display these messages. You must use a Windows 2000-based computer to create a logon message policy that applies to Windows 2000-based computers. If you inadvertently create a logon message policy on a Windows Vista-based or Windows XP Professional-based computer and you discover that it does not display properly on Windows 2000-based computers, do the following: Change the setting to Not Defined, and then change the setting to the desired value by using a Windows 2000-based computer. Important: If you do not reconfigure this setting to Not Defined before reconfiguring the setting using a Windows 2000-based computer, the changes will not take effect properly.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
LegalNoticeText
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Message text for users
attempting to log on
```

References:

1. CCE-3672-3

ARCHIVE

1.1.1.2.1.49 Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry ScreenSaverGracePeriod was added to the template file in the HKEY_LOCAL_MACHINE\SYSTEM\Software\Microsoft\ Windows NT\CurrentVersion\Winlogon\ registry key. The entry appears as MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended) in the SCE. Windows includes a grace period between when the screen saver is launched and when the console is actually locked automatically when screen saver locking is enabled. This setting is configured to 0 seconds for both of the environments that are discussed in this guide.

Rationale:

The default grace period that is allowed for user movement before the screen saver lock takes effect is five seconds. If you leave the default grace period configuration, your computer is vulnerable to a potential attack from someone who could approach the console and attempt to log on to the computer before the lock takes effect. An entry to the registry can be made to adjust the length of the grace period.

Impact:

Users will have to enter their passwords to resume their console sessions as soon as the screen saver activates.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:ScreenSaverGracePeriod
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (ScreenSaverGracePeriod) The time in seconds
before the screen saver grace period expires (0 recommended)
```

References:

1. CCE-3764-8

ARCHIVE

1.1.1.2.1.50 Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the SMB client will attempt to negotiate SMB packet signing. The implementation of digital signing in Windowsbased networks helps to prevent sessions from being hijacked. If you enable this policy setting, the Microsoft network client will use signing only if the server with which it communicates accepts digitally signed communication. Microsoft recommends to enable The Microsoft network client: Digitally sign communications (if server agrees) setting. Note Enabling this policy setting on SMB clients on your network makes them fully effective for packet signing with all clients and servers in your environment.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then them so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

ARCHIVE

Impact:

The Windows 2000 and later implementations of the SMB file and print sharing protocol support mutual authentication, which protect against session hijacking attacks and support message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: http://support.microsoft.com/default.aspx/kb/950876/.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parame
ters:EnableSecuritySignature
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network client: Digitally sign
communications (if server agrees)
```

References:

1. CCE-8534-0

ARCHIVE

1.1.1.2.1.51 Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether all secure channel traffic that is initiated by the domain member must be signed or encrypted. If a system is set to always encrypt or sign secure channel data, it cannot establish a secure channel with a domain controller that is not capable of signing or encrypting all secure channel traffic, because all secure channel data must be signed and encrypted. Microsoft recommends to configure the Domain member: Digitally encrypt or sign secure channel data (always) setting to Enabled.

Rationale:

When a computer joins a domain, a computer account is created. After it joins the domain, the computer uses the password for that account to create a secure channel with the domain controller for its domain every time that it restarts. Requests that are sent on the secure channel are authenticatedâ€and sensitive information such as passwords are encryptedâ€but the channel is not integrity-checked, and not all information is encrypted. If a computer is configured to always encrypt or sign secure channel data but the domain controller cannot sign or encrypt any portion of the secure channel data, the computer and domain controller cannot establish a secure channel. If the computer is configured to encrypt or sign secure channel data when possible, a secure channel can be established, but the level of encryption and signing is negotiated.

ARCHIVE

Impact:

Digital encryption and signing of the secure channel is a good idea where it is supported. The secure channel protects domain credentials as they are sent to the domain controller. However, only Windows NT 4.0 with Service Pack 6a (SP6a) and subsequent versions of the Windows operating system support digital encryption and signing of the secure channel. Windows 98 Second Edition clients do not support it unless they have the Dsclient installed. Therefore, you cannot enable the Domain member: Digitally encrypt or sign secure channel data (always) setting on domain controllers that support Windows 98 clients as members of the domain. Potential impacts can include the following: . The ability to create or delete trust relationships with clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled. . Logons from clients running versions of Windows earlier than Windows NT 4.0 with SP6a will be disabled. . The ability to authenticate other domains' users from a domain controller running a version of Windows earlier than Windows NT 4.0 with SP6a in a trusted domain will be disabled. You can enable this policy setting after you eliminate all Windows 9x clients from the domain and upgrade all Windows NT 4.0 servers and domain controllers from trusted/trusting domains to Windows NT 4.0 with SP6a. You can enable the other two policy settings, Domain member: Digitally encrypt secure channel data (when possible) and Domain member: Digitally encrypt sign channel data (when possible), on all computers in the domain that support them and clients running versions of Windows earlier than Windows NT 4.0 with SP6a and applications that run on these versions of Windows will not be affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:requ
iresignorseal
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Digitally encrypt or sign secure
channel data (always)
```

References:

1. CCE-3731-7

ARCHIVE

1.1.1.2.1.52 Set 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the strength of the default discretionary access control list (DACL) for objects. The setting helps secure objects that can be located and shared among processes and its default configuration strengthens the DACL, because it allows users who are not administrators to read shared objects but does not allow them to modify any that they did not create.

Rationale:

This setting determines the strength of the default DACL for objects. Windows Server 2003 maintains a global list of shared computer resources so that objects can be located and shared among processes. Each type of object is created with a default DACL that specifies who can access the objects and with what permissions. If you enable this setting, the default DACL is strengthened because non-administrator users are allowed to read shared objects but not modify shared objects that they did not create.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session
Manager:ProtectionMode
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System objects: Strengthen default permissions of
internal system objects (e.g. Symbolic Links)
```

References:

1. CCE-2963-7

ARCHIVE

1.1.1.2.1.53 Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the LAN Manager (LM) hash value for the new password is stored when the password is changed. The LM hash is relatively weak and prone to attack compared to the cryptographically stronger Microsoft Windows NT® hash. Note Older operating systems and some third-party applications may fail when this policy setting is enabled. Also you will need to change the password on all accounts after you enable this setting.

Rationale:

The SAM file can be targeted by attackers who seek access to username and password hashes. Such attacks use special tools to crack passwords, which can then be used to impersonate users and gain access to resources on your network. These types of attacks will not be prevented if you enable this policy setting, but it will be much more difficult for these types of attacks to succeed.

Impact:

Earlier operating systems such as Windows 95, Windows 98, and Windows ME as well as some third-party applications will fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:NoLMHash
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network security: Do not store LAN Manager hash
value on next password change
```

Default Value:

Disabled

References:

1. CCE-3632-7

ARCHIVE

1.1.1.2.1.54 Set 'Network access: Remotely accessible registry paths and sub-paths' to 'System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Sof (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which registry paths and sub-paths will be accessible when an application or process references the WinReg key to determine access permissions. Note: In Windows XP this setting is called Network access: Remotely accessible registry paths, the setting with that same name in Windows Vista, Windows Server 2008, and Windows Server 2003 does not exist in Windows XP. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

The registry contains sensitive computer configuration information that could be used by an attacker to facilitate unauthorized activities. The fact that the default ACLs assigned throughout the registry are fairly restrictive and help to protect the registry from access by unauthorized users reduces the risk of such an attack.

Impact:

Remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server require remote access to the registry to properly monitor and manage those computers. If you remove the default registry paths from the list of accessible ones, such remote management tools could fail. Note: If you want to allow remote access, you must also enable the Remote Registry service.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\
AllowedPaths:Machine
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Software\Microsoft\Windows NT\CurrentVersion\Windows System\CurrentControlSet\Control\ContentIndex System\CurrentControlSet\Control\Terminal Server System\CurrentControlSet\Control\Terminal Server\UserConfig System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration Software\Microsoft\Windows NT\CurrentVersion\Perflib System\CurrentControlSet\Services\SysmonLog.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Remotely accessible registry paths
and sub-paths
```

Default Value:

System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog, Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Software\Microsoft\Windows NT\CurrentVersion\Windows System\CurrentControlSet\Control\ContentIndex System\CurrentControlSet\Control\Terminal Server System\CurrentControlSet\Control\Terminal Server\UserConfig System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration Software\Microsoft\Windows NT\CurrentVersion\Perflib System\CurrentControlSet\Services\SysmonLog

References:

1. CCE-8325-3

ARCHIVE

1.1.1.2.1.55 Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether users' private keys (such as their S-MIME keys) require a password to be used. If you configure this policy setting so that users must provide a password—distinct from their domain password—every time that they use a key, then it will be more difficult for an attacker to access locally stored keys, even an attacker who discovers logon passwords.

Rationale:

If a users account is compromised or their computer is inadvertently left unsecured the malicious user can use the keys stored for the user to access protected resources. You can configure this policy setting so that users must provide a password that is distinct from their domain password every time they use a key. This configuration makes it more difficult for an attacker to access locally stored user keys, even if the attacker takes control of the userâ€ s computer and determines their logon password.

Impact:

Users will have to enter their password every time they access a key that is stored on their computer. For example, if users use an S-MIME certificate to digitally sign their e-mail they will be forced to enter the password for that certificate every time they send a signed e-mail message. For some organizations the overhead that is involved using this configuration may be too high. For end user computers that are used to access sensitive data this setting could be set to "User is prompted when the key is first used," but Microsoft does not recommend enforcing this setting on servers due to the significant impact on manageability. For example, if this setting is configured to "User is prompted when the key is first used" you may not be able to configure Remote Desktop Services to use SSL certificates. More information is available in the Windows PKI blog: http://blogs.technet.com/b/pki/archive/2009/06/17/what-is-a-strong-key-protection-in-windows.aspx.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Cryptography:ForceKeyProtectio
n
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System cryptography: Force strong key protection
for user keys stored on the computer
```

References:

1. CCE-8462-4

ARCHIVE

1.1.1.2.1.56 Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry DisableIPSourceRouting was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\ registry key. The entry appears as MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing) in the SCE. IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should take through the network. It is recommended to configure this setting to Not Defined for enterprise environments and to Highest Protection for high security environments to completely disable source routing.

Rationale:

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

Impact:

If you configure this value to 2, all incoming source routed packets will be dropped.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:Disable
IPSourceRouting
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `2`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (DisableIPSourceRouting) IP source routing
protection level (protects against packet spoofing)
```

References:

1. CCE-3227-6

ARCHIVE

1.1.1.2.1.57 Set 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry PerformRouterDiscovery was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\ registry key. The entry appears as MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS) in the SCE. This setting is used to enable or disable the Internet Router Discovery Protocol (IRDP), which allows the system to detect and configure default gateway addresses automatically as described in RFC 1256 on a per-interface basis.

Rationale:

An attacker who has gained control of a computer on the same network segment could configure a computer on the network to impersonate a router. Other computers with IRDP enabled would then attempt to route their traffic through the already compromised computer.

Impact:

If you disable this entry, Windows cannot automatically detect and configure default gateway addresses on the computer.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:Perform
RouterDiscovery
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (PerformRouterDiscovery) Allow IRDP to detect
and configure Default Gateway addresses (could lead to DoS)
```

References:

1. CCE-3509-7

ARCHIVE

1.1.1.2.1.58 Set 'MSS: (TcpMaxConnectResponseRetransmissions) SYN-ACK retransmissions when a connection request is not acknowledged' to '3 & 6 seconds, half-open connections dropped after 21 seconds' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (TcpMaxConnectResponseRetransmissions) SYN-ACK retransmissions when a connection request is not acknowledged in the SCE. This entry determines the number of times that TCP retransmits a SYN before it aborts the attempt. The retransmission time-out is doubled with each successive retransmission in a given connect attempt. The initial time-out value is three seconds. Not applicable to Windows Vista or Windows Server 2008.

Rationale:

In a SYN flood attack, the attacker sends a continuous stream of SYN packets to a server. The server leaves the half-open connections open until it is overwhelmed and no longer is able to respond to legitimate requests.

Impact:

If you configure this value to greater than or equal to 2, the stack will employ SYN-ATTACK protection internally. If you configure this entry to less than 2, the stack cannot read the registry values at all for SYN-ATTACK protection. This entry shortens the default amount of time that is needed to clean up a half-open TCP connection. A site that is under heavy attack might set the value as low as 1. A value of 0 is also valid. However, if this parameter is set to 0, SYN-ACKs will not be retransmitted at all and will time out in 3 seconds. If the value is this low, legitimate connection attempts from distant clients may fail.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:TcpMaxC
onnectResponseRetransmissions
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `2`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (TcpMaxConnectResponseRetransmissions) SYN-ACK
retransmissions when a connection request is not acknowledged
```

References:

1. CCE-8472-3

ARCHIVE

1.1.1.2.1.59 Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether to disconnect users who are connected to the local computer outside their user account's valid logon hours. It affects the SMB component. If you enable this policy setting, client sessions with the SMB service will be forcibly disconnected when the client's logon hours expire. If you disable this policy setting, established client sessions will be maintained after the client's logon hours expire. If you enable this policy setting you should also enable Network security: Force logoff when logon hours expire. If your organization configures logon hours for users, it makes sense to enable this policy setting.

Rationale:

If your organization configures logon hours for users, then it makes sense to enable this policy setting. Otherwise, users who should not have access to network resources outside of their logon hours may actually be able to continue to use those resources with sessions that were established during allowed hours.

Impact:

If logon hours are not used in your organization, this policy setting will have no impact. If logon hours are used, existing user sessions will be forcibly terminated when their logon hours expire.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
enableforcedlogoff
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network server: Disconnect clients when
logon hours expire
```

References:

1. CCE-3773-9

ARCHIVE

1.1.1.2.1.60 Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines what additional permissions are assigned for anonymous connections to the computer. If you enable this policy setting, anonymous Windows users are allowed to perform certain activities, such as enumerate the names of domain accounts and network shares. An unauthorized user could anonymously list account names and shared resources and use the information to guess passwords or perform social engineering attacks.

Rationale:

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords, perform social engineering attacks, or launch denial of service (DoS) attacks.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:EveryoneIncludesAnony
mous
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Let Everyone permissions apply to
anonymous users
```

References:

1. CCE-3817-4

ARCHIVE

1.1.1.2.1.61 Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines if the server side SMB service is required to perform SMB packet signing. Enable this policy setting in a mixed environment to prevent downstream clients from using the workstation as a network server.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems.SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 and later implementations of the SMB file and print sharing protocol support mutual authentication, which protect against session hijacking attacks and support message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: http://support.microsoft.com/default.aspx/kb/950876/.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
requiresecuritysignature
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network server: Digitally sign
communications (always)
```

Default Value:

Enabled

References:

1. CCE-3295-3

ARCHIVE

1.1.1.2.1.62 Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' or better (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines the level of data signing that is requested on behalf of clients that issue LDAP BIND requests, as follows: . None (least secure). The LDAP BIND request is issued with the caller-specified options. . Negotiate signing. If Transport Layer Security/Secure Sockets Layer (TLS/SSL) has not been started, the LDAP BIND request is initiated with the LDAP data signing option set in addition to the caller-specified options. If TLS/SSL has been started, the LDAP BIND request is initiated with the caller-specified options. . Require signature (most secure). This level is the same as Negotiate signing. However, if the LDAP server's intermediate saslBindInProgress response does not indicate that LDAP traffic signing is required, the caller is told that the LDAP BIND command request failed. Note: This policy setting does not have any impact on ldap_simple_bind or ldap_simple_bind_s. No Microsoft LDAP clients that are included with Windows XP Professional use ldap_simple_bind or ldap_simple_bind_s to communicate with a domain controller. The possible values for the Network security: LDAP client signing requirements setting are: . None . Negotiate signing . Require signature . Not Defined

Rationale:

Unsigned network traffic is susceptible to man-in-the-middle attacks in which an intruder captures the packets between the client and server, modifies them, and then forwards them to the server. For an LDAP server, this susceptibility means that an attacker could cause a server to make decisions that are based on false or altered data from the LDAP queries. To lower this risk in your network, you can implement strong physical security measures to protect the network infrastructure. Also, you can make all types of man-in-the-middle attacks extremely difficult if you require digital signatures on all network packets by means of IPsec authentication headers.

Impact:

If you configure the server to require LDAP signatures you must also configure the client. If you do not configure the client it will not be able to communicate with the server, which could cause many features to fail, including user authentication, Group Policy, and logon scripts.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LDAP:LDAPClientIntegrity
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network security: LDAP client signing requirements
```

References:

1. CCE-2819-1

ARCHIVE

1.1.1.2.1.63 Set 'Devices: Allow undock without having to log on' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a portable computer can be undocked if the user does not log on to the system. Enable this policy setting to eliminate a Logon requirement and allow use of an external hardware eject button to undock the computer. If you disable this policy setting, a user must log on and have been assigned the Remove computer from docking station user right to undock the computer.

Rationale:

If this policy setting is enabled, anyone with physical access to portable computers in docking stations could remove them and possibly tamper with them. However, the value of implementing this countermeasure is reduced by the following factors: . If attackers can restart the computer, they could remove it from the docking station after the BIOS starts but before the operating system starts. . This setting does not affect servers, because they typically are not installed in docking stations. . An attacker could steal the computer and the docking station together.

Impact:

Users who have docked their computers will have to log on to the local console before they can undock their computers. For computers that do not have docking stations, this policy setting will have no impact.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
undockwithoutlogon
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Allow undock without having to log on
```

References:

1. CCE-3613-7

ARCHIVE

1.1.1.2.1.64 Set 'Audit: Audit the access of global system objects' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting creates a default system access control list (SACL) for system objects such as mutexes (mutual exclusive), events, semaphores, and MS-DOS devices, and causes access to these system objects to be audited. If the Audit: Audit the access of global system objects setting is enabled, a very large number of security events could quickly fill the Security event log.

Rationale:

A globally visible named object, if incorrectly secured, could be acted upon by malicious software that knows the name of the object. For instance, if a synchronization object such as a mutex had a poorly chosen discretionary access control list (DACL), then malicious software could access that mutex by name and cause the program that created it to malfunction. However, the risk of such an occurrence is very low.

Impact:

If you enable the Audit: Audit the access of global system objects setting, a large number of security events could be generated, especially on busy domain controllers and application servers. Such an occurrence could cause servers to respond slowly and force the Security log to record numerous events of little significance. This policy setting can only be enabled or disabled, and there is no way to choose which events are recorded. Even organizations that have the resources to analyze events that are generated by this policy setting would not likely have the source code or a description of what each named object is used for. Therefore, it is unlikely that many organizations could benefit by enabling this policy setting.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:AuditBaseObjects
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Audit: Audit the access of global system objects
```

Default Value:

Disabled

References:

1. CCE-3774-7

ARCHIVE

1.1.1.2.1.65 Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments) in the SCE. This entry, when enabled, permits a server to automatically reboot after a fatal crash. It is enabled by default, which is undesirable on highly secure servers. You can add this registry value to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\CrashControl\ subkey.

Rationale:

There is some concern that a computer could get stuck in an endless loop of failures and reboots. However, the alternative to this entry may not be much more appealing—the computer will simply stop running.

Impact:

The computer will no longer reboot automatically after a failure.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\CrashControl:AutoReboot
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (AutoReboot) Allow Windows to automatically
restart after a system crash (recommended except for highly secure
environments)
```

Default Value:

Enabled

ARCHIVE

References:

1. CCE-7611-7

ARCHIVE

1.1.1.2.1.66 Set 'Interactive logon: Require smart card' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you use this setting, if appropriate to your environment and your organization's business requirements, to help protect end user computers. This policy setting requires users to log on to a computer with a smart card. Note: This setting applies to Windows 2000 computers, but it is not available through the Security Configuration Manager tools on these computers.

Rationale:

It can be difficult to make users choose strong passwords, and even strong passwords are vulnerable to brute-force attacks if an attacker has sufficient time and computing resources.

Impact:

All users of a computer with this setting enabled will have to use smart cards to log onto the local computer, which means that the organization will need a reliable public key infrastructure (PKI) as well as smart cards and smart card readers for these users. These requirements are significant challenges, because expertise and resources are required to plan for and deploy these technologies. However, Windows Server 2003 and later versions of Windows Server includes Certificate Services, a highly advanced service for implementing and managing certificates. When Certificate Services is combined with client computers that run Windows, features such as automatic user and computer enrollment and renewal become available. For more information about deploying Smart Cards with Windows Vista see the paper "Windows Vista Smart Card Infrastructure" available for download at the Microsoft Web site (http://www.microsoft.com/downloads/details.aspx?FamilyID=ac201438-3317-44d3-9638-07625fe397b9&displaylang=en).

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System:
scforceoption
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Require smart card
```

Default Value:

Disabled

References:

1. CCE-8542-3

ARCHIVE

1.1.1.2.1.67 Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether removable floppy media are accessible to both local and remote users simultaneously. If you enable this policy setting, only the interactively logged-on user is allowed to access removable floppy media. If this policy setting is enabled and no one is logged on interactively, the floppy media is accessible over the network.

Rationale:

A remote user could potentially access a mounted floppy that contains sensitive information. This risk is small because floppy disk drives are not automatically shared; administrators must deliberately choose to share the drive. However, administrators may wish to deny network users the ability to view data or run applications from removable media on the server.

Impact:

Users who connect to the server over the network will not be able to use any floppy disk drives that are installed on the server whenever anyone is logged on to the local console of the server. System tools that require access to floppy disk drives will fail. For example, the Volume Shadow Copy service attempts to access all CD-ROM and floppy disk drives present on the computer when it initializes, and if the service cannot access one of these drives it will fail. This condition will cause the Windows Backup tool to fail if volume shadow copies were specified for the backup job. Any non-Microsoft backup products that use volume shadow copies will also fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:AllocateFloppies
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Devices: Restrict floppy access to locally logged-
on user only
```

Default Value:

Disabled

References:

1. CCE-2822-5

ARCHIVE

1.1.1.2.1.68 Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether an anonymous user can request security identifier (SID) attributes for another user, or use a SID to obtain its corresponding user name. Disable this policy setting to prevent unauthenticated users from obtaining user names that are associated with their respective SIDs.

Rationale:

If this policy setting is enabled, a user with local access could use the well-known Administrator's SID to learn the real name of the built-in Administrator account, even if it has been renamed. That person could then use the account name to initiate a password guessing attack.

Impact:

Disabled is the default configuration for this policy setting on member computers; therefore it will have no impact on them. If you disable this policy setting on domain controllers, legacy computers may be unable to communicate with other computers in the domain. For example, the following computers may not work: . Windows NT 4.0based Remote Access Service servers. . Microsoft SQL Servers that run on Windows NT 3.xbased or Windows NT 4.0based computers. . Remote Access Service or Microsoft SQL servers that run on Windows 2000based computers and are located in Windows NT 3.x domains or Windows NT 4.0 domains.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `False`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Allow anonymous SID/Name
translation
```

References:

1. CCE-3402-5

ARCHIVE

1.1.1.2.1.69 Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

When this policy setting is enabled, a secure channel can only be established with domain controllers that are capable of encrypting secure channel data with a strong (128-bit) session key. To enable this policy setting, all domain controllers in the domain must be able to encrypt secure channel data with a strong key, which means all domain controllers must be running Microsoft Windows 2000 or later. If communication to non-Windows 2000based domains is required, it is recommended that you disable this policy setting.

Rationale:

Session keys that are used to establish secure channel communications between domain controllers and member computers are much stronger in Windows 2000 than they were in previous Microsoft operating systems. Whenever possible, you should take advantage of these stronger session keys to help protect secure channel communications from attacks thattempt to hijack network sessions and eavesdropping. (Eavesdropping is a form of hacking in which network data is read or altered in transit. The data can be modified to hide or change the sender, or be redirected.)

Impact:

Computers that have this policy setting enabled will not be able to join Windows NT 4.0 domains, and trusts between Active Directory domains and Windows NT-style domains may not work properly. Also, computers that do not support this policy setting will not be able to join domains in which the domain controllers have this policy setting enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters:requ
irestrongkey
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Domain member: Require strong (Windows 2000 or
later) session key
```

References:

1. CCE-3478-5

ARCHIVE

1.1.1.2.1.70 Set 'Network access: Remotely accessible registry paths' to 'System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which registry paths will be accessible after referencing the WinReg key to determine access permissions to the paths. Note: This setting does not exist in Windows XP. There was a setting with that name in Windows XP, but it is called Network access: Remotely accessible registry paths and subpaths in Windows Server 2003, Windows Vista, and Windows Server 2008. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

The registry is a database that contains computer configuration information, and much of the information is sensitive. An attacker could use this information to facilitate unauthorized activities. To reduce the risk of such an attack, suitable ACLs are assigned throughout the registry to help protect it from access by unauthorized users.

Impact:

Remote management tools such as the Microsoft Baseline Security Analyzer and Microsoft Systems Management Server require remote access to the registry to properly monitor and manage those computers. If you remove the default registry paths from the list of accessible ones, such remote management tools could fail. Note: If you want to allow remote access, you must also enable the Remote Registry service.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\
AllowedExactPaths:Machine
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Remotely accessible registry paths
```

Default Value:

System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion

References:

1. CCE-3729-1

ARCHIVE

1.1.1.2.1.71 Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '0' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a user can log on to a Windows domain using cached account information. Logon information for domain accounts can be cached locally to allow users to log on even if a domain controller cannot be contacted. This policy setting determines the number of unique users for whom logon information is cached locally. If this value is set to 0, the logon cache feature is disabled. An attacker who is able to access the file system of the server could locate this cached information and use a brute force attack to determine user passwords.

Rationale:

The number that is assigned to this policy setting indicates the number of users whose logon information the servers will cache locally. If the number is set to 10, then the server caches logon information for 10 users. When an eleventh user logs on to the computer, the server overwrites the oldest cached logon session. Users who access the server console will have their logon credentials cached on that server. An attacker who is able to access the file system of the server could locate this cached information and use a brute force attack to attempt to determine user passwords. To mitigate this type of attack, Windows encrypts the information and obscures its physical location.

Impact:

Users will be unable to log on to any computers if there is no domain controller available to authenticate them. Organizations may want to configure this value to 2 for end-user computers, especially for mobile users. A configuration value of 2 means that the userâ€ s logon information will still be in the cache, even if a member of the IT department has recently logged on to their computer to perform system maintenance. This method allows users to log on to their computers when they are not connected to the organizationâ€ s network.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:cachedlogonscount
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Number of previous logons to
cache (in case domain controller is not available)
```

References:

1. CCE-3709-3

ARCHIVE

1.1.1.2.1.72 Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which communication sessions, or pipes, will have attributes and permissions that allow anonymous access. Note: When you configure this setting you specify a list of one or more objects. The delimiter used when entering the list is a line feed or carriage return, that is, type the first object on the list, press the Enter button, type the next object, press Enter again, etc. The setting value is stored as a comma-delimited list in group policy security templates. It is also rendered as a comma-delimited list in Group Policy Editor's display pane and the Resultant Set of Policy console. It is recorded in the registry as a line-feed delimited list in a REG_MULTI_SZ value.

Rationale:

You can restrict access over named pipes such as COMNAP and LOCATOR to help prevent unauthorized access to the network. The list of some of the default named pipes and their purpose is provided in the following list: Browser - Named pipe for the Computer Browser service. COMNAP - SNABase named pipe. Systems Network Architecture (SNA) is a collection of network protocols that were originally developed for IBM mainframe computers. COMNODE - SNA Server named pipe. EPMAPPER - End Point Mapper named pipe. LOCATOR - Remote Procedure Call Locator service named pipe. Lsarpc - Named pipe for the Local Security Authority Remote Procedure Call service. Netlogon - Named pipe for then NetLogon service. Samr - Named pipe for the Security Accounts Manager service. SPOOLSS - Named pipe for the Print Spooler service. SQL\QUERY - Default named pipe for SQL Server. Srvsvc - Named pipe for the Server service. TrkSvr - Distributed Link Tracking Server named pipe. TrkWks - Distributed Link Tracking Client named pipe. Wkssvc - Named pipe for the Workstation service.

ARCHIVE

Impact:

This configuration will disable null session access over named pipes, and applications that rely on this feature or on unauthenticated access to named pipes will no longer function. For example, with Microsoft Commercial Internet System 1.0, the Internet Mail Service runs under the Inetinfo process. Inetinfo starts in the context of the System account. When Internet Mail Service needs to query the Microsoft SQL Server database, it uses the System account, which uses null credentials to access a SQL pipe on the computer that runs SQL Server. To avoid this problem, refer to the Microsoft Knowledge Base article How to access network files from IIS applications, which is located at http://support.microsoft.com/default.aspx?scid=207671.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
NullSessionPipes
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Named Pipes that can be accessed
anonymously
```

Default Value:

COMNAP COMNODE SQL\QUERY SPOOLSS EPMAPPER LOCATOR TrkWks TrkSvr

References:

1. CCE-3711-9

ARCHIVE

1.1.1.2.1.73 Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls the ability of anonymous users to enumerate SAM accounts as well as shares. If you enable this policy setting, anonymous users will not be able to enumerate domain account user names and network share names on the workstations in your environment. The Network access: Do not allow anonymous enumeration of SAM accounts and shares setting is configured to Enabled for the two environments that are discussed in this guide.

Rationale:

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords or perform social engineering attacks.

Impact:

It will be impossible to grant access to users of another domain across a one-way trust because administrators in the trusting domain will be unable to enumerate lists of accounts in the other domain. Users who access file and print servers anonymously will be unable to list the shared network resources on those servers; the users will have to authenticate before they can view the lists of shared folders and printers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:RestrictAnonymous
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Do not allow anonymous enumeration
of SAM accounts and shares
```

References:

1. CCE-3591-5

ARCHIVE

1.1.1.2.1.74 Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The recovery console is a command-line environment that is used to recover from system problems. If you enable this policy setting, the administrator account is automatically logged on to the recovery console when it is invoked during startup.

Rationale:

The Recovery Console can be very useful when you need to troubleshoot and repair computers that do not start. However, it is dangerous to allow automatic logon to the console. Anyone could walk up to the server, disconnect the power to shut it down, restart it, select Recover Console from the Restart menu, and then assume full control of the server.

Impact:

Users will have to enter a user name and password to access the Recovery Console.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Setup\RecoveryConsole:securitylevel
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Recovery console: Allow automatic administrative
logon
```

References:

1. CCE-3659-0

ARCHIVE

1.1.1.2.1.75 Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the system shuts down if it is unable to log Security events. It is a requirement for Trusted Computer System Evaluation Criteria (TCSEC)-C2 and Common Criteria certification to prevent auditable events from occurring if the audit system is unable to log them. Microsoft has chosen to meet this requirement by halting the system and displaying a stop message if the auditing system experiences a failure. When this policy setting is enabled, the system will be shut down if a security audit cannot be logged for any reason. If the Audit: Shut down system immediately if unable to log security audits setting is enabled, unplanned system failures can occur. Therefore, this policy setting is configured to Not Defined for both of the environments that are discussed in this chapter.

Rationale:

If the computer is unable to record events to the Security log, critical evidence or important troubleshooting information may not be available for review after a security incident. Also, an attacker could potentially generate a large volume of Security log events to purposely force a computer shutdown.

Impact:

If you enable this policy setting, the administrative burden can be significant, especially if you also configure the Retention method for the Security log to Do not overwrite events (clear log manually). This configuration causes a repudiation threat (a backup operator could deny that they backed up or restored data) to become a denial of service (DoS) vulnerability, because a server could be forced to shut down if it is overwhelmed with logon events and other security events that are written to the Security log. Also, because the shutdown is not graceful, it is possible that irreparable damage to the operating system, applications, or data could result. Although the NTFS file system guarantees its integrity when an ungraceful computer shutdown occurs, it cannot guarantee that every data file for every application will still be in a usable form when the computer restarts.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:crashonauditfail
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Audit: Shut down system immediately if unable to
log security audits
```

References:

1. CCE-3430-6

ARCHIVE

1.1.1.2.1.76 Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines if the server side SMB service is able to sign SMB packets if it is requested to do so by a client that attempts to establish a connection. If no signing request comes from the client, a connection will be allowed without a signature if the Microsoft network server: Digitally sign communications (always) setting is not enabled. Note Enable this policy setting on SMB clients on your network to make them fully effective for packet signing with all clients and servers in your environment.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then them so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data. SMB is the resource sharing protocol that is supported by many Windows operating systems. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Windows 2000 and later implementations of the SMB file and print sharing protocol support mutual authentication, which protect against session hijacking attacks and support message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server. Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a domain controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks. When SMB signing policies are enabled on domain controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledgebase Article 950876 for more details: http://support.microsoft.com/default.aspx/kb/950876/.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters:
enablesecuritysignature
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Microsoft network server: Digitally sign
communications (if client agrees)
```

Default Value:

Enabled

References:

1. CCE-3189-8

ARCHIVE

1.1.1.2.1.77 Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines how network logons that use local accounts are authenticated. The Classic option allows precise control over access to resources, including the ability to assign different types of access to different users for the same resource. The Guest only option allows you to treat all users equally. In this context, all users authenticate as Guest only to receive the same access level to a given resource.

Rationale:

With the Guest only model, any user who can authenticate to your computer over the network does so with guest privileges, which probably means that they will not have write access to shared resources on that computer. Although this restriction does increase security, it makes it more difficult for authorized users to access shared resources on those computers because ACLs on those resources must include access control entries (ACEs) for the Guest account. With the Classic model, local accounts should be password protected. Otherwise, if Guest access is enabled, anyone can use those user accounts to access shared system resources.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:ForceGuest
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Sharing and security model for
local accounts
```

Default Value:

Classic - local users authenticate as themselves

References:

1. CCE-3112-0

ARCHIVE

1.1.1.2.1.78 Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls the ability of anonymous users to enumerate the accounts in the Security Accounts Manager (SAM). If you enable this policy setting, users with anonymous connections cannot enumerate domain account user names on the workstations in your environment. This policy setting also allows additional restrictions on anonymous connections.

Rationale:

An unauthorized user could anonymously list account names and use the information to perform social engineering attacks or attempt to guess passwords. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information.)

Impact:

It will be impossible to establish trusts with Windows NT 4.0â€based domains. Also, client computers that run older versions of the Windows operating system such as Windows NT 3.51 and Windows 95 will experience problems when they try to use resources on the server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:RestrictAnonymousSAM
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Do not allow anonymous enumeration
of SAM accounts
```

References:

1. CCE-3631-9

ARCHIVE

1.1.1.2.1.79 Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Logon information is required to unlock a locked computer. For domain accounts, the Interactive logon: Require Domain Controller authentication to unlock workstation setting determines whether it is necessary to contact a domain controller to unlock a computer. If you enable this setting, a domain controller must authenticate the domain account that is being used to unlock the computer. If you disable this setting, logon information confirmation with a domain controller is not required for a user to unlock the computer. However, if you configure the Interactive logon: Number of previous logons to cache (in case domain controller is not available) setting to a value that is greater than zero, then the user's cached credentials will be used to unlock the computer. Note: This setting applies to Windows 2000 computers, but it is not available through the Security Configuration Manager tools on these computers.

Rationale:

By default, the computer caches in memory the credentials of any users who are authenticated locally. The computer uses these cached credentials to authenticate anyone who attempts to unlock the console. When cached credentials are used, any changes that have recently been made to the accountâ€such as user rights assignments, account lockout, or the account being disabledâ€are not considered or applied after the account is authenticated. User privileges are not updated, and (more importantly) disabled accounts are still able to unlock the console of the computer.

Impact:

When the console on a computer is locked, either by a user or automatically by a screen saver time-out, the console can only be unlocked if the user is able to re-authenticate to the domain controller. If no domain controller is available, then users cannot unlock their workstations. If you configure the Interactive logon: Number of previous logons to cache (in case domain controller is not available) setting to 0, users whose domain controllers are unavailable (such as mobile or remote users) will not be able to log on.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows
NT\CurrentVersion\Winlogon:ForceUnlockLogon
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Interactive logon: Require Domain Controller
authentication to unlock workstation
```

References:

1. CCE-3504-8

ARCHIVE

1.1.1.2.1.80 Set 'Network access: Do not allow storage of credentials or .NET Passports for network authentication' to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the Stored User Names and Passwords feature may save passwords or credentials for later use when it gains domain authentication. If you enable this policy setting, the Stored User Names and Passwords feature of Windows does not store passwords and credentials.

Rationale:

Passwords that are cached can be accessed by the user when logged on to the computer. Although this information may sound obvious, a problem can arise if the user unknowingly executes hostile code that reads the passwords and forwards them to another, unauthorized user.

Impact:

Users will be forced to enter passwords whenever they log on to their Passport account or other network resources that aren't accessible to their domain account. Testing has shown that clients running Windows Vista or Windows Server 2008 will be unable to connect to Distributed File System (DFS) shares in untrusted domains. Enabling this setting also makes it impossible to specify alternate credentials for scheduled tasks, this can cause a variety of problems. For example, some third party backup products will no longer work. This policy setting should have no impact on users who access network resources that are configured to allow access with their Active Directorybased domain account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:DisableDomainCreds
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `1`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Network access: Do not allow storage of credentials
or .NET Passports for network authentication
```

Default Value:

Disabled

References:

1. CCE-3420-7

ARCHIVE

1.1.1.2.1.81 Set 'MSS: (EnableDeadGWDetect) Allow automatic detection of dead network gateways (could lead to DoS)' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This entry appears as MSS: (EnableDeadGWDetect) Allow automatic detection of dead network gateways (could lead to DoS) in the SCE. When dead gateway detection is enabled, the IP may change to a backup gateway if a number of connections experience difficulty. Not applicable to Windows Vista or Windows Server 2008.

Rationale:

An attacker could force the server to switch gateways, potentially to an unintended one. This would be very difficult to do, so the value of this entry is small.

Impact:

If you configure this value to 0, Windows cannot detect dead gateways and automatically switch to alternates.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:EnableD
eadGWDetect
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (EnableDeadGWDetect) Allow automatic detection
of dead network gateways (could lead to DoS)
```

References:

1. CCE-2919-9

ARCHIVE

1.1.1.2.1.82 Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether the Transport Layer Security/Secure Sockets Layer (TLS/SSL) Security Provider supports only the TLS_RSA_WITH_3DES_EDE_CBC_SHA cipher suite. Although this policy setting increases security, most public Web sites that are secured with TLS or SSL do not support these algorithms. Client computers that have this policy setting enabled will also be unable to connect to Terminal Services on servers that are not configured to use the FIPS compliant algorithms. Note If you enable this policy setting, computer performance will be slower because the 3DES process is performed on each block of data in the file three times. This policy setting should only be enabled if your organization is required to be FIPS compliant. Important: This setting is recorded in different registry locations depending upon the version of Windows being used. For Windows XP and Windows Server 2003 it is stored at HKLM\System\CurrentControlSet\Control\Lsa\FIPSAlgorithmPolicy, with Windows Vista and later versions of Windows it is stored at HKLM\System\CurrentControlSet\Control\Lsa\FIPSAlgorithmPolicy\Enabled. This means that you must use Windows XP or Windows Server 2003 to edit group policies and security templates which will be applied to computers running Windows XP or Windows Server 2003. However, when editing group policies or security templates which will be applied to computers running Windows Vista or Windows Server 2008 you must use Windows Vista or Windows Server 2008.

Rationale:

You can enable this policy setting to ensure that the computer will use the most powerful algorithms that are available for digital encryption, hashing and signing. Use of these algorithms will minimize the risk of compromise of digitally encrypted or signed data by an unauthorized user.

ARCHIVE

Impact:

Client computers that have this policy setting enabled will be unable to communicate by means of digitally encrypted or signed protocols with servers that do not support these algorithms. Network clients that do not support these algorithms will not be able to use servers that require them for network communications. For example, many Apache-based Web servers are not configured to support TLS. If you enable this setting, you also need to configure Internet Explorer to use TLS. This policy setting also affects the encryption level that is used for the Remote Desktop Protocol (RDP). The Remote Desktop Connection tool uses the RDP protocol to communicate with servers that run Terminal Services and client computers that are configured for remote control; RDP connections will fail if both computers are not configured to use the same encryption algorithms. To enable Internet Explore to use TLS 1. On the Internet Explorer Tools menu, click Internet Options. 2. Click the Advanced tab. 3. Select the Use TLS 1.0 check box. It is also possible to configure this policy setting through Group Policy or by using the Internet Explorer Administrators Kit. Client computers running Windows XP, Windows XP SP1 and Windows XP SP2 that try to connect to a Terminal Services server that has this setting enabled will be unable to communicate with the server until an updated version of the Terminal Services client is installed. This issue could aslo affect Remote Assistance and Remote Desktop connections. For more information about the issue and how to resolve it see "Remote Assistance connection to Windows Server 2003 with FIPS encryption does not work" at http://support.microsoft.com/default.aspx?scid=kb;en-us;811770.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:FIPSAlgorithmPolicy
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\System cryptography: Use FIPS compliant algorithms
for encryption, hashing, and signing
```

References:

1. CCE-3441-3

ARCHIVE

1.1.1.2.1.83 Set 'Audit: Audit the use of Backup and Restore privilege' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether to audit the use of all user privileges, including Backup and Restore, when the Audit privilege use setting is in effect. If you enable both policies, an audit event will be generated for every file that is backed up or restored. If the Audit: Audit the use of Backup and Restore privilege setting is enabled, a very large number of security events could quickly fill the Security event log.

Rationale:

When back up and restore is used it creates a copy of the file system that is identical to the target of the backup. Making regular backups and restore volumes is an important part of a your incident response plan, but a malicious user could use a legitimate backup copy to get access to information or spoof a legitimate network resource to compromise your enterprise.

Impact:

If you enable this policy setting, a large number of security events could be generated, which could cause servers to respond slowly and force the Security event log to record numerous events of little significance. If you increase the Security log size to reduce the chances of a system shutdown, an excessively large log file may affect system performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa:fullprivilegeauditing
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `00`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\Audit: Audit the use of Backup and Restore
privilege
```

Default Value:

Disabled

References:

1. CCE-3814-1

ARCHIVE

1.1.1.2.1.84 Set 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry EnableICMPRedirect was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\ registry key. The entry appears as MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes in the SCE. Internet Control Message Protocol (ICMP) redirects cause the stack to plumb host routes. These routes override the Open Shortest Path First (OSPF)generated routes. It is recommended to configure this setting to Not Defined for enterprise environments and to Disabled for high security environments.

Rationale:

This behavior is expected. The problem is that the 10 minute time-out period for the ICMP redirect-plumbed routes temporarily creates a network situation in which traffic will no longer be routed properly for the affected host.

Impact:

When Routing and Remote Access Service (RRAS) is configured as an autonomous system boundary router (ASBR), it does not correctly import connected interface subnet routes. Instead, this router injects host routes into the OSPF routes. However, the OSPF router cannot be used as an ASBR router, and when connected interface subnet routes are imported into OSPF the result is confusing routing tables with strange routing paths.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters:EnableI
CMPRedirect
```

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `0`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (EnableICMPRedirect) Allow ICMP redirects to
override OSPF generated routes
```

References:

1. CCE-3725-9

ARCHIVE

1.1.1.2.1.85 Set 'MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.' to 'Only ISAKMP is exempt (recommended for Windows Server 2003)' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The registry value entry NoDefaultExempt was added to the template file in the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\IPSEC\ registry key. The entry appears as MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic in the SCE. The default exemptions to IPsec policy filters are documented in the online help for the specific operating system. These filters make it possible for Internet Key Exchange (IKE) and the Kerberos authentication protocol to function. The filters also make it possible for the network Quality of Service (QoS) to be signaled (RSVP) when the data traffic is secured by IPsec, and for traffic that IPsec might not secure such as multicast and broadcast traffic. IPsec is increasingly used for basic host-firewall packet filtering, particularly in Internet-exposed scenarios, and the affect of these default exemptions has not been fully understood. Therefore, some IPsec administrators may create IPsec policies that they think are secure, but are not actually secure against inbound attacks that use the default exemptions. For additional information, see the Knowledge Base article 811832, IPSec Default Exemptions Can Be Used to Bypass IPsec Protection in Some Scenarios.

Rationale:

As IPsec is increasingly used for basic host-firewall packet filtering, particularly in Internet-exposed scenarios, the affect of these default exemptions has not been fully understood. Some IPsec administrators may create IPsec policies that they think are secure, but are not actually secure against inbound attacks that use the default exemptions. Attackers could forge network traffic that appears to consist of legitimate IKE, RSVP, or Kerberos protocol packets but direct them to other network services on the host.

Impact:

After you enable this entry, security policies that already exist may have to be changed to work correctly. For details, refer to the Microsoft Knowledge Base article "IPSec Default Exemptions Can Be Used to Bypass IPsec Protection in Some Scenarios" at http://support.microsoft.com/default.aspx?kbid=811832.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\IPSEC:NoDefaultExempt
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `3`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Security Options\MSS: (NoDefaultExempt) Configure IPSec exemptions
for various types of network traffic.
```

Default Value:

Enabled

References:

1. CCE-8601-7

ARCHIVE

1.1.1.2.2 Audit Policy

ARCHIVE

1.1.1.2.2.1 Set 'Audit directory service access' to 'Failure' (Automated)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting determines whether to audit user access to an Active Directory object that has its own specified system access control list (SACL). If you define the Audit directory service access setting, you can specify whether to audit successes, failures, or not audit the event type at all. Success audits generate an audit entry when a user successfully accesses an Active Directory object that has a specified SACL. Failure audits generate an audit entry when a user unsuccessfully attempts to access an Active Directory object that has a specified SACL. If you enable the Audit directory service access setting in the DCBP and configure SACLs on directory objects, a large volume of entries can be generated in the Security logs on domain controllers. You should only enable this setting if you actually intend to use the information that is created. The following includes important security events that the Audit directory service access setting records in the Security log: Event ID Event description ID Description 566 A generic object operation took place.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit directory service access
```

References:

1. CCE-2827-4

ARCHIVE

1.1.1.2.2.2 Set 'Audit account logon events' to 'Success, Failure' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether to audit each instance of a user who logs on to or off from another computer that validates the account. Authentication of a domain user account on a domain controller generates an account logon event that is logged in the domain controller's Security log. Authentication of a local user on a local computer generates a logon event that is logged in the local Security log. No account logoff events are logged. The following table includes the important security events that this policy setting logs in the Security log. These event IDs can be useful when you want to create custom alerts to monitor any software suite, such as Microsoft Operations Manager (MOM). Table 4.3 Account Logon Events Event ID Event description 672 An authentication service (AS) ticket was successfully issued and validated. In Windows Server 2003 with SP1, the type of this event will be Success Audit for successful requests or Failure Audit for failed requests. 673 A ticket granting service (TGS) ticket was granted. A TGS is a ticket that is issued by the Kerberos version 5 TGS that allows a user to authenticate to a specific service in the domain. Windows Server 2003 with SP1 will log successes and failures for this event type. 674 A security principal renewed an AS ticket or a TGS ticket. 675 Pre-authentication failed. This event is generated on a Key Distribution Center (KDC) when a user enters an incorrect password. 676 Authentication ticket request failed. This event is not generated by Windows Server 2003 with SP1. Other Windows versions use this event to indicate an authentication failure that was not due to incorrect credentials. 677 A TGS ticket was not granted. This event is not generated by Windows Server 2003 with SP1, which uses a failure audit event with ID 672 for this case. 678 An account was successfully mapped to a domain account. 681 Logon failure. A domain account logon was attempted. This event is only generated by domain controllers. 682 A user has reconnected to a disconnected Terminal Server session. 683 A user disconnected a Terminal Server session but did not log off.

ARCHIVE

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Success, Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit account logon events
```

Default Value:

Success

References:

1. CCE-3321-7

ARCHIVE

1.1.1.2.2.3 Set 'Audit logon events' to 'Success, Failure' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The prescribed GPOs from Microsoft include settings that configure the audit categories present in previous versions of Windows. If you use the script and the GPOs included with this security guidance, these settings will not apply to computers running Windows Vista. The GPOs intended for use in enterprise environments have been designed to work with Windows XP based computers. Settings for audit categories are included in these GPOs so that computers running Windows XP in your environment receive the recommended audit policy settings for Windows XPbased computers. You can configure the Audit policy settings in Windows Vista at the following location in the Group Policy Object Editor: Computer Configuration\Windows Settings\Security Settings \Local Policies\Audit Policy

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Success, Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit logon events
```

Default Value:

Success

References:

1. CCE-3603-8

ARCHIVE

1.1.1.2.2.4 Set 'Audit process tracking' to 'No Auditing' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether to audit detailed tracking information for events such as program activation, process exit, handle duplication, and indirect object access. Enabling Audit process tracking will generate a large number of events, so typically it is set to No Auditing. However, this setting can provide a great benefit during an incident response from the detailed log of the processes started and the time when they were launched.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `No Auditing`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit process tracking
```

Default Value:

Not defined

References:

1. CCE-3510-5

ARCHIVE

1.1.1.2.2.5 Set 'Audit account management' to 'Success, Failure' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether to audit each account management event on a computer. Examples of account management events include: . A user account or group is created, changed, or deleted. . A user account is renamed, disabled, or enabled. . A password is set or changed. Organizations need to be able to determine who creates, modifies, or deletes both domain and local accounts. Unauthorized changes could indicate mistaken changes made by an administrator who does not understand how to follow organizational policies, but could also indicate a deliberate attack. The following table includes the important security events that this policy setting records in the Security log. These event IDs can be useful when you want to create custom alerts to monitor any software suite, such as MOM. Most operational management software can be customized with scripts to capture or flag events that are based on these event IDs. Table 4.4 Account Management Events Event ID Event description 624 A user account was created. 627 A user password was changed. 628 A user password was set. 630 A user account was deleted. 631 A global group was created. 632 A member was added to a global group. 633 A member was removed from a global group. 634 A global group was deleted. 635 A new local group was created. 636 A member was added to a local group. 637 A member was removed from a local group. 638 A local group was deleted. 639 A local group account was changed. 641 A global group account was changed. 642 A user account was changed. 643 A domain policy was modified. 644 A user account was automatically locked. 645 A computer account was created. 646 A computer account was changed. 647 A computer account was deleted. 648 A local security group with security disabled was created. Note: SECURITY_DISABLED in the formal name means that this group cannot be used to grant permissions in access checks. 649 A local security group with security disabled was changed. 650 A member was added to a security-disabled local security group. 651 A member was removed from a security-disabled local security group. 652 A security-disabled local group was deleted. 653 A security-disabled global group was created. 654 A security-disabled global group was changed. 655 A member was added to a security-disabled global group. 656 A member was removed from a security-disabled global group. 657 A security-disabled global group was deleted. 658

ARCHIVE

A security-enabled universal group was created. 659 A security-enabled universal group was changed. 660 A member was added to a security-enabled universal group. 661 A member was removed from a security-enabled universal group. 662 A security-enabled universal group was deleted. 663 A security-disabled universal group was created. 664 A security-disabled universal group was changed. 665 A member was added to a security-disabled universal group. 666 A member was removed from a security-disabled universal group. 667 A security-disabled universal group was deleted. 668 A group type was changed. 684 The security descriptor of administrative group members was set. Note: Every 60 minutes on a domain controller, a background thread searches all members of administrative groups (such as domain, enterprise, and schema administrators) and applies a fixed security descriptor on them. This event is logged. 685 Name of an account was changed.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Success, Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit account management
```

References:

1. CCE-3427-2

ARCHIVE

1.1.1.2.2.6 Set 'Audit policy change' to 'Success' (minimum) or 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines whether to audit every incident of a change to user rights assignment policies, Windows Firewall policies, Trust policies, or changes to the Audit policy itself. The recommended settings would let you see any account privileges that an attacker attempts to elevate—for example, by adding the Debug programs privilege or the Back up files and directories privilege.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Success` or `Success and Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit policy change
```

References:

1. CCE-3546-9

ARCHIVE

1.1.1.2.2.7 Set 'Audit system events' to 'Success' (minimum) or 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting is very important because it allows you to monitor system events that succeed and fail, and provides a record of these events that may help determine instances of unauthorized system access. System events include starting or shutting down computers in your environment, full event logs, or other security-related events that affect the entire system.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Success` or `Success and Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit system events
```

References:

1. CCE-3594-9

ARCHIVE

1.1.1.2.2.8 Set 'Audit privilege use' to 'Failure' (minimum) or 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting determines whether to audit each instance of a user exercising a user right. If you configure this value to Success, an audit entry is generated each time that a user right is exercised successfully. If you configure this value to Failure, an audit entry is generated each time that a user right is exercised unsuccessfully. This policy setting can generate a very large number of event records.

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Failure` or `Success and Failure`.

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit privilege use
```

References:

1. CCE-3211-0

ARCHIVE

1.1.1.2.2.9 Configure 'Audit object access' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Earlier security GPOs from Microsoft include settings that configure the audit categories in previous versions of Windows. These earlier GPOs do not apply to computers running Windows Vista. The GPOs intended for use in enterprise environments have been designed to work with Windows XP-based computers. Settings for audit categories are included in these GPOs so that computers running Windows XP in your environment receive the recommended audit policy settings for Windows XPbased computers. You can configure the Audit policy settings in Windows Vista at the following location in the Group Policy Object Editor: Computer Configuration\Windows Settings\Security Settings \Local Policies\Audit Policy

Rationale:

If audit settings are not configured, it can be difficult or impossible to determine what occurred during a security incident. However, if audit settings are configured so that events are generated for all activities the Security log will be filled with data and hard to use. Also, you can use a large amount of data storage as well as adversely affect overall computer performance if you configure audit settings for a large number of objects. If failure auditing is used and the Audit: Shut down system immediately if unable to log security audits setting in the Security Options section of Group Policy is enabled, an attacker could generate millions of failure events such as logon failures in order to fill the Security log and force the computer to shut down, creating a Denial of Service. If security logs are allowed to be overwritten, an attacker can overwrite part or all of their activity by generating large numbers of events so that the evidence of their intrusion is overwritten.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local
Policies\Audit Policy\Audit object access
```

References:

1. CCE-3286-2

ARCHIVE

1.1.1.2.3 User Rights Assignment

ARCHIVE

1.1.1.2.3.1 Set 'Allow log on through Terminal Services' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting determines which users or groups have the right to log on as a Terminal Services client. Remote desktop users require this user right. If your organization uses Remote Assistance as part of its help desk strategy, create a group and assign it this user right through Group Policy. If the help desk in your organization does not use Remote Assistance, assign this user right only to the Administrators group or use the restricted groups feature to ensure that no user accounts are part of the Remote Desktop Users group. Restrict this user right to the Administrators group, and possibly the Remote Desktop Users group, to prevent unwanted users from gaining access to computers on your network by means of the Remote Assistance feature. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any account with the Allow log on through Terminal Services user right can log on to the remote console of the computer. If you do not restrict this user right to legitimate users who need to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

Removal of the Allow log on through Terminal Services user right from other groups or membership changes in these default groups could limit the abilities of users who perform specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Allow log on through Terminal Services
```

Default Value:

Administrators, Remote Desktop Users

References:

1. CCE-3499-1

ARCHIVE

1.1.1.2.3.2 Set 'Allow log on through Terminal Services' to 'Administrators, Remote desktop Users' (Automated)

Profile Applicability:

- Level 1 - Member Server

Description:

This policy setting determines which users or groups have the right to log on as a Terminal Services client. Remote desktop users require this user right. If your organization uses Remote Assistance as part of its help desk strategy, create a group and assign it this user right through Group Policy. If the help desk in your organization does not use Remote Assistance, assign this user right only to the Administrators group or use the restricted groups feature to ensure that no user accounts are part of the Remote Desktop Users group. Restrict this user right to the Administrators group, and possibly the Remote Desktop Users group, to prevent unwanted users from gaining access to computers on your network by means of the Remote Assistance feature. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any account with the Allow log on through Terminal Services user right can log on to the remote console of the computer. If you do not restrict this user right to legitimate users who need to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

Removal of the Allow log on through Terminal Services user right from other groups or membership changes in these default groups could limit the abilities of users who perform specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators, Remote desktop Users`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Allow log on through Terminal Services
```

Default Value:

Administrators, Remote Desktop Users

References:

1. CCE-3499-1

ARCHIVE

1.1.1.2.3.3 Set 'Take ownership of files or other objects' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to take ownership of files, folders, registry keys, processes, or threads. This user right bypasses any permissions that are in place to protect objects to give ownership to the specified user. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any users with the Take ownership of files or other objects user right can take control of any object, regardless of the permissions on that object, and then make any changes they wish to that object. Such changes could result in exposure of data, corruption of data, or a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Take ownership of files or other objects
```

References:

1. CCE-2848-0

ARCHIVE

1.1.1.2.3.4 Set 'Enable computer and user accounts to be trusted for delegation' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting allows users to change the Trusted for Delegation setting on a computer object in Active Directory. Abuse of this privilege could allow unauthorized users to impersonate other users on the network. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Misuse of the Enable computer and user accounts to be trusted for delegation user right could allow unauthorized users to impersonate other users on the network. An attacker could exploit this privilege to gain access to network resources and make it difficult to determine what has happened after a security incident.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Enable computer and user accounts to be trusted for
delegation
```

Default Value:

Administrators

References:

1. CCE-3473-6

ARCHIVE

1.1.1.2.3.5 Configure 'Enable computer and user accounts to be trusted for delegation' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting allows users to change the Trusted for Delegation setting on a computer object in Active Directory. Abuse of this privilege could allow unauthorized users to impersonate other users on the network. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Misuse of the Enable computer and user accounts to be trusted for delegation user right could allow unauthorized users to impersonate other users on the network. An attacker could exploit this privilege to gain access to network resources and make it difficult to determine what has happened after a security incident.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Enable computer and user accounts to be trusted for
delegation
```

Default Value:

Administrators

References:

1. CCE-3473-6

ARCHIVE

1.1.1.2.3.6 Set 'Remove computer from docking station' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows the user of a portable computer to click Eject PC on the Start menu to undock the computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Anyone who has the Remove computer from docking station user right can log on and then remove a portable computer from its docking station. If this setting is not defined, it has the same effect as if everyone was granted this right. However, the value of implementing this countermeasure is reduced by the following factors: . If attackers can restart the computer, they could remove it from the docking station after the BIOS starts but before the operating system starts. . This setting does not affect servers, because they typically are not installed in docking stations. . An attacker could steal the computer and the docking station together.

Impact:

In Windows XP and Windows Server 2003 only members of the local Administrators and Power Users groups are granted this right by default. In later versions of Windows members of the local Administrators and Users groups have this right by default. Other user accounts must be explicitly granted the right as necessary. If your organization's users are not members of these groups on their portable computers, they will be unable to remove their own portable computers from their docking stations without shutting them down first. Therefore, on Windows XP, you may want to assign the Remove computer from docking station privilege to the local Users group for portable computers.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Remove computer from docking station
```

Default Value:

Administrators, Power Users

References:

1. CCE-2663-3

ARCHIVE

1.1.1.2.3.7 Configure 'Create permanent shared objects' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This user right is useful to kernel-mode components that extend the object namespace. However, components that run in kernel mode have this user right inherently. Therefore, it is typically not necessary to specifically assign this user right. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who have the Create permanent shared objects user right could create new shared objects and expose sensitive data to the network.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Create permanent shared objects
```

Default Value:

No One

References:

1. CCE-3269-8

ARCHIVE

1.1.1.2.3.8 Set 'Debug programs' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which user accounts will have the right to attach a debugger to any process or to the kernel, which provides complete access to sensitive and critical operating system components. Developers who are debugging their own applications do not need to be assigned this user right; however, developers who are debugging new system components will need it. Note Microsoft released several security updates in October 2003 that used a version of Update.exe that required the administrator to have the Debug programs user right. Administrators who did not have this user right were unable to install these security updates until they reconfigured their user rights. This is not typical behavior for operating system updates. For more information, see Knowledge Base article 830846: Windows Product Updates may stop responding or may use most or all the CPU resources. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Debug programs user right can be exploited to capture sensitive computer information from system memory, or to access and modify kernel or application structures. Some attack tools exploit this user right to extract hashed passwords and other private security information, or to insert rootkit code. By default, the Debug programs user right is assigned only to administrators, which helps to mitigate the risk from this vulnerability. The value of removing this user right from members of the Administrators group is diminished by the fact that a malicious user who has administrative privileges can bypass the countermeasure by launching processes under the Local System account.

ARCHIVE

Impact:

If you revoke this user right, no one will be able to debug programs. If you do revoke this privilege from all accounts and a problem arises that requires an application to be debugged on a production server, you can move the server to a different OU temporarily and assign the Debug programs user right to a separate Group Policy for that OU. The service account that is used for the cluster service needs the Debug programs privilege; if it does not have it, Windows Clustering will fail. For additional information about how to configure Windows Clustering in conjunction with computer hardening, see article 891597, How to apply more restrictive security settings on a Windows Server 2003based cluster server, in the Microsoft Knowledge Base (http://go.microsoft.com/fwlink/?LinkId=100746). Tools that are used to manage processes will be unable to affect processes that are not owned by the person who runs the tools. For example, the Windows Server 2003 Resource Kit tool Kill.exe requires this user right for administrators to terminate processes that they did not start. Task Manager will not be able to manage processes owned by other accounts. Also, some older versions of Update.exe (which is used to install Windows product updates) require the account that applies the update to have this user right. If you install one of the patches that uses this version of Update.exe, the computer could become unresponsive. For more information, see article 830846, Windows Product Updates may stop responding or may use most or all the CPU resources, in the Microsoft Knowledge Base (http://go.microsoft.com/fwlink/?LinkId=100747).

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Debug programs
```

References:

1. CCE-2576-7

ARCHIVE

1.1.1.2.3.9 Configure 'Load and unload device drivers' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to dynamically load a new device driver on a system. An attacker could potentially use this capability to install malicious code that appears to be a device driver. This user right is required for users to add local printers or printer drivers in Windows Vista. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Device drivers run as highly privileged code. A user who has the Load and unload device drivers user right could unintentionally install malicious code that masquerades as a device driver. Administrators should exercise greater care and install only drivers with verified digital signatures.

Impact:

If you remove the Load and unload device drivers user right from the Print Operators group or other accounts you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should ensure that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Load and unload device drivers
```

References:

1. CCE-3293-8

ARCHIVE

1.1.1.2.3.10 Set 'Adjust memory quotas for a process' to 'Administrators, LOCAL SERVICE, NETWORK SERVICE' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows a user to adjust the maximum amount of memory that is available to a process. The ability to adjust memory quotas is useful for system tuning, but it can be abused. In the wrong hands, it could be used to launch a denial of service (DoS) attack. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

A user with the Adjust memory quotas for a process privilege can reduce the amount of memory that is available to any process, which could cause business-critical network applications to become slow or to fail. In the wrong hands, this privilege could be used to start a denial of service (DoS) attack.

Impact:

Organizations that have not restricted users to roles with limited privileges will find it difficult to impose this countermeasure. Also, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Adjust memory quotas for a process user right to additional accounts that are required by those components. IIS requires that this privilege be explicitly assigned to the IWAM_<ComputerName>, Network Service, and Service accounts. Otherwise, this countermeasure should have no impact on most computers. If this user right is necessary for a user account, it can be assigned to a local computer account instead of a domain account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators, LOCAL SERVICE, NETWORK SERVICE`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Adjust memory quotas for a process
```

References:

1. CCE-3147-6

ARCHIVE

1.1.1.2.3.11 Configure 'Generate security audits' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users or processes can generate audit records in the Security log. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

An attacker could use this capability to create a large number of audited events, which would make it more difficult for a system administrator to locate any illicit activity. Also, if the event log is configured to overwrite events as needed, any evidence of unauthorized activities could be overwritten by a large number of unrelated events.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Generate security audits
```

References:

1. CCE-3491-8

ARCHIVE

1.1.1.2.3.12 Set 'Shut down the system' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users who are logged on locally to the computers in your environment can shut down the operating system with the Shut Down command. Misuse of this user right can result in a denial of service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The ability to shut down domain controllers should be limited to a very small number of trusted administrators. Although the Shut down the system user right requires the ability to log on to the server, you should be very careful about which accounts and groups you allow to shut down a domain controller. When a domain controller is shut down, it is no longer available to process logons, serve Group Policy, and answer Lightweight Directory Access Protocol (LDAP) queries. If you shut down domain controllers that possess Flexible SingleMaster Operations (FSMO) roles, you can disable key domain functionality, such as processing logons for new passwords—the Primary Domain Controller (PDC) Emulator role.

Impact:

The impact of removing these default groups from the Shut down the system user right could limit the delegated abilities of assigned roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Shut down the system
```

Default Value:

Administrators, Power Users, Backup Operators

References:

1. CCE-3346-4

ARCHIVE

1.1.1.2.3.13 Configure 'Increase scheduling priority' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether users can increase the base priority class of a process. (It is not a privileged operation to increase relative priority within a priority class.) This user right is not required by administrative tools that are supplied with the operating system but might be required by software development tools. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

A user who is assigned this user right could increase the scheduling priority of a process to Real-Time, which would leave little processing time for all other processes and could lead to a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Increase scheduling priority
```

References:

1. CCE-3539-4

ARCHIVE

1.1.1.2.3.14 Set 'Replace a process level token' to 'LOCAL SERVICE, NETWORK SERVICE' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows one process or service to start another service or process with a different security access token, which can be used to modify the security access token of that sub-process and result in the escalation of privileges. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

User with the Replace a process level token privilege are able to start processes as other users whose credentials they know. They could use this method to hide their unauthorized actions on the computer. (On Windows 2000-based computers, use of the Replace a process level token user right also requires the user to have the Adjust memory quotas for a process user right that is discussed earlier in this section.)

Impact:

On most computers, this is the default configuration and there will be no negative impact. However, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Replace a process level token privilege to additional accounts. For example, IIS requires that the Service, Network Service, and IWAM_<ComputerName> accounts be explicitly granted this user right.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `LOCAL SERVICE, NETWORK SERVICE`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Replace a process level token
```

References:

1. CCE-3447-0

ARCHIVE

1.1.1.2.3.15 Configure 'Add workstations to domain' (Manual)

Profile Applicability:

- Level 1 - Domain Controller

Description:

This policy setting specifies which users can add computer workstations to a specific domain. For this policy setting to take effect, it must be assigned to the user as part of the Default Domain Controller Policy for the domain. A user who has been assigned this right can add up to 10 workstations to the domain. Users who have been assigned the Create Computer Objects permission for an OU or the Computers container in Active Directory can add an unlimited number of computers to the domain, regardless of whether they have been assigned the Add workstations to a domain user right. By default, all users in the Authenticated Users group have the ability to add up to 10 computer accounts to an Active Directory domain. These new computer accounts are created in the Computers container. In Windowsbased networks, the term security principal is defined as a user, group, or computer that is automatically assigned a security identifier to control access to resources. In an Active Directory domain, each computer account is a full security principal with the ability to authenticate and access domain resources. However, some organizations may want to limit the number of computers in an Active Directory environment so that they can consistently track, build, and manage the computers. If users are allowed to add computers to the domain, tracking and management efforts would be hampered. Also, users could perform activities that are more difficult to trace because of their ability to create additional unauthorized domain computers. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Add workstations to domain user right presents a moderate vulnerability. Users with this right could add a computer to the domain that is configured in a way that violates organizational security policies. For example, if your organization does not want its users to have administrative privileges on their computers, a user could install Windows on his or her computer and then add the computer to the domain. The user would know the password for the local administrator account, and could log on with that account and then add his or her domain account to the local Administrators group.

Impact:

For organizations that have never allowed users to set up their own computers and add them to the domain, this countermeasure will have no impact. For those that have allowed some or all users to configure their own computers, this countermeasure will force the organization to establish a formal process for these procedures going forward. It will not affect existing computers unless they are removed from and re-added to the domain.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Add workstations to domain
```

Default Value:

No One

References:

1. CCE-3354-8

ARCHIVE

1.1.1.2.3.16 Configure 'Change the system time' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users and groups can change the time and date on the internal clock of the computers in your environment. Users who are assigned this user right can affect the appearance of event logs. When a computer's time setting is changed, logged events reflect the new time, not the actual time that the events occurred. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers. Note: Discrepancies between the time on the local computer and on the domain controllers in your environment may cause problems for the Kerberos authentication protocol, which could make it impossible for users to log on to the domain or obtain authorization to access domain resources after they are logged on. Also, problems will occur when Group Policy is applied to client computers if the system time is not synchronized with the domain controllers.

Rationale:

Users who can change the time on a computer could cause several problems. For example, time stamps on event log entries could be made inaccurate, time stamps on files and folders that are created or modified could be incorrect, and computers that belong to a domain may not be able to authenticate themselves or users who try to log on to the domain from them. Also, because the Kerberos authentication protocol requires that the requestor and authenticator have their clocks synchronized within an administrator-defined skew period, an attacker who changes a computer's time may cause that computer to be unable to obtain or grant Kerberos tickets. The risk from these types of events is mitigated on most domain controllers, member servers, and end-user computers because the Windows Time service automatically synchronizes time with domain controllers in the following ways: . All client desktop computers and member servers use the authenticating domain controller as their inbound time partner. . All domain controllers in a domain nominate the primary domain controller (PDC) emulator operations master as their inbound time partner. . All PDC emulator operations masters follow the hierarchy of domains in the selection of their inbound time partner. . The PDC emulator operations master at the root of the domain is authoritative for the organization. Therefore it is recommended that you configure this computer to synchronize with a reliable external time server. This vulnerability becomes much more serious if an attacker is able to change the system time and then stop the Windows Time service or reconfigure it to synchronize with a time server that is not accurate.

ARCHIVE

Impact:

There should be no impact, because time synchronization for most organizations should be fully automated for all computers that belong to the domain. Computers that do not belong to the domain should be configured to synchronize with an external source.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Change the system time
```

Default Value:

Administrators, Power Users

References:

1. CCE-3397-7

ARCHIVE

1.1.1.2.3.17 Configure 'Restore files and directories' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users can bypass file, directory, registry, and other persistent object permissions when restoring backed up files and directories on computers that run Windows Vista in your environment. This user right also determines which users can set valid security principals as object owners; it is similar to the Back up files and directories user right. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

An attacker with the Restore files and directories user right could restore sensitive data to a computer and overwrite data that is more recent, which could lead to loss of important data, data corruption, or a denial of service. Attackers could overwrite executable files that are used by legitimate administrators or system services with versions that include malicious software to grant themselves elevated privileges, compromise data, or install backdoors for continued access to the computer. Note: Even if the following countermeasure is configured, an attacker could still restore data to a computer in a domain that is controlled by the attacker. Therefore, it is critical that organizations carefully protect the media that are used to back up data.

Impact:

If you remove the Restore files and directories user right from the Backup Operators group and other accounts you could make it impossible for users who have been delegated specific tasks to perform those tasks. You should verify that this change won't negatively affect the ability of your organizationâ€ s personnel to do their jobs.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Restore files and directories
```

References:

1. CCE-3465-2

ARCHIVE

1.1.1.2.3.18 Configure 'Create a token object' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows a process to create an access token, which may provide elevated rights to access sensitive data. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

A user account that is given this user right has complete control over the system and can lead to the system being compromised. It is highly recommended that you do not assign any user accounts this right. The operating system examines a user's access token to determine the level of the user's privileges. Access tokens are built when users log on to the local computer or connect to a remote computer over a network. When you revoke a privilege, the change is immediately recorded, but the change is not reflected in the user's access token until the next time the user logs on or connects. Users with the ability to create or modify tokens can change the level of access for any currently logged on account. They could escalate their own privileges or create a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Create a token object
```

Default Value:

No One

ARCHIVE

References:

1. CCE-3498-3

ARCHIVE

1.1.1.2.3.19 Configure 'Synchronize directory service data' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Rationale:

The Synchronize directory service data user right affects domain controllers; only domain controllers should be able to synchronize directory service data. Domain controllers have this user right inherently, because the synchronization process runs in the context of the System account on domain controllers. Attackers who have this user right can view all information stored within the directory. They could then use some of that information to facilitate additional attacks or expose sensitive data, such as direct telephone numbers or physical addresses.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Synchronize directory service data
```

Default Value:

Not Defined

References:

1. CCE-3368-8

ARCHIVE

1.1.1.2.3.20 Set 'Profile system performance' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to use tools to view the performance of different system processes, which could be abused to allow attackers to determine a system's active processes and provide insight into the potential attack surface of the computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Profile system performance user right poses a moderate vulnerability. Attackers with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. Attackers may also be able to determine what processes are active on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software or an intrusion detection system.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Profile system performance
```

Default Value:

Administrators

ARCHIVE

References:

1. CCE-3002-3

ARCHIVE

1.1.1.2.3.21 Configure 'Access this computer from the network' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows other users on the network to connect to the computer and is required by various network protocols that include Server Message Block (SMB)based protocols, NetBIOS, Common Internet File System (CIFS), and Component Object Model Plus (COM+). When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who can connect from their computer to the network can access resources on target computers for which they have permission. For example, the Access this computer from the network user right is required for users to connect to shared printers and folders. If this user right is assigned to the Everyone group, then anyone in the group will be able to read the files in those shared folders. However, this situation is unlikely for new installations of recent versions of Windows, because the default share and NTFS permissions do not include the Everyone group. This vulnerability may have a higher level of risk for computers that you upgrade from Windows NT® 4.0 or Windows 2000, because the default permissions for these operating systems are not as restrictive as the default permissions in Windows Server 2003 and later versions of the Windows operating system.

Impact:

If you remove the Access this computer from the network user right on domain controllers for all users, no one will be able to log on to the domain or use network resources. If you remove this user right on member servers, users will not be able to connect to those servers through the network. Successful negotiation of IPsec connections requires that the initiating machine has this right, therefore it is recommended that it is assigned to the Users group. If you have installed optional components such as ASP.NET or Internet Information Services (IIS), you may need to assign this user right to additional accounts that are required by those components. It is important to verify that authorized users are assigned this user right for the computers they need to access the network.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Access this computer from the network
```

Default Value:

Everyone, Administrators, Users, Power Users, Backup Operators

References:

1. CCE-3322-5

ARCHIVE

1.1.1.2.3.22 Set 'Profile single process' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users can use tools to monitor the performance of non-system processes. Typically, you do not need to configure this user right to use the Microsoft Management Console (MMC) Performance snap-in. However, you do need this user right if System Monitor is configured to collect data using Windows Management Instrumentation (WMI). Restricting the Profile single process user right prevents intruders from gaining additional information that could be used to mount an attack on the system. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Profile single process user right presents a moderate vulnerability. An attacker with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. The attacker may also be able to determine what processes run on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software, an intrusion-detection system, or which other users are logged on to a computer.

Impact:

If you remove the Profile single process user right from the Power Users group or other accounts, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should ensure that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Profile single process
```

Default Value:

Administrators, Power Users

References:

1. CCE-2861-3

ARCHIVE

1.1.1.2.3.23 Configure 'Impersonate a client after authentication' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The policy setting allows programs that run on behalf of a user to impersonate that user (or another specified account) so that they can act on behalf of the user. If this user right is required for this kind of impersonation, an unauthorized user will not be able to convince a client to connect—for example, by remote procedure call (RPC) or named pipes—to a service that they have created to impersonate that client, which could elevate the unauthorized user's permissions to administrative or system levels. Services that are started by the Service Control Manager have the built-in Service group added by default to their access tokens. COM servers that are started by the COM infrastructure and configured to run under a specific account also have the Service group added to their access tokens. As a result, these processes are assigned this user right when they are started. Also, a user can impersonate an access token if any of the following conditions exist: . The access token that is being impersonated is for this user. . The user, in this logon session, logged on to the network with explicit credentials to create the access token. . The requested level is less than Impersonate, such as Anonymous or Identify. An attacker with the Impersonate a client after authentication user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

An attacker with the Impersonate a client after authentication user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

Impact:

In most cases this configuration will have no impact. If you have installed optional components such as ASP.NET or IIS, you may need to assign the Impersonate a client after authentication user right to additional accounts that are required by those components, such as IUSR_<ComputerName>, IIS_WPG, ASP.NET or IWAM_<ComputerName>.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Impersonate a client after authentication
```

Default Value:

Administrators, SERVICE

References:

1. CCE-8013-5

ARCHIVE

1.1.1.2.3.24 Set 'Create a pagefile' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to change the size of the pagefile. By making the pagefile extremely large or extremely small, an attacker could easily affect the performance of a compromised computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who can change the page file size could make it extremely small or move the file to a highly fragmented storage volume, which could cause reduced computer performance.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Create a pagefile
```

References:

1. CCE-3538-6

ARCHIVE

1.1.1.2.3.25 Set 'Deny log on as a batch job' to 'Guests' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which accounts will not be able to log on to the computer as a batch job. A batch job is not a batch (.bat) file, but rather a batch-queue facility. Accounts that use the Task Scheduler to schedule jobs need this user right. The Deny log on as a batch job user right overrides the Log on as a batch job user right, which could be used to allow accounts to schedule jobs that consume excessive system resources. Such an occurrence could cause a DoS condition. Failure to assign this user right to the recommended accounts can be a security risk. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Accounts that have the Deny log on as a batch job user right could be used to schedule jobs that could consume excessive computer resources and cause a DoS condition.

Impact:

If you assign the Deny log on as a batch job user right to other accounts, you could deny users who are assigned to specific administrative roles the ability to perform their required job activities. You should confirm that delegated tasks will not be affected adversely. For example, if you assign this user right to the IWAM_<ComputerName> account, the MSM Management Point will fail. On a newly installed computer that runs Windows Server 2003 this account does not belong to the Guests group, but on a computer that was upgraded from Windows 2000 this account is a member of the Guests group. Therefore, it is important that you understand which accounts belong to any groups that you assign the Deny log on as a batch job user right.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Guests`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Deny log on as a batch job
```

Default Value:

No One

References:

1. CCE-2649-2

ARCHIVE

1.1.1.2.3.26 Set 'Deny log on through Terminal Services' to 'Guests' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether users can log on as Terminal Services clients. After the baseline member server is joined to a domain environment, there is no need to use local accounts to access the server from the network. Domain accounts can access the server for administration and end-user processing. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any account with the right to log on through Terminal Services could be used to log on to the remote console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the Deny log on through Terminal Services user right to other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. Accounts that have this user right will be unable to connect to the computer through either Terminal Services or Remote Assistance. You should confirm that delegated tasks will not be negatively impacted.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Guests`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Deny log on through Terminal Services
```

Default Value:

No one

ARCHIVE

References:

1. CCE-3438-9

ARCHIVE

1.1.1.2.3.27 Configure 'Act as part of the operating system' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows a process to assume the identity of any user and thus gain access to the resources that the user is authorized to access. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Act as part of the operating system user right is extremely powerful. Anyone with this user right can take complete control of the computer and erase evidence of their activities.

Impact:

There should be little or no impact because the Act as part of the operating system user right is rarely needed by any accounts other than the Local System account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Act as part of the operating system
```

Default Value:

No one

References:

1. CCE-3490-0

ARCHIVE

1.1.1.2.3.28 Configure 'Back up files and directories' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to circumvent file and directory permissions to back up the system. This user right is enabled only when an application (such as NTBACKUP) attempts to access a file or directory through the NTFS file system backup application programming interface (API). Otherwise, the assigned file and directory permissions apply. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who are able to back up data from a computer could take the backup media to a non-domain computer on which they have administrative privileges and restore the data. They could take ownership of the files and view any unencrypted data that is contained within the backup set.

Impact:

Changes in the membership of the groups that have the Back up files and directories user right could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that authorized backup administrators are still able to perform backup operations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Back up files and directories
```

References:

1. CCE-2869-6

ARCHIVE

1.1.1.2.3.29 Set 'Log on as a service' to 'NETWORK SERVICE' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows accounts to launch network services or to register a process as a service running on the system. This user right should be restricted on any computer in a high security environment, but because many applications may require this privilege, it should be carefully evaluated and tested before configuring it in an enterprise environment. On Windows Vistabased computers, no users or groups have this privilege by default. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Log on as a service is a powerful user right because it allows accounts to launch network services or services that run continuously on a computer, even when no one is logged on to the console. The risk is reduced by the fact that only users with administrative privileges can install and configure services. An attacker who has already attained that level of access could configure the service to run with the Local System account.

Impact:

On most computers, this is the default configuration and there will be no negative impact. However, if you have installed optional components such as ASP.NET or IIS, you may need to assign the Log on as a service user right to additional accounts that are required by those components. IIS requires that this user right be explicitly granted to the ASPNET user account.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `NETWORK SERVICE`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Log on as a service
```

Default Value:

NETWORK SERVICE

References:

1. CCE-3332-4

ARCHIVE

1.1.1.2.3.30 Set 'Deny access to this computer from the network' to 'ANONYMOUS LOGON, Guests' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting prohibits users from connecting to a computer from across the network, which would allow users to access and potentially modify data remotely. In high security environments, there should be no need for remote users to access data on a computer. Instead, file sharing should be accomplished through the use of network servers. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who can log on to the computer over the network can enumerate lists of account names, group names, and shared resources. Users with permission to access shared folders and files can connect over the network and possibly view or modify data.

Impact:

If you configure the Deny access to this computer from the network user right for other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should verify that delegated tasks will not be negatively affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `ANONYMOUS LOGON, Guests`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Deny access to this computer from the network
```

Default Value:

SUPPORT_388945a0

ARCHIVE

References:

1. CCE-3062-7

ARCHIVE

1.1.1.2.3.31 Configure 'Perform volume maintenance tasks' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to manage the system's volume or disk configuration, which could allow a user to delete a volume and cause data loss as well as a denial-of-service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

A user who is assigned the Perform volume maintenance tasks user right could delete a volume, which could result in the loss of data or a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Perform volume maintenance tasks
```

References:

1. CCE-3319-1

ARCHIVE

1.1.1.2.3.32 Configure 'Deny log on locally' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This security setting determines which users are prevented from logging on at the computer. This policy setting supersedes the Allow log on locally policy setting if an account is subject to both policies.Important:If you apply this security policy to the Everyone group, no one will be able to log on locally. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any account with the ability to log on locally could be used to log on at the console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the Deny log on locally user right to additional accounts, you could limit the abilities of users who are assigned to specific roles in your environment. However, this user right should explicitly be assigned to the ASPNET account on computers that run IIS 6.0. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Deny log on locally
```

Default Value:

SUPPORT_388945a0

ARCHIVE

References:

1. CCE-3531-1

ARCHIVE

1.1.1.2.3.33 Set 'Allow log on locally' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users can interactively log on to computers in your environment. Logons that are initiated by pressing the CTRL+ALT+DEL key sequence on the client computer keyboard require this user right. Users who attempt to log on through Terminal Services or IIS also require this user right. The Guest account is assigned this user right by default. Although this account is disabled by default, it is recommended that you enable this setting through Group Policy. However, this user right should generally be restricted to the Administrators and Users groups. Assign this user right to the Backup Operators group if your organization requires that they have this capability. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any account with the Allow log on locally user right can log on at the console of the computer. If you do not restrict this user right to legitimate users who need to be able to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

If you remove these default groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. If you have installed optional components such as ASP.NET or Internet Information Services, you may need to assign Allow log on locally user right to additional accounts that are required by those components. IIS requires that this user right be assigned to the IUSR_<ComputerName> account. You should confirm that delegated activities will not be adversely affected by any changes that you make to the Allow log on locally user rights assignments.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Allow log on locally
```

Default Value:

Administrators, Users, Power Users, Backup Operators (Administrators, Backup Operators, Account Operators, Server Operators, Print Operators for domain controllers)

References:

1. CCE-3557-6

ARCHIVE

1.1.1.2.3.34 Configure 'Create global objects' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether users can create global objects that are available to all sessions. Users can still create objects that are specific to their own session if they do not have this user right. Users who can create global objects could affect processes that run under other users' sessions. This capability could lead to a variety of problems, such as application failure or data corruption. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users who can create global objects could affect processes that run under other users' sessions. This capability could lead to a variety of problems, such as application failure or data corruption.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Create global objects
```

Default Value:

Administrators, SERVICE

References:

1. CCE-7604-2

ARCHIVE

1.1.1.2.3.35 Configure 'Bypass traverse checking' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users who do not have the Traverse Folder access permission to pass through folders when they browse an object path in the NTFS file system or the registry. This user right does not allow users to list the contents of a folder. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The default configuration for the Bypass traverse checking setting is to allow all users, including the Everyone group, to bypass traverse checking. Permissions to files and folders are controlled though appropriate configuration of file system access control lists (ACLs), as the ability to traverse the folder does not provide any read or write permissions to the user. The only scenario in which the default configuration could lead to a mishap would be if the administrator who configures permissions does not understand how this policy setting works. For example, the administrator might expect that users who are unable to access a folder will be unable to access the contents of any child folders. Such a situation is unlikely, and therefore this vulnerability presents little risk.

Impact:

The Windows operating systems, as well as many applications, were designed with the expectation that anyone who can legitimately access the computer will have this user right. Therefore, we recommend that you thoroughly test any changes to assignments of the Bypass traverse checking user right before you make such changes to production systems. In particular, IIS requires this user right to be assigned to the Network Service, Local Service, IIS_WPG, IUSR_<ComputerName>, and IWAM_<ComputerName> accounts. (It must also be assigned to the ASPNET account through its membership in the Users group.) We recommend that you leave this policy setting at its default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Bypass traverse checking
```

Default Value:

Everyone, Administrators, Users, Power Users, Backup Operators

References:

1. CCE-3375-3

ARCHIVE

1.1.1.2.3.36 Configure 'Deny log on as a service' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This security setting determines which service accounts are prevented from registering a process as a service. This policy setting supersedes the Log on as a service policy setting if an account is subject to both policies.Note: This security setting does not apply to the System, Local Service, or Network Service accounts. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Accounts that can log on as a service could be used to configure and start new unauthorized services, such as a keylogger or other malicious software. The benefit of the specified countermeasure is somewhat reduced by the fact that only users with administrative privileges can install and configure services, and an attacker who has already attained that level of access could configure the service to run with the System account.

Impact:

If you assign the Deny log on as a service user right to specific accounts, services may not be able to start and a DoS condition could result.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Deny log on as a service
```

Default Value:

No one

ARCHIVE

References:

1. CCE-3543-6

ARCHIVE

1.1.1.2.3.37 Set 'Manage auditing and security log' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines which users can change the auditing options for files and directories and clear the Security log. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The ability to manage the Security event log is a powerful user right and it should be closely guarded. Anyone with this user right can clear the Security log to erase important evidence of unauthorized activity.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Manage auditing and security log
```

References:

1. CCE-3575-8

ARCHIVE

1.1.1.2.3.38 Configure 'Lock pages in memory' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows a process to keep data in physical memory, which prevents the system from paging the data to virtual memory on disk. If this user right is assigned, significant degradation of system performance can occur. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Users with the Lock pages in memory user right could assign physical memory to several processes, which could leave little or no RAM for other processes and result in a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Lock pages in memory
```

Default Value:

No one

References:

1. CCE-2936-3

ARCHIVE

1.1.1.2.3.39 Configure 'Force shutdown from a remote system' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to shut down Windows Vistabased computers from remote locations on the network. Anyone who has been assigned this user right can cause a denial of service (DoS) condition, which would make the computer unavailable to service user requests. Therefore, it is recommended that only highly trusted administrators be assigned this user right. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Any user who can shut down a computer could cause a denial of service (DoS) condition to occur. Therefore, this user right should be tightly restricted.

Impact:

If you remove the Force shutdown from a remote system user right from the Server Operator group you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Force shutdown from a remote system
```

References:

1. CCE-3359-7

ARCHIVE

1.1.1.2.3.40 Set 'Modify firmware environment values' to 'Administrators' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows users to configure the system-wide environment variables that affect hardware configuration. This information is typically stored in the Last Known Good Configuration. Modification of these values and could lead to a hardware failure that would result in a denial of service condition. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

Anyone who is assigned the Modify firmware environment values user right could configure the settings of a hardware component to cause it to fail, which could lead to data corruption or a denial of service (DoS) condition.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Administrators`.

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Modify firmware environment values
```

References:

1. CCE-3218-5

ARCHIVE

1.1.1.2.3.41 Configure 'Log on as a batch job' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows accounts to log on using the task scheduler service. Because the task scheduler is often used for administrative purposes, it may be needed in enterprise environments. However, its use should be restricted in high security environments to prevent misuse of system resources or to prevent attackers from using the right to launch malicious code after gaining user level access to a computer. When configuring a user right in the SCM enter a comma delimited list of accounts. Accounts can be either local or located in Active Directory, they can be groups, users, or computers.

Rationale:

The Log on as a batch job user right presents a low-risk vulnerability. For most organizations, the default settings are sufficient.

Impact:

If you configure the Log on as a batch job setting through domainbased Group Policies, the computer will not be able to assign the user right to accounts that are used for scheduled jobs in the Task Scheduler. If you install optional components such as ASP.NET or IIS, you might need to assign this user right to additional accounts that are required by those components. For example, IIS requires assignment of this user right to the IIS_WPG group and the IUSR_<ComputerName>, ASPNET, and IWAM_<ComputerName> accounts. If this user right is not assigned o this group and these accounts, IIS will be unable to run some COM objects that are necessary for proper functionality.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Local Policies\User
Rights Assignment\Log on as a batch job
```

Default Value:

LOCAL SERVICE, SUPPORT_388945a0

References:

1. CCE-3191-4

ARCHIVE

1.1.1.3 Event Log

ARCHIVE

1.1.1.3.1 Set 'Retention method for system log' to 'Overwrites events as needed' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the wrapping method for the System log. It is imperative that the System log is archived regularly if historical events are desirable for either forensics or troubleshooting purposes. Overwriting events as needed ensures that the log always stores the most recent events, although this configuration could result in a loss of historical data.

Rationale:

If you significantly increase the number of objects to audit in your organization, there is a risk that the Security log will reach its capacity and force the computer to shut down. If such a shutdown occurs, the computer will be unusable until an administrator clears the Security log. To prevent such a shutdown, you can disable the Audit: Shut down system immediately if unable to log security audits setting that is described in Security Options and then increase the Security log size. If you set the Event log retention method to Manual or Overwrite events by days, it is possible for important recent events to not be recorded or for a DoS attack to occur.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method is set so that the computer can overwrite the oldest entries with the most recent ones.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `WhenNeeded`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retention
method for system log
```

References:

1. CCE-3422-3

ARCHIVE

1.1.1.3.2 Set 'Maximum application log size' to '16384' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies the maximum size of the Application event log. In Windows Vista and Windows Server 2008 this setting has been replaced by another called System, located at Computer Configuration\Administrative Templates\Windows Components\Event Log Service. If both this setting and the new one are configured the settingatComputer Configuration\Administrative Templates\Windows Components\Event Log Service will take precedence.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `16384`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Maximum
application log size
```

Default Value:

16384 KB

References:

1. CCE-3550-1

ARCHIVE

1.1.1.3.3 Set 'Retention method for security log' to 'Overwrites events as needed' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the wrapping method for the Security log. It is imperative that the Security log is archived regularly if historical events are desirable for either forensics or troubleshooting purposes. Overwriting events as needed ensures that the log always stores the most recent events, although this configuration could result in a loss of historical data.

Rationale:

If you significantly increase the number of objects to audit in your organization, there is a risk that the Security log will reach its capacity and force the computer to shut down. If such a shutdown occurs, the computer will be unusable until an administrator clears the Security log. To prevent such a shutdown, you can disable the Audit: Shut down system immediately if unable to log security audits setting that is described in Security Options and then increase the Security log size. If you set the Event log retention method to Manual or Overwrite events by days, it is possible for important recent events to not be recorded or for a DoS attack to occur.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method is set so that the computer can overwrite the oldest entries with the most recent ones.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `WhenNeeded`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retention
method for security log
```

References:

1. CCE-3484-3

ARCHIVE

1.1.1.3.4 Set 'Maximum system log size' to '16384' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies the maximum size of the System event log. In Windows Vista and Windows Server 2008 this setting has been replaced by another called System, located at Computer Configuration\Administrative Templates\Windows Components\Event Log Service. If both this setting and the new one are configured the settingatComputer Configuration\Administrative Templates\Windows Components\Event Log Service will take precedence.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `16384`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Maximum
system log size
```

Default Value:

16384 KB

References:

1. CCE-3506-3

ARCHIVE

1.1.1.3.5 Set 'Maximum security log size' to '81920' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies the maximum size of the System event log. In Windows Vista and Windows Server 2008 this setting has been replaced by another called System, located at Computer Configuration\Administrative Templates\Windows Components\Event Log Service. If both this setting and the new one are configured the settingatComputer Configuration\Administrative Templates\Windows Components\Event Log Service will take precedence.

Rationale:

If you significantly increase the number of objects to audit in your organization, there is a risk that the Security log will reach its capacity and force the computer to shut down if you enabled the Audit: Shut down system immediately if unable to log security audits setting. If such a shutdown occurs, the computer will be unusable until an administrator clears the Security log. To prevent such a shutdown, you can disable the Audit: Shut down system immediately if unable to log security audits setting that is described in Chapter 5, "Security Options," and increase the Security log size. Alternatively, you can configure automatic log rotation as described in the Microsoft Knowledge Base article "The event log stops logging events before reaching the maximum log size" at http://support.microsoft.com/default.aspx?kbid=312571.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed. The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data. Ideally, all specifically monitored events should be sent to a server that uses Microsoft Operations Manager (MOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `81920`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Maximum
security log size
```

Default Value:

16384 KB

References:

1. CCE-3343-1

ARCHIVE

1.1.1.3.6 Set 'Retention method for application log' to 'Overwrites events as needed' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the wrapping method for the Application log. It is imperative that the Application log is archived regularly if historical events are desirable for either forensics or troubleshooting purposes. Overwriting events as needed ensures that the log always stores the most recent events, although this configuration could result in a loss of historical data.

Rationale:

If you significantly increase the number of objects to audit in your organization, there is a risk that the Security log will reach its capacity and force the computer to shut down. If such a shutdown occurs, the computer will be unusable until an administrator clears the Security log. To prevent such a shutdown, you can disable the Audit: Shut down system immediately if unable to log security audits setting that is described in Security Options and then increase the Security log size. If you set the Event log retention method to Manual or Overwrite events by days, it is possible for important recent events to not be recorded or for a DoS attack to occur.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method is set so that the computer can overwrite the oldest entries with the most recent ones.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed.

ARCHIVE

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `WhenNeeded`.

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retention
method for application log
```

References:

1. CCE-17457-3

ARCHIVE

1.1.1.3.7 Configure 'Retain system log' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This setting turns on and off the option to retain the system log and works in conjunction with the Retention method for system log setting.

Rationale:

If you archive the log at scheduled intervals: 1. Open the Properties dialog box for this policy setting. 2. Specify the appropriate number of days in the Retain application log setting. 3. Select Overwrite events by days for the event log retention method. Also, ensure that the maximum log size is large enough to accommodate the interval.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retain
system log
```

Default Value:

Not defined

References:

1. CCE-3512-1

ARCHIVE

1.1.1.3.8 Configure 'Retain security log' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This setting is the toggle setting to retain the security log and works with the Retention method for the security log setting.

Rationale:

If you archive the log at scheduled intervals: 1. Open the Properties dialog box for this policy setting. 2. Specify the appropriate number of days in the Retain application log setting. 3. Select Overwrite events by days for the event log retention method. Also, ensure that the maximum log size is large enough to accommodate the interval.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retain
security log
```

Default Value:

Not defined

References:

1. CCE-3127-8

ARCHIVE

1.1.1.3.9 Configure 'Retain application log' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This setting is the toggle setting to retain the application log and works in conjunction with the retention method for application logs setting.

Rationale:

If you archive the log at scheduled intervals: 1. Open the Properties dialog box for this policy setting. 2. Specify the appropriate number of days in the Retain application log setting. 3. Select Overwrite events by days for the event log retention method. Also, ensure that the maximum log size is large enough to accommodate the interval.

Impact:

None. This is the default configuration.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization.

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Windows Settings\Security Settings\Event Log\Retain
application log
```

Default Value:

Not defined

References:

1. CCE-3567-5

ARCHIVE

1.2 Administrative Templates

1.2.1 Network

1.2.1.1 Network Connections

1.2.1.1.1 Windows Firewall

1.2.1.1.1.1 Standard Profile

ARCHIVE

1.2.1.1.1.1.1 Configure 'Windows Firewall: Allow ICMP exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting defines the set of Internet Control Message Protocol (ICMP) message types that Windows Firewall allows. Utilities can use ICMP messages to determine the status of other computers. For example, Ping uses the echo request message.

Rationale:

Many attacker tools take advantage of computers that accept ICMP message types and use these messages to mount a variety of attacks.

Impact:

If you configure the Windows Firewall: Allow ICMP exceptions setting to Enabled, you must specify which ICMP message types Windows Firewall allows the computer to send or receive. When you configure this policy setting to Disabled, Windows Firewall blocks all unsolicited inbound ICMP message types and the listed outbound ICMP message types. As a result, utilities that rely on ICMP may fail. Some applications require some ICMP messages in order to function properly. Also, ICMP messages are used to estimate network performance when Group Policy is downloaded and processed; if ICMP messages are blocked, Group Policy may not be applied to affected systems. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\IcmpSettings:AllowOutboundParameterProblem
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow ICMP
exceptions
```

References:

1. CCE-17102-5

ARCHIVE

1.2.1.1.1.1.2 Configure 'Windows Firewall: Define inbound port exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you avoid the use of this setting, unless required by your environment and your organization's business requirements. The Windows Firewall port exceptions list should be defined by Group Policy, which allows you to centrally manage and deploy your port exceptions and ensure that local administrators do not create less secure settings.

Rationale:

Granting port exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you enable the Windows Firewall: Define inbound port exceptions setting, you can view and change the port exceptions list that is defined by Group Policy. To view and modify the port exceptions list, configure the setting to Enabled and then click the Show button. Note that if you type an invalid definition string, Windows Firewall adds it to the list without checking for errors, which means that you can accidentally create multiple entries for the same port with Scope or Status values that conflict. If you disable the Windows Firewall: Define inbound port exceptions setting, the port exceptions list that is defined by Group Policy is deleted but other settings can continue to open or block ports. Also, if a local port exceptions list exists, it is ignored unless you enable the Windows Firewall: Allow local port exceptions setting. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\GloballyOpenPorts:Enabled
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Define
inbound port exceptions
```

References:

1. CCE-17589-3

ARCHIVE

1.2.1.1.1.1.3 Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting helps prevent a computer from receiving unicast responses to its outgoing multicast or broadcast messages.

Rationale:

Typically, you would not want to receive unicast responses to multicast or broadcast messages. Such responses can indicate a denial of service (DoS) attack or an attempt to probe a known computer.

Impact:

Note This policy setting has no effect if the unicast message is a response to a DHCP broadcast message that is sent by the computer. Windows Firewall always permits those DHCP responses. However, this policy setting can interfere with the NetBIOS messages that detect name conflicts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e:DisableUnicastResponsesToMulticastBroadcast
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Prohibit
unicast response to multicast or broadcast requests
```

References:

1. CCE-17364-1

ARCHIVE

1.2.1.1.1.1.4 Configure 'Windows Firewall: Allow local program exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you avoid the use of this setting, unless required by your environment and your organization's business requirements. This policy setting controls whether administrators can use the Windows Firewall component in Control Panel to define a local program exceptions list.

Rationale:

Granting program exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you disable this policy setting, administrators will not be able to define a local program exceptions list; also, this configuration ensures that program exceptions only come from Group Policy. If this policy setting is enabled, local administrators are allowed to use Control Panel to define program exceptions locally. For enterprise client computers, there may be conditions that justify local program exceptions. These conditions may include applications that were not analyzed when the organization's firewall policy was created or new applications that require nonstandard port configuration. If you choose to enable the Windows Firewall: Allow local program exceptions setting for such situations, remember that the attack surface of the affected computers is increased.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\AuthorizedApplications:AllowUserPrefMerge
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow local
program exceptions
```

References:

1. CCE-16712-2

ARCHIVE

1.2.1.1.1.1.5 Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Many organizations take advantage of remote computer administration in their daily operations. To provide flexibility for remote administration, the Windows Firewall: Allow inbound remote administration exception setting is available. If you enable this setting, computers in your environment should accept remote administration requests from as few computers as possible. To maximize the protection provided by Windows Firewall, make sure to specify only the necessary IP addresses and subnets of computers that are used for remote administration.

Rationale:

Some attacks have exploited the ports that are typically used by remote administration programs; Windows Firewall can help block these ports.

Impact:

If this policy setting is enabled, the computer can receive the unsolicited incoming messages that are associated with remote administration on TCP ports 135 and 445. This policy setting also allows Svchost.exe and Lsass.exe to receive unsolicited incoming messages and allows hosted services to open additional dynamically-assigned ports, typically in the range of 1024 to 1034 but potentially anywhere from 1024 to 65535. If you enable this policy setting, you need to specify the IP addresses or subnets from which these incoming messages are allowed. If you configure the Windows Firewall: Allow inbound remote administration exception setting to Disabled, Windows Firewall makes none of the described exceptions. The impact of configuring this policy setting to Disabled may be unacceptable to many organizations because many remote administration tools and tools that scan for vulnerabilities will fail.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\RemoteAdminSettings:Enabled
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow inbound
remote administration exception
```

References:

1. CCE-16739-5

ARCHIVE

1.2.1.1.1.1.6 Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Many organizations use Remote Desktop connections in their normal troubleshooting procedures or operations. To provide flexibility for remote administration, the Windows Firewall: Allow inbound Remote Desktop exceptions setting is available.

Rationale:

Some attacks have exploited the ports that are typically used by Remote Desktop.

Impact:

If you enable this policy setting, Windows Firewall opens TCP port 3389 for inbound connections. You must also specify the IP addresses or subnets from which these inbound messages are allowed. If you disable this policy setting, Windows Firewall blocks this port and prevents the computer from receiving Remote Desktop requests. If an administrator adds this port to a local port exceptions list in an attempt to open it, Windows Firewall does not open the port. Computers in your environment should accept Remote Desktop requests from as few computers as possible.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\Services\RemoteDesktop:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow inbound
Remote Desktop exceptions
```

References:

1. CCE-17228-8

ARCHIVE

1.2.1.1.1.1.7 Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows a computer to receive unsolicited Plug and Play messages that are sent by network devices, such as routers with built-in firewalls. To receive these messages, Windows Firewall opens TCP port 2869 and UDP port 1900.

Rationale:

Blocking UPnP network traffic effectively reduces the attack surface of computers in your environment.

Impact:

If you enable the Windows Firewall: Allow inbound UPnP framework exceptions setting, Windows Firewall opens these ports so that the computer can receive Plug and Play messages. You must specify the IP addresses or subnets from which these inbound messages are allowed. If you disable this policy setting, Windows Firewall blocks these ports and prevents the computer from receiving Plug and Play messages.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\Services\UPnPFramework:Enabled
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow inbound
UPnP framework exceptions
```

References:

1. CCE-17360-9

ARCHIVE

1.2.1.1.1.1.8 Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting creates an exception that allows file and printer sharing. It configures Windows Firewall to open UDP ports 137 and 138 and TCP ports 139 and 445.

Rationale:

Enabling access to file and printer sharing could cause a user to unknowingly expose sensitive data. Additionally, there have been vulnerabilities in the resource sharing features that have been remotely exploitable.

Impact:

If you enable this policy setting, Windows Firewall opens these ports so that the computer can receive print jobs and requests for access to shared files. You must specify the IP addresses or subnets from which such messages are allowed. If you disable the Windows Firewall: Allow inbound file and printer sharing exception setting, Windows Firewall blocks these ports and prevents the computer from sharing files and printers. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\Services\FileAndPrint:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow inbound
file and printer sharing exception
```

References:

1. CCE-16584-5

ARCHIVE

1.2.1.1.1.1.9 Configure 'Windows Firewall: Define inbound program exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you use this setting, if appropriate to your environment and your organization's business requirements, to help protect end user computers. Some applications may need to open and use network ports that are not typically allowed by Windows Firewall. The Windows Firewall: Define inbound program exceptions setting allows you to view and change the program exceptions list that is defined by Group Policy.

Rationale:

There is risk that inbound exceptions will be made to programs that have software vulnerabilities, however, if exceptions are not allowed then management programs and other useful applications will fail.

Impact:

If this policy setting is Enabled you can view and change the program exceptions list. If you add a program to this list and set its status to Enabled, that program can receive unsolicited incoming messages on any port that it requests Windows Firewall to open, even if that port is blocked by another setting. If you configure this policy setting to Disabled, the program exceptions list that is defined by Group Policy is deleted. Note If you type an invalid definition string, Windows Firewall adds it to the list without checking for errors. Because the entry is not checked, you can add programs that you have not installed yet. You can also accidentally create multiple exceptions for the same program with Scope or Status values that conflict.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\AuthorizedApplications:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Define
inbound program exceptions
```

References:

1. CCE-16591-0

ARCHIVE

1.2.1.1.1.1.10 Configure 'Windows Firewall: Allow local port exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The Windows Firewall port exceptions list should be defined by Group Policy, which allows you to centrally manage and deploy your port exceptions and ensure that local administrators do not create less secure settings.

Rationale:

Granting port exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you enable the Windows Firewall: Define inbound port exceptions setting, you can view and change the port exceptions list that is defined by Group Policy. To view and modify the port exceptions list, configure the setting to Enabled and then click the Show button. Note that if you type an invalid definition string, Windows Firewall adds it to the list without checking for errors, which means that you can accidentally create multiple entries for the same port with Scope or Status values that conflict. If you disable the Windows Firewall: Define inbound port exceptions setting, the port exceptions list that is defined by Group Policy is deleted but other settings can continue to open or block ports. Also, if a local port exceptions list exists, it is ignored unless you enable the Windows Firewall: Allow local port exceptions setting. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e\GloballyOpenPorts:AllowUserPrefMerge
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Allow local
port exceptions
```

References:

1. CCE-16589-4

ARCHIVE

1.2.1.1.1.1.11 Configure 'Windows Firewall: Prohibit notifications' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Windows Firewall can display notifications to users when a program requests that Windows Firewall add the program to the program exceptions list. This situation occurs when programs attempt to open a port and are not allowed to do so because of current Windows Firewall rules. The Windows Firewall: Prohibit notifications setting determines whether these settings are shown to the users. If you configure this policy setting to Enabled, Windows Firewall prevents the display of these notifications. If you configure it to Disabled, Windows Firewall allows the display of these notifications.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity.

Impact:

If you configure this policy setting to Enabled, Windows Firewall prevents the display of these notifications. If you configure it to Disabled, Windows Firewall allows the display of these notifications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e:DisableNotifications
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Prohibit
notifications
```

References:

1. CCE-17483-9

ARCHIVE

1.2.1.1.1.1.12 Configure 'Windows Firewall: Do not allow exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting caused Windows Firewall to block all unsolicited incoming messages. It overrides all other Windows Firewall settings that allow such messages. If you enable this policy setting in the Windows Firewall item in Control Panel, the Don't allow exceptions check box is selected and administrators cannot clear it.

Rationale:

This policy setting provides a strong defense against external attackers and should be set to Enabled in situations in which you require complete protection from external attacks, such as the outbreak of a new network worm. If you set this policy setting to Disabled, Windows Firewall will be able to apply other policy settings that allow unsolicited incoming messages.

Impact:

Many environments contain applications and services that must be allowed to receive inbound unsolicited communications as part of their normal operation. Such environments may need to configure the Windows Firewall: Do not allow exceptions setting to Disabled to allow those applications and services to run properly. However, before you configure this policy setting, you should test the environment to determine exactly what communications need to be allowed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e:DoNotAllowExceptions
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Do not allow
exceptions
```

References:

1. CCE-16593-6

ARCHIVE

1.2.1.1.1.1.13 Configure 'Windows Firewall: Protect all network connections' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting enables Windows Firewall, which replaces Internet Connection Firewall on all computers that run Windows Vista.

Rationale:

If Windows Firewall: Protect all network connections is configured to Disabled, Windows Firewall is turned off and all other settings for Windows Firewall are ignored. This exposes the computer to potential network-based attacks.

Impact:

None, this is the default configuration. If you enable this policy setting, Windows Firewall runs and ignores the setting for Computer Configuration\Administrative Templates\Network\Network Connections \Prohibit use of Internet Connection Firewall on your DNS domain network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\StandardProfil
e:EnableFirewall
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Standard Profile\Windows Firewall: Protect all
network connections
```

References:

1. CCE-16760-1

ARCHIVE

1.2.1.1.1.2 Domain Profile

ARCHIVE

1.2.1.1.1.2.1 Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you avoid the use of this setting, unless required by your environment and your organization's business requirements. This policy setting allows a computer to receive unsolicited Plug and Play messages that are sent by network devices, such as routers with built-in firewalls. To receive these messages, Windows Firewall opens TCP port 2869 and UDP port 1900.

Rationale:

Blocking UPnP network traffic effectively reduces the attack surface of computers in your environment.

Impact:

If you enable the Windows Firewall: Allow inbound UPnP framework exceptions setting, Windows Firewall opens these ports so that the computer can receive Plug and Play messages. You must specify the IP addresses or subnets from which these inbound messages are allowed. If you disable this policy setting, Windows Firewall blocks these ports and prevents the computer from receiving Plug and Play messages.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
Services\UPnPFramework:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow inbound
UPnP framework exceptions
```

References:

1. CCE-16829-4

ARCHIVE

1.2.1.1.1.2.2 Configure 'Windows Firewall: Do not allow exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you avoid the use of this setting, unless required by your environment and your organization's business requirements. This policy setting caused Windows Firewall to block all unsolicited incoming messages. It overrides all other Windows Firewall settings that allow such messages. If you enable this policy setting in the Windows Firewall item in Control Panel, the Don't allow exceptions check box is selected and administrators cannot clear it.

Rationale:

This policy setting provides a strong defense against external attackers and should be set to Enabled in situations in which you require complete protection from external attacks, such as the outbreak of a new network worm. If you set this policy setting to Disabled, Windows Firewall will be able to apply other policy settings that allow unsolicited incoming messages.

Impact:

Many environments contain applications and services that must be allowed to receive inbound unsolicited communications as part of their normal operation. Such environments may need to configure the Windows Firewall: Do not allow exceptions setting to Disabled to allow those applications and services to run properly. However, before you configure this policy setting, you should test the environment to determine exactly what communications need to be allowed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:
DoNotAllowExceptions
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Do not allow
exceptions
```

References:

1. CCE-17582-8

ARCHIVE

1.2.1.1.1.2.3 Configure 'Windows Firewall: Allow local program exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls whether administrators can use the Windows Firewall component in Control Panel to define a local program exceptions list.

Rationale:

Granting program exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you disable this policy setting, administrators will not be able to define a local program exceptions list; also, this configuration ensures that program exceptions only come from Group Policy. If this policy setting is enabled, local administrators are allowed to use Control Panel to define program exceptions locally. For enterprise client computers, there may be conditions that justify local program exceptions. These conditions may include applications that were not analyzed when the organization's firewall policy was created or new applications that require nonstandard port configuration. If you choose to enable the Windows Firewall: Allow local program exceptions setting for such situations, remember that the attack surface of the affected computers is increased.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
AuthorizedApplications:AllowUserPrefMerge
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow local
program exceptions
```

References:

1. CCE-17446-6

ARCHIVE

1.2.1.1.1.2.4 Configure 'Windows Firewall: Allow local port exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

The Windows Firewall port exceptions list should be defined by Group Policy, which allows you to centrally manage and deploy your port exceptions and ensure that local administrators do not create less secure settings.

Rationale:

Granting port exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you enable the Windows Firewall: Define inbound port exceptions setting, you can view and change the port exceptions list that is defined by Group Policy. To view and modify the port exceptions list, configure the setting to Enabled and then click the Show button. Note that if you type an invalid definition string, Windows Firewall adds it to the list without checking for errors, which means that you can accidentally create multiple entries for the same port with Scope or Status values that conflict. If you disable the Windows Firewall: Define inbound port exceptions setting, the port exceptions list that is defined by Group Policy is deleted but other settings can continue to open or block ports. Also, if a local port exceptions list exists, it is ignored unless you enable the Windows Firewall: Allow local port exceptions setting. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
GloballyOpenPorts:AllowUserPrefMerge
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow local
port exceptions
```

References:

1. CCE-17067-0

ARCHIVE

1.2.1.1.1.2.5 Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Many organizations take advantage of remote computer administration in their daily operations. To provide flexibility for remote administration, the Windows Firewall: Allow inbound remote administration exception setting is available. If you enable this setting, computers in your environment should accept remote administration requests from as few computers as possible. To maximize the protection provided by Windows Firewall, make sure to specify only the necessary IP addresses and subnets of computers that are used for remote administration.

Rationale:

Some attacks have exploited the ports that are typically used by remote administration programs; Windows Firewall can help block these ports.

Impact:

If this policy setting is enabled, the computer can receive the unsolicited incoming messages that are associated with remote administration on TCP ports 135 and 445. This policy setting also allows Svchost.exe and Lsass.exe to receive unsolicited incoming messages and allows hosted services to open additional dynamically-assigned ports, typically in the range of 1024 to 1034 but potentially anywhere from 1024 to 65535. If you enable this policy setting, you need to specify the IP addresses or subnets from which these incoming messages are allowed. If you configure the Windows Firewall: Allow inbound remote administration exception setting to Disabled, Windows Firewall makes none of the described exceptions. The impact of configuring this policy setting to Disabled may be unacceptable to many organizations because many remote administration tools and tools that scan for vulnerabilities will fail.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
RemoteAdminSettings:Enabled
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow inbound
remote administration exception
```

References:

1. CCE-17574-5

ARCHIVE

1.2.1.1.1.2.6 Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting creates an exception that allows file and printer sharing. It configures Windows Firewall to open UDP ports 137 and 138 and TCP ports 139 and 445.

Rationale:

Enabling access to file and printer sharing could cause a user to unknowingly expose sensitive data. Additionally, there have been vulnerabilities in the resource sharing features that have been remotely exploitable.

Impact:

If you enable this policy setting, Windows Firewall opens these ports so that the computer can receive print jobs and requests for access to shared files. You must specify the IP addresses or subnets from which such messages are allowed. If you disable the Windows Firewall: Allow inbound file and printer sharing exception setting, Windows Firewall blocks these ports and prevents the computer from sharing files and printers. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
Services\FileAndPrint:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow inbound
file and printer sharing exception
```

References:

1. CCE-16675-1

ARCHIVE

1.2.1.1.1.2.7 Configure 'Windows Firewall: Allow ICMP exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting defines the set of Internet Control Message Protocol (ICMP) message types that Windows Firewall allows. Utilities can use ICMP messages to determine the status of other computers. For example, Ping uses the echo request message. If you configure the Windows Firewall: Allow ICMP exceptions setting to Enabled, you must specify which ICMP message types Windows Firewall allows the computer to send or receive. When you configure this policy setting to Disabled, Windows Firewall blocks all unsolicited inbound ICMP message types and the listed outbound ICMP message types. As a result, utilities that rely on ICMP may fail. Many attacker tools take advantage of computers that accept ICMP message types and use these messages to mount a variety of attacks. However, some applications require some ICMP messages in order to function properly. Also, ICMP messages are used to estimate network performance when Group Policy is downloaded and processed; if ICMP messages are blocked, Group Policy may not be applied to affected systems. For that reason, it is recommended that you configure the Windows Firewall: Allow ICMP exceptions setting to Disabled whenever possible. If your environment requires some ICMP messages to get through Windows Firewall, configure this policy setting with the appropriate message types. Whenever the computer is on an untrusted network, the Windows Firewall: Allow ICMP exceptions setting should be configured to Disabled. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

Rationale:

Many attacker tools take advantage of computers that accept ICMP message types and use these messages to mount a variety of attacks.

ARCHIVE

Impact:

If you configure the Windows Firewall: Allow ICMP exceptions setting to Enabled, you must specify which ICMP message types Windows Firewall allows the computer to send or receive. When you configure this policy setting to Disabled, Windows Firewall blocks all unsolicited inbound ICMP message types and the listed outbound ICMP message types. As a result, utilities that rely on ICMP may fail. Some applications require some ICMP messages in order to function properly. Also, ICMP messages are used to estimate network performance when Group Policy is downloaded and processed; if ICMP messages are blocked, Group Policy may not be applied to affected systems. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
IcmpSettings:AllowInboundRouterRequest
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow ICMP
exceptions
```

References:

1. CCE-16671-0

ARCHIVE

1.2.1.1.1.2.8 Configure 'Windows Firewall: Prohibit notifications' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Unless required by your environment and your organization's business requirements you may wish to avoid using this setting because the notifications can help users to understand why certain applications aren't working as expected. Windows Firewall can display notifications to users when a program requests that Windows Firewall add the program to the program exceptions list. This situation occurs when programs attempt to open a port and are not allowed to do so because of current Windows Firewall rules. The Windows Firewall: Prohibit notifications setting determines whether these settings are shown to the users.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity.

Impact:

If you configure this policy setting to Enabled, Windows Firewall prevents the display of these notifications. If you configure it to Disabled, Windows Firewall allows the display of these notifications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:
DisableNotifications
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Prohibit
notifications
```

References:

1. CCE-16710-6

ARCHIVE

1.2.1.1.1.2.9 Configure 'Windows Firewall: Define inbound port exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Microsoft recommends that you avoid the use of this setting, unless required by your environment and your organization's business requirements; specifying allowed applications using the Define inbound program exceptions is usually a more secure approach. The Windows Firewall port exceptions list should be defined by Group Policy, which allows you to centrally manage and deploy your port exceptions and ensure that local administrators do not create less secure settings.

Rationale:

Granting port exeptions could expose the computer to network-based attacks, however not allowing any exceptions is likely to break some applications such as computer management tools

Impact:

If you enable the Windows Firewall: Define inbound port exceptions setting, you can view and change the port exceptions list that is defined by Group Policy. To view and modify the port exceptions list, configure the setting to Enabled and then click the Show button. Note that if you type an invalid definition string, Windows Firewall adds it to the list without checking for errors, which means that you can accidentally create multiple entries for the same port with Scope or Status values that conflict. If you disable the Windows Firewall: Define inbound port exceptions setting, the port exceptions list that is defined by Group Policy is deleted but other settings can continue to open or block ports. Also, if a local port exceptions list exists, it is ignored unless you enable the Windows Firewall: Allow local port exceptions setting. Note If any policy setting opens TCP port 445, Windows Firewall allows inbound ICMP echo request messages (such as those sent by the Ping utility), even if the Windows Firewall: Allow ICMP exceptions policy setting would block them. Policy settings that can open TCP port 445 include Windows Firewall: Allow inbound file and printer sharing exception, Windows Firewall: Allow inbound remote administration exception, and Windows Firewall: Define inbound port exceptions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
GloballyOpenPorts:Enabled
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Define inbound
port exceptions
```

References:

1. CCE-16715-5

ARCHIVE

1.2.1.1.1.2.10 Configure 'Windows Firewall: Protect all network connections' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting enables Windows Firewall, which replaces Internet Connection Firewall on all computers that run Windows Vista.

Rationale:

If Windows Firewall: Protect all network connections is configured to Disabled, Windows Firewall is turned off and all other settings for Windows Firewall are ignored. This exposes the computer to potential network-based attacks.

Impact:

None, this is the default configuration. If you enable this policy setting, Windows Firewall runs and ignores the setting for Computer Configuration\Administrative Templates\Network\Network Connections \Prohibit use of Internet Connection Firewall on your DNS domain network.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:
EnableFirewall
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Protect all
network connections
```

References:

1. CCE-17362-5

ARCHIVE

1.2.1.1.1.2.11 Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting helps prevent a computer from receiving unicast responses to its outgoing multicast or broadcast messages.

Rationale:

Typically, you would not want to receive unicast responses to multicast or broadcast messages. Such responses can indicate a denial of service (DoS) attack or an attempt to probe a known computer.

Impact:

Note This policy setting has no effect if the unicast message is a response to a DHCP broadcast message that is sent by the computer. Windows Firewall always permits those DHCP responses. However, this policy setting can interfere with the NetBIOS messages that detect name conflicts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile:
DisableUnicastResponsesToMulticastBroadcast
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Prohibit
unicast response to multicast or broadcast requests
```

References:

1. CCE-16609-0

ARCHIVE

1.2.1.1.1.2.12 Configure 'Windows Firewall: Define inbound program exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Some applications may need to open and use network ports that are not typically allowed by Windows Firewall. The Windows Firewall: Define inbound program exceptions setting allows you to view and change the program exceptions list that is defined by Group Policy.

Rationale:

There is risk that inbound exceptions will be made to programs that have software vulnerabilities, however, if exceptions are not allowed then management programs and other useful applications will fail.

Impact:

If this policy setting is Enabled you can view and change the program exceptions list. If you add a program to this list and set its status to Enabled, that program can receive unsolicited incoming messages on any port that it requests Windows Firewall to open, even if that port is blocked by another setting. If you configure this policy setting to Disabled, the program exceptions list that is defined by Group Policy is deleted. Note If you type an invalid definition string, Windows Firewall adds it to the list without checking for errors. Because the entry is not checked, you can add programs that you have not installed yet. You can also accidentally create multiple exceptions for the same program with Scope or Status values that conflict.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
AuthorizedApplications:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Define inbound
program exceptions
```

Default Value:

Disabled

References:

1. CCE-16596-9

ARCHIVE

1.2.1.1.1.2.13 Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Many organizations use Remote Desktop connections in their normal troubleshooting procedures or operations. To provide flexibility for remote administration, the Windows Firewall: Allow inbound Remote Desktop exceptions setting is available.

Rationale:

Some attacks have exploited the ports that are typically used by Remote Desktop.

Impact:

If you enable this policy setting, Windows Firewall opens TCP port 3389 for inbound connections. You must also specify the IP addresses or subnets from which these inbound messages are allowed. If you disable this policy setting, Windows Firewall blocks this port and prevents the computer from receiving Remote Desktop requests. If an administrator adds this port to a local port exceptions list in an attempt to open it, Windows Firewall does not open the port. Computers in your environment should accept Remote Desktop requests from as few computers as possible.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsFirewall\DomainProfile\
Services\RemoteDesktop:Enabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Network\Network
Connections\Windows Firewall\Domain Profile\Windows Firewall: Allow inbound
Remote Desktop exceptions
```

References:

1. CCE-16825-2

ARCHIVE

1.2.2 System

1.2.2.1 Remote Assistance

ARCHIVE

1.2.2.1.1 Configure 'Offer Remote Assistance' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether a support person or an IT expert administrator can offer remote assistance to computers in your environment if a user does not explicitly request assistance first through a channel, such as e-mail, or Instant Messenger. Note The expert cannot connect to the computer unannounced or control it without permission from the user. When the expert tries to connect, the user can still choose to deny the connection or give the expert view-only privileges. The user must explicitly click the Yes button to allow the expert to remotely control the workstation after the Offer Remote Assistance setting is configured to Enabled. If this policy setting is enabled the following options are available: . Allow helpers to only view the computer . Allow helpers to remotely control the computer When you configure this policy setting, you can also specify a list of users or user groups known as helpers who may offer remote assistance. To configure the list of helpers 1. In the Offer Remote Assistance setting configuration window, click Show. A new window will open in which you can enter helper names. 2. Add each user or group to the Helper list in one of the following formats: . <Domain Name>\<User Name> . <Domain Name>\<Group Name> If this policy setting is disabled or not configured, users and or groups will not be able to offer unsolicited remote assistance to computer users in your environment.

Rationale:

A user might be tricked and accept an unsolicited Remote Assistance offer from a malicious user.

Impact:

Help desk and support personnel will not be able to proactively offer assistance, although they can still respond to user assistance requests.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal
Services:fAllowUnsolicited
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Remote
Assistance\Offer Remote Assistance
```

References:

1. CCE-3617-8

ARCHIVE

1.2.2.1.2 Configure 'Solicited Remote Assistance' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines whether remote assistance may be solicited from computers running Windows operating systems in your environment. You can enable this policy setting to allow users to solicit remote assistance from IT expert administrators. If the Solicited Remote Assistance setting is enabled, the following options are available: . Allow helpers to remotely control the computer . Allow helpers to only view the computer Also, the following options are available to configure the amount of time that a user help request remains valid: . Maximum ticket time (value): . Maximum ticket time (units): hours, minutes or days When a ticket (help request) expires, the user must send another request before an expert can connect to the computer. If you disable the Solicited Remote Assistance setting, users cannot send help requests and the expert cannot connect to their computers. If the Solicited Remote Assistance setting is not configured, users can configure solicited remote assistance through the Control Panel. The following settings are enabled by default in the Control Panel: Solicited Remote Assistance, Buddy support, and Remote control. The value for the Maximum ticket time is set to 30 days. If this policy setting is disabled, no one will be able to access Windows Vista client computers across the network.

Rationale:

There is slight risk that a rogue administrator will gain access to another user's desktop session, however, they cannot connect to a user's computer unannounced or control it without permission from the user. When an expert tries to connect, the user can still choose to deny the connection or give the expert view-only privileges. The user must explicitly click the Yes button to allow the expert to remotely control the workstation.

ARCHIVE

Impact:

If you enable this policy, users on this computer can use e-mail or file transfer to ask someone for help. Also, users can use instant messaging programs to allow connections to this computer, and you can configure additional Remote Assistance settings. If you disable this policy, users on this computer cannot use e-mail or file transfer to ask someone for help. Also, users cannot use instant messaging programs to allow connections to this computer. If you don't configure this policy, users can enable or disable Solicited (Ask for) Remote Assistance themselves in System Properties in Control Panel. Users can also configure Remote Assistance settings. If you enable this policy setting, you have two ways to allow helpers to provide Remote Assistance: "Allow helpers to only view the computer" or "Allow helpers to remotely control the computer." The "Maximum ticket time" setting sets a limit on the amount of time that a Remote Assistance invitation created by using e-mail or file transfer can remain open. The "Select the method for sending e-mail invitations" setting specifies which e-mail standard to use to send Remote Assistance invitations. Depending on your e-mail program, you can use either the Mailto standard (the invitation recipient connects through an Internet link) or the SMAPI (Simple MAPI) standard (the invitation is attached to your e-mail message). This setting is not available in Windows Vista since SMAPI is the only method supported. If you enable this policy you should also enable appropriate firewall exceptions to allow Remote Assistance communications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal
Services:fAllowToGetHelp
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Remote
Assistance\Solicited Remote Assistance
```

References:

1. CCE-3599-8

ARCHIVE

1.2.2.2 Internet Communication Management

1.2.2.2.1 Internet Communication settings

ARCHIVE

1.2.2.2.1.1 Configure 'Turn off Windows Update device driver searching' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether Windows will search Windows Update for device drivers when no local drivers for a device are present. Note See also Turn off Windows Update device driver search prompt in Administrative Templates/System, which governs whether an administrator is prompted before Windows Update is searched for device drivers if a driver is not found locally.

Rationale:

If users are able to download and install device drivers there is a small chance that they will install a driver that reduces system stability. There is an even smaller possibility that they will install a driver that includes malicious code. These risks are very low because Microsoft requires vendors to test drivers extensively before they can be published on Windows Update.

Impact:

Users will not be able to download new or updated device drivers from Windows Update.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\DriverSearching:DontSe
archWindowsUpdate
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off Windows Update device
driver searching
```

Default Value:

Disabled

References:

1. CCE-17157-9

ARCHIVE

1.2.2.2.1.2 Configure 'Turn off Search Companion content file updates' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether Search Companion should automatically download content updates during local and Internet searches.

Rationale:

There is a small risk that users will unknowingly reveal sensitive information because of the topics they are searching for. This risk is very low because even if this setting is enabled users still must submit search queries to the desired search engine in order to perform searches.

Impact:

Internet searches will still send the search text and information about the search to Microsoft and the chosen search provider. If you select Classic Search, the Search Companion feature will be unavailable. You can select Classic Search by clicking Start, Search, Change Preferences, and then Change Internet Search Behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\SearchCompanion:DisableContent
FileUpdates
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off Search Companion content
file updates
```

References:

1. CCE-17531-5

ARCHIVE

1.2.2.2.1.3 Configure 'Turn off Internet download for Web publishing and online ordering wizards' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls whether Windows will download a list of providers for the Web publishing and online ordering wizards.

Rationale:

Although the risk is minimal, enabling this setting will reduce the possibility of a user unknowingly downloading malicious content through this feature.

Impact:

If this policy setting is enabled, Windows is prevented from downloading providers; only the service providers cached in the local registry will display.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explore
r:NoWebServices
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off Internet download for Web
publishing and online ordering wizards
```

References:

1. CCE-17382-3

ARCHIVE

1.2.2.2.1.4 Configure 'Turn off the Windows Messenger Customer Experience Improvement Program' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used.

Rationale:

Large enterprise environments may not want to have information collected from managed client computers.

Impact:

Microsoft uses information collected through the Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Messenger\Client:CEIP
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off the Windows Messenger
Customer Experience Improvement Program
```

References:

1. CCE-17523-2

ARCHIVE

1.2.2.2.1.5 Configure 'Turn off printing over HTTP' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to disable the client computer's ability to print over HTTP, which allows the computer to print to printers on the intranet as well as the Internet.

Rationale:

Information that is transmitted over HTTP through this capability is not protected and can be intercepted by malicious users. For this reason, it is not often used in enterprise environments.

Impact:

If you enable this policy setting, the client computer will not be able to print to Internet printers over HTTP. This policy setting affects the client side of Internet printing only. Regardless of how it is configured, a computer could act as an Internet Printing server and make its shared printers available through HTTP.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows
NT\Printers:DisableHTTPPrinting
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off printing over HTTP
```

References:

1. CCE-17527-3

ARCHIVE

1.2.2.2.1.6 Configure 'Turn off the "Publish to Web" task for files and folders' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether the tasks Publish this file to the Web, Publish this folder to the Web, and Publish the selected items to the Web are available from File and Folder Tasks in Windows folders.

Rationale:

Users may publish confidential or sensitive information to a public service outside of the control of the organization.

Impact:

The Web Publishing wizard is used to download a list of providers and allow users to publish content to the Web.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explore
r:NoPublishingWizard
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off the "Publish to Web" task
for files and folders
```

References:

1. CCE-17518-2

ARCHIVE

1.2.2.2.1.7 Configure 'Turn off downloading of print drivers over HTTP' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls whether the computer can download print driver packages over HTTP. To set up HTTP printing, printer drivers that are not available in the standard operating system installation might need to be downloaded over HTTP.

Rationale:

Users might download drivers that include malicious code.

Impact:

This policy setting does not prevent the client computer from printing to printers on the intranet or the Internet over HTTP. It only prohibits drivers that are not already installed locally from downloading.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows
NT\Printers:DisableWebPnPDownload
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Internet Communication
Management\Internet Communication settings\Turn off downloading of print
drivers over HTTP
```

References:

1. CCE-17377-3

ARCHIVE

1.2.2.3 Group Policy

ARCHIVE

1.2.2.3.1 Configure 'Registry policy processing' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines when registry policies are updated. It affects all policies in the Administrative Templates folder, and any other policies that store values in the registry. If this policy setting is enabled, the following options are available: . Do not apply during periodic background processing. . Process even if the Group Policy objects have not changed. Some settings that are configured through the Administrative Templates are made in areas of the registry that are accessible to users. User changes to these settings will be overwritten if this policy setting is enabled.

Rationale:

You can enable this setting and then select the Process even if the Group Policy objects have not changed option to ensure that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes that might have been configured locally are forced to match the domainbased Group Policy settings again.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}:NoBackgroundPolicy
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Group Policy\Registry
policy processing
```

References:

1. CCE-8043-2

ARCHIVE

1.2.2.3.2 Configure 'Do not apply during periodic background processing' (Manual)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

If this policy setting is enabled, the following options are available: . Do not apply during periodic background processing. . Process even if the Group Policy objects have not changed.

Rationale:

You can enable this setting and then select the Process even if the Group Policy objects have not changed option to ensure that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes that might have been configured locally are forced to match the domainbased Group Policy settings again.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}:NoBackgroundPolicy
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Group Policy:Do not
apply during periodic background processing
```

References:

1. CCE-8043-2

ARCHIVE

1.2.2.3.3 Configure 'Process even if the Group Policy objects have not changed' (Manual)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

If this policy setting is enabled, the following options are available: . Do not apply during periodic background processing. . Process even if the Group Policy objects have not changed.

Rationale:

You can enable this setting and then select the Process even if the Group Policy objects have not changed option to ensure that the policies will be reprocessed even if none have been changed. This way, any unauthorized changes that might have been configured locally are forced to match the domainbased Group Policy settings again.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}:NoBackgroundPolicy
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Group Policy:Process
even if the Group Policy objects have not changed
```

References:

1. CCE-8043-2

ARCHIVE

1.2.2.4 Remote Procedure Call

ARCHIVE

1.2.2.4.1 Set 'RPC Endpoint Mapper Client Authentication' to 'Enabled' (Manual)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

If you enable this policy setting, client computers that communicate with this computer are forced to provide authentication before RPC communication can be established. By default, RPC clients do not use authentication to communicate with the RPC Server Endpoint Mapper Service when they request the endpoint of a server.

Rationale:

Anonymous access to RPC services could result in accidental disclosure of information to unauthenticated users.

Impact:

RPC clients will be forced to authenticate before they can begin communicating with the desired RPC service, this means that anonymous access will not be available and RPC clients that do not support authentication will fail.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows
NT\Rpc:EnableAuthEpResolution
```

Remediation:

Configure the following Group Policy setting to `Enabled`:

```
Computer Configuration\Administrative Templates\System\Remote Procedure
Call\RPC Endpoint Mapper Client Authentication
```

Default Value:

Disabled

References:

1. CCE-8151-3

ARCHIVE

1.2.2.4.2 Set 'Restrictions for Unauthenticated RPC clients' to 'Enabled:Authenticated' (Automated)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting configures the RPC Runtime on an RPC server to restrict unauthenticated RPC clients from connecting to the RPC server. A client will be considered an authenticated client if it uses a named pipe to communicate with the server or if it uses RPC Security. RPC interfaces that have specifically asked to be accessible by unauthenticated clients may be exempt from this restriction, depending on the selected value for this policy.

Rationale:

Unauthenticated RPC communication can create a security vulnerability.

Impact:

RPC applications that do not authenticate unsolicited inbound connection requests may not work properly when this configuration is applied. Ensure you test applications before you deploy this policy setting throughout your environment. Although the Authenticated value for this policy setting is not completely secure, it can be useful for providing application compatibility in your environment.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows
NT\Rpc:RestrictRemoteClients
```

Remediation:

Configure the following Group Policy setting to `Enabled:Authenticated`:

```
Computer Configuration\Administrative Templates\System\Remote Procedure
Call\Restrictions for Unauthenticated RPC clients
```

Default Value:

Disabled

ARCHIVE

References:

1. CCE-8527-4

ARCHIVE

1.2.2.5 Logon

ARCHIVE

1.2.2.5.1 Configure 'Do not process the legacy run list' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting causes the run list, which is a list of programs that Windows runs automatically when it starts, to be ignored. The customized run lists for Windows Vista are stored in the registry at the following locations: . HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run . HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run You can enable the Do not process the legacy run list setting to help prevent a malicious user from running a program each time Windows Vista starts, which could compromise data on the computer or cause other harm. When this policy setting is enabled, certain system programs are prevented from running, such as antivirus software, and software distribution and monitoring software. It is recommended to evaluate the threat level to your environment before you determine whether to use this policy setting for your organization.

Rationale:

A malicious user could configure a program to be run each time Windows starts that could compromise data on the computer or cause other harm.

Impact:

If you enable this setting, certain computer programs such as antivirus software and software distribution and monitoring software are also prevented from execution. You should evaluate the threat level to your environment that this setting is designed to safeguard against before you decide on a strategy to use this setting for your organization.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explore
r:DisableLocalMachineRun
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Logon\Do not process
the legacy run list
```

Default Value:

Disabled

References:

1. CCE-17034-0

ARCHIVE

1.2.2.5.2 Configure 'Do not process the run once list' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting causes the run once list, which is the list of programs that Windows Vista runs automatically when it starts, to be ignored. This policy setting differs from the Do not process the legacy run list setting in that programs on this list will run once the next time the client computer restarts and an administrator logs on. Setup and installation programs are sometimes added to this list to complete installations after a client computer restarts. If you enable this policy setting, attackers generally cannot use the run once list to launch rogue applications, which was a common method of attack in the past. A malicious user can exploit the run once list to install a program that may compromise the security of Windows Vistabased client computers, however since editing this list requires administrator privileges the importance of configuring this setting is not high.

Rationale:

A malicious user can exploit the run once list to install a program that may compromise the security of Windows clients.

Impact:

If you enable the Do not process the run once list setting you should experience minimal functionality loss for users in your environment, especially if the clients have been configured with all of your organization's standard software before you apply this setting through Group Policy. However, this configuration may prevent some setup and installation programs, such as Internet Explorer, from working properly.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explore
r:DisableLocalMachineRunOnce
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\System\Logon\Do not process
the run once list
```

Default Value:

Disabled

References:

1. CCE-17148-8

ARCHIVE

1.2.3 Windows Components

1.2.3.1 AutoPlay Policies

ARCHIVE

1.2.3.1.1 Set 'Turn off Autoplay' to 'Enabled:All drives' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Autoplay starts to read from a drive as soon as you insert media in the drive, which causes the setup file for programs or audio media to start immediately. An attacker could use this feature to launch a program to damage the computer or data on the computer. You can enable the Turn off Autoplay setting to disable the Autoplay feature. Autoplay is disabled by default on some removable drive types, such as floppy disk and network drives, but not on CD-ROM drives. Note You cannot use this policy setting to enable Autoplay on computer drives in which it is disabled by default, such as floppy disk and network drives.

Rationale:

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

Impact:

Users will have to manually launch setup or installation programs that are provided on removable media.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explore
r:NoDriveTypeAutoRun
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Enabled`. Then set the available option to `All drives`.

```
Computer Configuration\Administrative Templates\Windows Components\AutoPlay
Policies\Turn off Autoplay
```

Default Value:

Not Configured

ARCHIVE

References:

1. CCE-3597-2

ARCHIVE

1.2.3.2 Windows Update

ARCHIVE

1.2.3.2.1 Configure 'Configure Automatic Updates' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If you configure this policy setting to Enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them. After you configure this policy setting to Enabled, select one of the following three options in the Configure Automatic Updates Properties dialog box to specify how the service will work: . Notify before downloading any updates and notify again before installing them. . Download the updates automatically and notify when they are ready to be installed. (Default setting) . Automatically download updates and install them on the schedule specified below. If you disable this policy setting, you will need to download and manually install any available updates from Windows Update.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

Critical operating system updates and service packs will automatically download and install at 3:00 A.M. daily.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU:NoAut
oUpdate
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\Configure Automatic Updates
```

Default Value:

Download the updates automatically and notify when they are ready to be installed

References:

1. CCE-3740-8

ARCHIVE

1.2.3.2.2 Configure 'Specify intranet Microsoft update service location' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to specify an intranet server to host updates from the Microsoft Update Web site. You can then use this update service location to automatically update computers on your network. The Automatic Updates client will search this service for updates that apply to the computers on your network. To use the Specify intranet Microsoft update service location setting, you must set two server name values: the server from which the Automatic Updates client detects and downloads updates, and the server to which updated workstations upload statistics. You can set both values to be the same server. If you enable the Specify intranet Microsoft update service location setting, the Automatic Updates client will connect to the specified intranet Microsoft update service server (instead of Windows Update) to search for and download updates. This configuration allows end users in your organization to avoid firewall issues, and provides you with an opportunity to test updates before you deploy them. If you disable or do not configure this policy setting, the Automatic Updates client will connect directly to the Windows Update site on the Internet (if Automatic Updates is not disabled by Group Policy or user preference).

Rationale:

By default, Automatic Updates will attempt to download updates from the Microsoft Windows Update Web site. Some organizations want to verify that all new updates are compatible with their particular environment before they are deployed. Also, if you configure an internal Software Update Services (SUS) server you will help reduce the load on perimeter firewalls, routers, and proxy servers, as well as the load on external network links.

Impact:

Critical updates and service packs will have to be proactively managed by the organization's IT staff.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate:WUServer
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\Specify intranet Microsoft update service location
```

Default Value:

Disabled

References:

1. CCE-17311-2

ARCHIVE

1.2.3.2.3 Configure 'Set the intranet statistics server' (Manual)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting allows you to specify an intranet server to host updates from the Microsoft Update Web site.

Rationale:

By default, Automatic Updates will attempt to download updates from the Microsoft Windows Update Web site. Some organizations want to verify that all new updates are compatible with their particular environment before they are deployed. Also, if you configure an internal Software Update Services (SUS) server you will help reduce the load on perimeter firewalls, routers, and proxy servers, as well as the load on external network links.

Impact:

Critical updates and service packs will have to be proactively managed by the organization's IT staff.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate:WUServer
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update:Set the intranet statistics server
```

Default Value:

Disabled

References:

1. CCE-17311-2

ARCHIVE

1.2.3.2.4 Configure 'Set the intranet update service for detecting updates' (Manual)

Profile Applicability:

- Level 1 - Domain Controller
- Level 1 - Member Server

Description:

This policy setting allows you to specify an intranet server to host updates from the Microsoft Update Web site.

Rationale:

By default, Automatic Updates will attempt to download updates from the Microsoft Windows Update Web site. Some organizations want to verify that all new updates are compatible with their particular environment before they are deployed. Also, if you configure an internal Software Update Services (SUS) server you will help reduce the load on perimeter firewalls, routers, and proxy servers, as well as the load on external network links.

Impact:

Critical updates and service packs will have to be proactively managed by the organization's IT staff.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate:WUServer
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update:Set the intranet update service for detecting updates
```

Default Value:

Disabled

References:

1. CCE-17311-2

ARCHIVE

1.2.3.2.5 Configure 'No auto-restart with logged on users for scheduled automatic updates installations' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies that Automatic Updates will wait for computers to be restarted by the users who are logged on to them to complete a scheduled installation. If you enable the No auto-restart for scheduled Automatic Updates installations setting, Automatic Updates does not restart computers automatically during scheduled installations. Instead, Automatic Updates notifies users to restart their computers to complete the installations. You should note that Automatic Updates will not be able to detect future updates until restarts occur on the affected computers. If you disable or do not configure this setting, Automatic Updates will notify users that their computers will automatically restart in 5 minutes to complete the installations. The possible values for the No auto-restart for scheduled Automatic Updates installations setting are: . Enabled . Disabled . Not Configured Note: This setting applies only when you configure Automatic Updates to perform scheduled update installations. If you configure the Configure Automatic Updates setting to Disabled, this setting has no effect.

Rationale:

Sometimes updates require updated computers to be restarted to complete an installation. If the computer cannot restart automatically, then the most recent update will not completely install and no new updates will download to the computer until it is restarted.

Impact:

If you enable this policy setting, the operating systems on the servers in your environment will restart themselves automatically. For critical servers this could lead to temporary but unexpected, DoS conditions.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU:NoAut
oRebootWithLoggedOnUsers
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\No auto-restart with logged on users for scheduled automatic updates
installations
```

Default Value:

Enabled

References:

1. CCE-3277-1

ARCHIVE

1.2.3.2.6 Configure 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to manage whether the Install Updates and Shut Down option is displayed in the Shut Down Windows dialog box. This policy setting works in conjunction with the following Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows Dialog box setting.

Rationale:

Updates are important for maintaining the ongoing security of a computer, therefore this setting should not be enabled.

Impact:

If you disable this policy setting, the Install Updates and Shut Down option will display in the Shut Down Windows dialog box if updates are available when the user selects the Shut Down option in the Start menu.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU:NoAUS
hutdownOption
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\Do not display 'Install Updates and Shut Down' option in Shut Down
Windows dialog box
```

Default Value:

Disabled

ARCHIVE

References:

1. CCE-17307-0

ARCHIVE

1.2.3.2.7 Configure 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to manage whether the 'Install Updates and Shut Down' option is allowed to be the default choice in the Shut Down Windows dialog. Note that this policy setting has no impact if the Computer Configuration\Administrative Templates\Windows Components\Windows Update\Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box policy setting is enabled.

Rationale:

Updates are important for maintaining the ongoing security of a computer, therefore this setting should not be enabled.

Impact:

If you enable this policy setting, the user's last shut down choice (Hibernate, Restart, etc.) is the default option in the Shut Down Windows dialog box, regardless of whether the 'Install Updates and Shut Down' option is available in the 'What do you want the computer to do?' list. If you disable or do not configure this policy setting, the 'Install Updates and Shut Down' option will be the default option in the Shut Down Windows dialog box if updates are available for installation at the time the user selects the Shut Down option in the Start menu.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU:NoAUA
sDefaultShutdownOption
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\Do not adjust default option to 'Install Updates and Shut Down' in
Shut Down Windows dialog box
```

Default Value:

Disabled

References:

1. CCE-17320-3

ARCHIVE

1.2.3.2.8 Configure 'Reschedule Automatic Updates scheduled installations' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting determines the amount of time before previously scheduled Automatic Update installations will proceed after system startup. If you configure this policy setting to Enabled, a previously scheduled installation will begin after a specified number of minutes when you next start the computer. If you configure this policy setting to Disabled or Not configured, previously scheduled installations will occur during the next regularly scheduled installation time. Note: This policy setting only works when Automatic Updates is configured to perform scheduled update installations. If the Configure Automatic Updates setting is Disabled, the Reschedule Automatic Updates scheduled installations setting has no effect. You can enable the latter two settings to ensure that previously missed installations will be scheduled to install each time the computer restarts.

Rationale:

If Automatic Updates is not forced to wait a few minutes after a restart, computers in your environment might not have enough time to completely start all of their applications and services. If you specify enough time after a restart, new update installations should not conflict with the computer's startup procedures.

Impact:

Automatic Updates will not start until 10 minutes after the computer restarts.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU:Resch
eduleWaitTimeEnabled
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Update\Reschedule Automatic Updates scheduled installations
```

Default Value:

Disabled

References:

1. CCE-3661-6

ARCHIVE

1.2.3.3 Windows Messenger

ARCHIVE

1.2.3.3.1 Configure 'Do not allow Windows Messenger to be run' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

You can enable the setting for Do not allow Windows Messenger to be run to disable Windows Messenger and prevent the program from running. Note: This setting only affects Windows Messenger software included in Windows XP. This setting will not prevent users from running MSN Messenger or Windows Live Messenger.

Rationale:

Because this application has been used for malicious purposes such as spam, the distribution of malicious software, and disclosure of sensitive data, Microsoft recommends to enable this setting.

Impact:

Users will be unable to use Windows Messenger.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Messenger\Client:PreventRun
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Messenger\Do not allow Windows Messenger to be run
```

References:

1. CCE-3658-2

ARCHIVE

1.2.3.4 Remote Desktop Services

1.2.3.4.1 Remote Desktop Connection Client

ARCHIVE

1.2.3.4.1.1 Configure 'Do not allow passwords to be saved' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting helps prevent Terminal Services clients from saving passwords on a computer. Note If this policy setting was previously configured as Disabled or Not configured, any previously saved passwords will be deleted the first time a Terminal Services client disconnects from any server.

Rationale:

An attacker with physical access to the computer may be able to break the protection guarding saved passwords. An attacker who compromises a user's account and connects to their computer could use saved passwords to gain access to additional hosts.

Impact:

If you enable this policy setting, the password saving checkbox is disabled for Terminal Services clients and users will not be able to save passwords.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal
Services:DisablePasswordSaving
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Connection Client\Do not allow passwords to
be saved
```

References:

1. CCE-17047-2

ARCHIVE

1.2.3.4.2 Remote Desktop Session Host

1.2.3.4.2.1 Device and Resource Redirection

ARCHIVE

1.2.3.4.2.1.1 Configure 'Do not allow drive redirection' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting prevents users from sharing the local drives on their client computers to Terminal Servers that they access. Mapped drives appear in the session folder tree in Windows Explorer in the following format: \\TSClient\$ If local drives are shared they are left vulnerable to intruders who want to exploit the data that is stored on them.

Rationale:

Data could be forwarded from the user's Terminal Server session to the user's local computer without any direct user interaction.

Impact:

Drive redirection will not be possible.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal
Services:fDisableCdm
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Session Host\Device and Resource
Redirection\Do not allow drive redirection
```

Default Value:

Disabled

References:

1. CCE-17051-4

ARCHIVE

1.2.3.4.2.2 Connections

ARCHIVE

1.2.3.4.2.2.1 Configure 'Allow users to connect remotely using Remote Desktop Services' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting allows you to control if users can connect to a computer using Terminal Services or Remote Desktop.

Rationale:

Any account with the Allow log on through Terminal Services user right can log on to the remote console of the computer. If you do not restrict access to legitimate users who need to log on to the console of the computer, unauthorized users could download and execute malicious code to elevate their privileges.

Impact:

If this setting is enabled legitimate users will be unable to use Terminal Services or Remote Desktop, this could make it more difficult for help desk technicians to troubleshoot and resove problems remotely. It would also make it impossible to use Terminal Services for hosting shared applications.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal
Services:Not Configured
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Session Host\Connections\Allow users to
connect remotely using Remote Desktop Services
```

Default Value:

Disabled

ARCHIVE

References:

1. CCE-3790-3

ARCHIVE

1.2.3.4.2.3 Security

ARCHIVE

1.2.3.4.2.3.1 Configure 'Set client connection encryption level' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether the computer that is about to host the remote connection will enforce an encryption level for all data sent between it and the client computer for the remote session.

Rationale:

If Terminal Server client connections are allowed that use low level encryption, it is more likely that an attacker will be able to decrypt any captured Terminal Services network traffic.

Impact:

Clients that do not support 128-bit encryption will be unable to establish Terminal Server sessions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal
Services:MinEncryptionLevel
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Session Host\Security\Set client connection
encryption level
```

References:

1. CCE-3812-5

ARCHIVE

1.2.3.4.2.3.2 Configure 'Always prompt for password upon connection' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting specifies whether Terminal Services always prompts the client computer for a password upon connection. You can use this policy setting to enforce a password prompt for users who log on to Terminal Services, even if they already provided the password in the Remote Desktop Connection client. By default, Terminal Services allows users to automatically log on if they enter a password in the Remote Desktop Connection client. The Always prompt client for password upon connection setting is configured to Enabled for both of the environments that are discussed in this guide. Note If you do not configure this policy setting, the local computer administrator can use the Terminal Services Configuration tool to either allow or prevent passwords from being automatically sent.

Rationale:

Users have the option to store both their username and password when they create a new Remote Desktop connection shortcut. If the server that runs Terminal Services allows users who have used this feature to log on to the server but not enter their password, then it is possible that an attacker who has gained physical access to the user's computer could connect to a Terminal Server through the Remote Desktop connection shortcut, even though they may not know the user's password.

Impact:

Users will always have to enter their password when they establish new Terminal Server sessions.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal
Services:fPromptForPassword
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Remote
Desktop Services\Remote Desktop Session Host\Security\Always prompt for
password upon connection
```

References:

1. CCE-3666-5

ARCHIVE

1.2.3.5 Windows Error Reporting

1.2.3.5.1 Advanced Error Reporting Settings

ARCHIVE

1.2.3.5.1.1 Configure 'Report operating system errors' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting controls whether errors are reported. If you configure the Report Errors setting to Enabled, users have the ability to report errors when they occur. Errors can be reported to Microsoft through the Internet or to local file shares in the users' organizations. The possible values for the Report Errors setting are: . Enabled with options for: . Do not display links to any Microsoft provided more information Web sites. If you select this option, no links are displayed for Microsoft Web sites that may have more information about the error message. . Do not collect additional files. If you select this option, no additional files are collected to include in error reports. . Do not collect additional machine data. If you select this option, no additional information about the computer on which the error occurred is included in error reports. . Force queue mode for application errors. If you select this option, users do not have an option to send an error report. Instead, the error is placed in a queue directory, and the next administrator who logs on to the computer decides whether to report the error. . Corporate upload file path. You can select this option to specify a Universal Naming Convention (UNC) path to a file share where error reports are uploaded. This option also enables the Corporate Error Reporting tool. . Replace instances of the word Microsoft. If you select this option, you can customize the error reporting dialog boxes with your organization's name. . Disabled . Not Configured If you do not configure this policy setting, users cannot adjust the setting in the Control Panel. The default configuration is Enabled in Windows XP Professional and Disabled in Windows Server 2003. If the Report Errors setting is enabled, it will override any settings that are made through the Control Panel for error reporting. This configuration will also enforce the default values for any error reporting policies that are not configured.

ARCHIVE

Rationale:

In its default configuration, the Windows Corporate Error Reporting features of Windows XP and Office will send data to Microsoft that some organizations may prefer to keep confidential. The Microsoft privacy statement for Windows Corporate Error Reporting ensures that Microsoft will not misuse data that is collected through Windows Corporate Error Reporting. However, some organizations may want to configure this feature so that no information is transmitted outside of the organization without first being reviewed by a trusted member of the IT team. Conversely, if error reporting is disabled completely, it is more difficult for Microsoft to identify and diagnose new bugs. Organizations that develop their own internal business applications can also take advantage of Windows Corporate Error Reporting to track down problems within their code. A reasonable configuration that ensures privacy and uses Windows Corporate Error Reporting effectively is to set up your own internal Corporate Error Reporting (CER) servers. Configure your client computers to point to these servers when they have error reports to submit. An administrator can then review the reports on the CER server and generate an aggregate report for Microsoft that contains no confidential information.

Impact:

Error reporting will be enabled, and new error reports will be sent to the CER server.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\PCHealth\ErrorReporting:Includ
eKernelFaults
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Error Reporting\Advanced Error Reporting Settings\Report operating system
errors
```

Default Value:

Enabled

References:

1. CCE-17294-0

ARCHIVE

1.2.3.5.2 Configure 'Display Error Notification' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

You can use this policy setting to control whether or not a user may report an error. When this policy setting is enabled, the user will be notified that an error has occurred and provided with access to details about the error. If the Report Errors setting is also enabled, the user will also be provided with a choice of whether to report the error. If you do not enable the Display Error Notification setting, the user is not provided with a choice of whether to report errors. If you enable the Report Errors setting errors will be automatically reported, but the user will not be notified when they occur. It is useful to disable this setting for server computers that do not have interactive users. If you do not configure this setting, users can adjust it through the Control Panel, which is set to Enable notification by default in Windows XP and Disable notification in Windows Server 2003.

Rationale:

If they are provided with the choice of whether or not to report errors, users may not comply with your organization's guidelines on error reporting. If you configure this policy setting to Disabled, users will not see error report messages.

Impact:

Users will not see error report messages when they are generated.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\PCHealth\ErrorReporting:ShowUI
```

ARCHIVE

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Error Reporting\Display Error Notification
```

Default Value:

Disabled

References:

1. CCE-17289-0

ARCHIVE

1.2.3.6 NetMeeting

ARCHIVE

1.2.3.6.1 Configure 'Disable remote Desktop Sharing' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

This policy setting disables the remote desktop sharing feature of NetMeeting. If you enable this policy setting, users will not be able to configure NetMeeting to allow remote control of the local desktop.

Rationale:

When this policy setting is enabled, users will not be able to use the remote desktop sharing feature of NetMeeting.

Impact:

Users will be unable to configure remote desktop sharing through NetMeeting, although they may still be able to use the Windows Remote Assistance and Remote Desktop features if you have left them enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\:Not Configured
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows
Components\NetMeeting\Disable remote Desktop Sharing
```

Default Value:

Disabled

References:

1. CCE-2909-0

ARCHIVE

1.2.3.7 Windows Installer

ARCHIVE

1.2.3.7.1 Set 'Always install with elevated privileges' to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

Directs Windows Installer to use system permissions when it installs any program on the system. This setting extends elevated privileges to all programs. These privileges are usually reserved for programs that have been assigned to the user (offered on the desktop), assigned to the computer (installed automatically), or made available in Add or Remove Programs in Control Panel. This setting lets users install programs that require access to directories that the user might not have permission to view or change, including directories on highly restricted computers. If you disable this setting or do not configure it, the system applies the current user's permissions when it installs programs that a system administrator does not distribute or offer. Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders. Caution: Skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure.

Rationale:

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

Impact:

Windows Installer will apply the current user's permissions when it installs programs, this will prevent standard users from installing applications that affect system-wide configuration items.

ARCHIVE

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer:AlwaysInstal
lElevated
```

Remediation:

To implement the recommended configuration state, set the following Group Policy setting to `Disabled`.

```
Computer Configuration\Administrative Templates\Windows Components\Windows
Installer\Always install with elevated privileges
```

Default Value:

Not Configured

References:

1. CCE-17439-1

ARCHIVE

1.2.3.8 Credential User Interface

ARCHIVE

1.2.3.8.1 Configure 'Require trusted path for credential entry.' (Manual)

Profile Applicability:

- Level 1 - Member Server
- Level 1 - Domain Controller

Description:

If you enable this policy setting, users are required to enter Windows credentials on the Secure Desktop by means of the trusted path mechanism. This means that before entering account and password information to authorize an elevation request, a user first need to press CTRL+ALT+DEL.

Rationale:

Requiring the use of a trusted path helps prevent a Trojan horse or other types of malicious code from stealing the user's Windows credentials.

Impact:

If you disable or do not configure this policy setting, users can enter Windows credentials within the user's desktop session, potentially allowing malicious code access to the user's Windows credentials.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed for your organization. This group policy object is backed by the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI:
EnableSecureCredentialPrompting
```

Remediation:

Configure the following Group Policy setting in a manner that is consistent with the security and operational requirements of your organization:

```
Computer Configuration\Administrative Templates\Windows Components\Credential
User Interface\Require trusted path for credential entry.
```

References:

1. CCE-17399-7

ARCHIVE

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Computer Configuration**		
1.1	**Windows Settings**		
1.1.1	**Security Settings**		
1.1.1.1	**Account Policies**		
1.1.1.1.1	**Kerberos Policy**		
1.1.1.1.1.1	Configure 'Maximum lifetime for service ticket' (Manual)	☐	☐
1.1.1.1.1.2	Configure 'Enforce user logon restrictions' (Manual)	☐	☐
1.1.1.1.1.3	Configure 'Maximum lifetime for user ticket' (Manual)	☐	☐
1.1.1.1.1.4	Configure 'Maximum tolerance for computer clock synchronization' (Manual)	☐	☐
1.1.1.1.1.5	Configure 'Maximum lifetime for user ticket renewal' (Manual)	☐	☐
1.1.1.1.2	**Account Lockout Policy**		
1.1.1.1.2.1	Set 'Reset account lockout counter after' to '15' or more (Automated)	☐	☐
1.1.1.1.2.2	Set 'Account lockout duration' to '15' or greater (Automated)	☐	☐
1.1.1.1.2.3	Set 'Account lockout threshold' is set to '6' or fewer (Automated)	☐	☐
1.1.1.1.3	**Password Policy**		
1.1.1.1.3.1	Set 'Maximum password age' to '60' or less (Automated)	☐	☐
1.1.1.1.3.2	Set 'Enforce password history' to '24' or more (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.1.3.3	Set 'Store passwords using reversible encryption' to 'Disabled' (Automated)	☐	☐
1.1.1.1.3.4	Set 'Minimum password age' to '1' or more (Automated)	☐	☐
1.1.1.1.3.5	Set 'Password must meet complexity requirements' to 'Enabled' (Automated)	☐	☐
1.1.1.1.3.6	Set 'Minimum password length' to '14' or more (Automated)	☐	☐
1.1.1.2	**Local Policies**		
1.1.1.2.1	**Security Options**		
1.1.1.2.1.1	Set 'Domain controller: Allow server operators to schedule tasks' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.2	Set 'Accounts: Guest account status' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.3	Set 'Accounts: Limit local account use of blank passwords to console logon only' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.4	Set 'Domain controller: Refuse machine account password changes' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.5	Set 'Accounts: Administrator account status' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.6	Set 'System objects: Default owner for objects created by members of the Administrators group' to 'Object creator' (Automated)	☐	☐
1.1.1.2.1.7	Set 'Network access: Shares that can be accessed anonymously' to 'None' (Automated)	☐	☐
1.1.1.2.1.8	Set 'Interactive logon: Smart card removal behavior' to 'Lock Workstation' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.9	Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated)	☐	☐
1.1.1.2.1.10	Set 'Devices: Prevent users from installing printer drivers' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.11	Set 'Devices: Unsigned driver installation behavior' to 'Warn but allow installation' (Automated)	☐	☐
1.1.1.2.1.12	Set 'Recovery console: Allow floppy copy and access to all drives and all folders' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.13	Set 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved (recommended)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.14	Set 'Network access: Restrict anonymous access to Named Pipes and Shares' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.15	Set 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' to '90' (Automated)	☐	☐
1.1.1.2.1.16	Set 'MSS: (SynAttackProtect) Syn attack protection level (protects against DoS)' to 'Connections time out sooner if a SYN attack is detected' (Automated)	☐	☐
1.1.1.2.1.17	Set 'System settings: Use Certificate Rules on Windows Executables for Software Restriction Policies' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.18	Set 'MSS: (AutoShareServer) Enable Administrative Shares (recommended except for highly secure environments)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.19	Set 'Shutdown: Clear virtual memory pagefile' to 'Disabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.20	Set 'Domain member: Disable machine account password changes' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.21	Set 'Microsoft network server: Amount of idle time required before suspending session' to '15' (Automated)	☐	☐
1.1.1.2.1.22	Set 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.23	Configure 'Devices: Restrict CD-ROM access to locally logged-on user only' (Manual)	☐	☐
1.1.1.2.1.24	Set 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' to '300000 or 5 minutes (recommended)' (Automated)	☐	☐
1.1.1.2.1.25	Set 'Shutdown: Allow system to be shut down without having to log on' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.26	Set 'Interactive logon: Do not display last user name' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.27	Set 'Network security: LAN Manager authentication level' to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)	☐	☐
1.1.1.2.1.28	Configure 'DCOM: Machine Access Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)	☐	☐
1.1.1.2.1.29	Configure 'MSS: (Hidden) Hide Computer From the Browse List (not recommended except for highly secure environments)' (Manual)	☐	☐
1.1.1.2.1.30	Set 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' to 'Disabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.31	Set 'Network security: Minimum session security for NTLM SSP based (including secure RPC) servers' to 'Require message integrity,Require message confidentiality,Require NTLMv2 session security,Require 128-bit encryption' (Automated)	☐	☐
1.1.1.2.1.32	Set 'System objects: Require case insensitivity for non-Windows subsystems' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.33	Configure 'DCOM: Machine Launch Restrictions in Security Descriptor Definition Language (SDDL) syntax' (Manual)	☐	☐
1.1.1.2.1.34	Set 'System settings: Optional subsystems' to '' (Automated)	☐	☐
1.1.1.2.1.35	Set 'Devices: Allowed to format and eject removable media' to 'Administrators' (Automated)	☐	☐
1.1.1.2.1.36	Set 'Microsoft network client: Digitally sign communications (always)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.37	Set 'Interactive logon: Prompt user to change password before expiration' to '14' (Automated)	☐	☐
1.1.1.2.1.38	Set 'Domain member: Maximum machine account password age' to '30' (Automated)	☐	☐
1.1.1.2.1.39	Set 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.40	Configure 'Interactive logon: Display user information when the session is locked' (Manual)	☐	☐
1.1.1.2.1.41	Set 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' to '3' (Automated)	☐	☐
1.1.1.2.1.42	Set 'Domain member: Digitally sign secure channel data (when possible)' to 'Enabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.43	Set 'Domain member: Digitally encrypt secure channel data (when possible)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.44	Configure 'Domain controller: LDAP server signing requirements' (Manual)	☐	☐
1.1.1.2.1.45	Set 'Microsoft network client: Send unencrypted password to third-party SMB servers' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.46	Set 'Interactive logon: Do not require CTRL+ALT+DEL' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.47	Configure 'Interactive logon: Message title for users attempting to log on' (Manual)	☐	☐
1.1.1.2.1.48	Configure 'Interactive logon: Message text for users attempting to log on' (Manual)	☐	☐
1.1.1.2.1.49	Set 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' to '0' (Automated)	☐	☐
1.1.1.2.1.50	Set 'Microsoft network client: Digitally sign communications (if server agrees)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.51	Set 'Domain member: Digitally encrypt or sign secure channel data (always)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.52	Set 'System objects: Strengthen default permissions of internal system objects (e.g. Symbolic Links)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.53	Set 'Network security: Do not store LAN Manager hash value on next password change' to 'Enabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.54	Set 'Network access: Remotely accessible registry paths and sub-paths' to 'System\CurrentControlSet\Control\Print\Printers System\CurrentControlSet\Services\Eventlog Software\Microsoft\OLAP Server Software\Microsoft\Windows NT\CurrentVersion\Print Sof (Automated)	☐	☐
1.1.1.2.1.55	Configure 'System cryptography: Force strong key protection for user keys stored on the computer' (Manual)	☐	☐
1.1.1.2.1.56	Set 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' to 'Highest protection, source routing is completely disabled' (Automated)	☐	☐
1.1.1.2.1.57	Set 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.58	Set 'MSS: (TcpMaxConnectResponseRetransmissions) SYN-ACK retransmissions when a connection request is not acknowledged' to '3 & 6 seconds, half-open connections dropped after 21 seconds' (Automated)	☐	☐
1.1.1.2.1.59	Set 'Microsoft network server: Disconnect clients when logon hours expire' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.60	Set 'Network access: Let Everyone permissions apply to anonymous users' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.61	Set 'Microsoft network server: Digitally sign communications (always)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.62	Set 'Network security: LDAP client signing requirements' to 'Negotiate signing' or better (Automated)	☐	☐
1.1.1.2.1.63	Set 'Devices: Allow undock without having to log on' to 'Disabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.64	Set 'Audit: Audit the access of global system objects' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.65	Set 'MSS: (AutoReboot) Allow Windows to automatically restart after a system crash (recommended except for highly secure environments)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.66	Set 'Interactive logon: Require smart card' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.67	Configure 'Devices: Restrict floppy access to locally logged-on user only' (Manual)	☐	☐
1.1.1.2.1.68	Set 'Network access: Allow anonymous SID/Name translation' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.69	Set 'Domain member: Require strong (Windows 2000 or later) session key' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.70	Set 'Network access: Remotely accessible registry paths' to 'System\CurrentControlSet\Control\ProductOptions System\CurrentControlSet\Control\Server Applications Software\Microsoft\Windows NT\CurrentVersion' (Automated)	☐	☐
1.1.1.2.1.71	Set 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '0' (Automated)	☐	☐
1.1.1.2.1.72	Configure 'Network access: Named Pipes that can be accessed anonymously' (Manual)	☐	☐
1.1.1.2.1.73	Set 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.74	Set 'Recovery console: Allow automatic administrative logon' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.75	Set 'Audit: Shut down system immediately if unable to log security audits' to 'Disabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.1.76	Set 'Microsoft network server: Digitally sign communications (if client agrees)' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.77	Set 'Network access: Sharing and security model for local accounts' to 'Classic - local users authenticate as themselves' (Automated)	☐	☐
1.1.1.2.1.78	Set 'Network access: Do not allow anonymous enumeration of SAM accounts' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.79	Set 'Interactive logon: Require Domain Controller authentication to unlock workstation' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.80	Set 'Network access: Do not allow storage of credentials or .NET Passports for network authentication' to 'Enabled' (Automated)	☐	☐
1.1.1.2.1.81	Set 'MSS: (EnableDeadGWDetect) Allow automatic detection of dead network gateways (could lead to DoS)' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.82	Set 'System cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.83	Set 'Audit: Audit the use of Backup and Restore privilege' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.84	Set 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' to 'Disabled' (Automated)	☐	☐
1.1.1.2.1.85	Set 'MSS: (NoDefaultExempt) Configure IPSec exemptions for various types of network traffic.' to 'Only ISAKMP is exempt (recommended for Windows Server 2003)' (Automated)	☐	☐
1.1.1.2.2	**Audit Policy**		

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.2.1	Set 'Audit directory service access' to 'Failure' (Automated)	☐	☐
1.1.1.2.2.2	Set 'Audit account logon events' to 'Success, Failure' (Automated)	☐	☐
1.1.1.2.2.3	Set 'Audit logon events' to 'Success, Failure' (Automated)	☐	☐
1.1.1.2.2.4	Set 'Audit process tracking' to 'No Auditing' (Automated)	☐	☐
1.1.1.2.2.5	Set 'Audit account management' to 'Success, Failure' (Automated)	☐	☐
1.1.1.2.2.6	Set 'Audit policy change' to 'Success' (minimum) or 'Success and Failure' (Automated)	☐	☐
1.1.1.2.2.7	Set 'Audit system events' to 'Success' (minimum) or 'Success and Failure' (Automated)	☐	☐
1.1.1.2.2.8	Set 'Audit privilege use' to 'Failure' (minimum) or 'Success and Failure' (Automated)	☐	☐
1.1.1.2.2.9	Configure 'Audit object access' (Manual)	☐	☐
1.1.1.2.3	**User Rights Assignment**		
1.1.1.2.3.1	Set 'Allow log on through Terminal Services' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.2	Set 'Allow log on through Terminal Services' to 'Administrators, Remote desktop Users' (Automated)	☐	☐
1.1.1.2.3.3	Set 'Take ownership of files or other objects' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.4	Set 'Enable computer and user accounts to be trusted for delegation' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.5	Configure 'Enable computer and user accounts to be trusted for delegation' (Manual)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.3.6	Set 'Remove computer from docking station' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.7	Configure 'Create permanent shared objects' (Manual)	☐	☐
1.1.1.2.3.8	Set 'Debug programs' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.9	Configure 'Load and unload device drivers' (Manual)	☐	☐
1.1.1.2.3.10	Set 'Adjust memory quotas for a process' to 'Administrators, LOCAL SERVICE, NETWORK SERVICE' (Automated)	☐	☐
1.1.1.2.3.11	Configure 'Generate security audits' (Manual)	☐	☐
1.1.1.2.3.12	Set 'Shut down the system' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.13	Configure 'Increase scheduling priority' (Manual)	☐	☐
1.1.1.2.3.14	Set 'Replace a process level token' to 'LOCAL SERVICE, NETWORK SERVICE' (Automated)	☐	☐
1.1.1.2.3.15	Configure 'Add workstations to domain' (Manual)	☐	☐
1.1.1.2.3.16	Configure 'Change the system time' (Manual)	☐	☐
1.1.1.2.3.17	Configure 'Restore files and directories' (Manual)	☐	☐
1.1.1.2.3.18	Configure 'Create a token object' (Manual)	☐	☐
1.1.1.2.3.19	Configure 'Synchronize directory service data' (Manual)	☐	☐
1.1.1.2.3.20	Set 'Profile system performance' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.21	Configure 'Access this computer from the network' (Manual)	☐	☐
1.1.1.2.3.22	Set 'Profile single process' to 'Administrators' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.3.23	Configure 'Impersonate a client after authentication' (Manual)	☐	☐
1.1.1.2.3.24	Set 'Create a pagefile' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.25	Set 'Deny log on as a batch job' to 'Guests' (Automated)	☐	☐
1.1.1.2.3.26	Set 'Deny log on through Terminal Services' to 'Guests' (Automated)	☐	☐
1.1.1.2.3.27	Configure 'Act as part of the operating system' (Manual)	☐	☐
1.1.1.2.3.28	Configure 'Back up files and directories' (Manual)	☐	☐
1.1.1.2.3.29	Set 'Log on as a service' to 'NETWORK SERVICE' (Automated)	☐	☐
1.1.1.2.3.30	Set 'Deny access to this computer from the network' to 'ANONYMOUS LOGON, Guests' (Automated)	☐	☐
1.1.1.2.3.31	Configure 'Perform volume maintenance tasks' (Manual)	☐	☐
1.1.1.2.3.32	Configure 'Deny log on locally' (Manual)	☐	☐
1.1.1.2.3.33	Set 'Allow log on locally' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.34	Configure 'Create global objects' (Manual)	☐	☐
1.1.1.2.3.35	Configure 'Bypass traverse checking' (Manual)	☐	☐
1.1.1.2.3.36	Configure 'Deny log on as a service' (Manual)	☐	☐
1.1.1.2.3.37	Set 'Manage auditing and security log' to 'Administrators' (Automated)	☐	☐
1.1.1.2.3.38	Configure 'Lock pages in memory' (Manual)	☐	☐
1.1.1.2.3.39	Configure 'Force shutdown from a remote system' (Manual)	☐	☐
1.1.1.2.3.40	Set 'Modify firmware environment values' to 'Administrators' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.1.2.3.41	Configure 'Log on as a batch job' (Manual)	☐	☐
1.1.1.3	**Event Log**		
1.1.1.3.1	Set 'Retention method for system log' to 'Overwrites events as needed' (Automated)	☐	☐
1.1.1.3.2	Set 'Maximum application log size' to '16384' (Automated)	☐	☐
1.1.1.3.3	Set 'Retention method for security log' to 'Overwrites events as needed' (Automated)	☐	☐
1.1.1.3.4	Set 'Maximum system log size' to '16384' (Automated)	☐	☐
1.1.1.3.5	Set 'Maximum security log size' to '81920' (Automated)	☐	☐
1.1.1.3.6	Set 'Retention method for application log' to 'Overwrites events as needed' (Automated)	☐	☐
1.1.1.3.7	Configure 'Retain system log' (Manual)	☐	☐
1.1.1.3.8	Configure 'Retain security log' (Manual)	☐	☐
1.1.1.3.9	Configure 'Retain application log' (Manual)	☐	☐
1.2	**Administrative Templates**		
1.2.1	**Network**		
1.2.1.1	**Network Connections**		
1.2.1.1.1	**Windows Firewall**		
1.2.1.1.1.1	**Standard Profile**		
1.2.1.1.1.1.1	Configure 'Windows Firewall: Allow ICMP exceptions' (Manual)	☐	☐
1.2.1.1.1.1.2	Configure 'Windows Firewall: Define inbound port exceptions' (Manual)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.1.1.1.1.3	Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual)	☐	☐
1.2.1.1.1.1.4	Configure 'Windows Firewall: Allow local program exceptions' (Manual)	☐	☐
1.2.1.1.1.1.5	Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual)	☐	☐
1.2.1.1.1.1.6	Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual)	☐	☐
1.2.1.1.1.1.7	Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual)	☐	☐
1.2.1.1.1.1.8	Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual)	☐	☐
1.2.1.1.1.1.9	Configure 'Windows Firewall: Define inbound program exceptions' (Manual)	☐	☐
1.2.1.1.1.1.10	Configure 'Windows Firewall: Allow local port exceptions' (Manual)	☐	☐
1.2.1.1.1.1.11	Configure 'Windows Firewall: Prohibit notifications' (Manual)	☐	☐
1.2.1.1.1.1.12	Configure 'Windows Firewall: Do not allow exceptions' (Manual)	☐	☐
1.2.1.1.1.1.13	Configure 'Windows Firewall: Protect all network connections' (Manual)	☐	☐
1.2.1.1.1.2	**Domain Profile**		
1.2.1.1.1.2.1	Configure 'Windows Firewall: Allow inbound UPnP framework exceptions' (Manual)	☐	☐
1.2.1.1.1.2.2	Configure 'Windows Firewall: Do not allow exceptions' (Manual)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.1.1.1.2.3	Configure 'Windows Firewall: Allow local program exceptions' (Manual)	☐	☐
1.2.1.1.1.2.4	Configure 'Windows Firewall: Allow local port exceptions' (Manual)	☐	☐
1.2.1.1.1.2.5	Configure 'Windows Firewall: Allow inbound remote administration exception' (Manual)	☐	☐
1.2.1.1.1.2.6	Configure 'Windows Firewall: Allow inbound file and printer sharing exception' (Manual)	☐	☐
1.2.1.1.1.2.7	Configure 'Windows Firewall: Allow ICMP exceptions' (Manual)	☐	☐
1.2.1.1.1.2.8	Configure 'Windows Firewall: Prohibit notifications' (Manual)	☐	☐
1.2.1.1.1.2.9	Configure 'Windows Firewall: Define inbound port exceptions' (Manual)	☐	☐
1.2.1.1.1.2.10	Configure 'Windows Firewall: Protect all network connections' (Manual)	☐	☐
1.2.1.1.1.2.11	Configure 'Windows Firewall: Prohibit unicast response to multicast or broadcast requests' (Manual)	☐	☐
1.2.1.1.1.2.12	Configure 'Windows Firewall: Define inbound program exceptions' (Manual)	☐	☐
1.2.1.1.1.2.13	Configure 'Windows Firewall: Allow inbound Remote Desktop exceptions' (Manual)	☐	☐
1.2.2	**System**		
1.2.2.1	**Remote Assistance**		
1.2.2.1.1	Configure 'Offer Remote Assistance' (Manual)	☐	☐
1.2.2.1.2	Configure 'Solicited Remote Assistance' (Manual)	☐	☐
1.2.2.2	**Internet Communication Management**		

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.2.2.1	**Internet Communication settings**		
1.2.2.2.1.1	Configure 'Turn off Windows Update device driver searching' (Manual)	☐	☐
1.2.2.2.1.2	Configure 'Turn off Search Companion content file updates' (Manual)	☐	☐
1.2.2.2.1.3	Configure 'Turn off Internet download for Web publishing and online ordering wizards' (Manual)	☐	☐
1.2.2.2.1.4	Configure 'Turn off the Windows Messenger Customer Experience Improvement Program' (Manual)	☐	☐
1.2.2.2.1.5	Configure 'Turn off printing over HTTP' (Manual)	☐	☐
1.2.2.2.1.6	Configure 'Turn off the "Publish to Web" task for files and folders' (Manual)	☐	☐
1.2.2.2.1.7	Configure 'Turn off downloading of print drivers over HTTP' (Manual)	☐	☐
1.2.2.3	**Group Policy**		
1.2.2.3.1	Configure 'Registry policy processing' (Manual)	☐	☐
1.2.2.3.2	Configure 'Do not apply during periodic background processing' (Manual)	☐	☐
1.2.2.3.3	Configure 'Process even if the Group Policy objects have not changed' (Manual)	☐	☐
1.2.2.4	**Remote Procedure Call**		
1.2.2.4.1	Set 'RPC Endpoint Mapper Client Authentication' to 'Enabled' (Manual)	☐	☐
1.2.2.4.2	Set 'Restrictions for Unauthenticated RPC clients' to 'Enabled:Authenticated' (Automated)	☐	☐
1.2.2.5	**Logon**		

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.2.5.1	Configure 'Do not process the legacy run list' (Manual)	☐	☐
1.2.2.5.2	Configure 'Do not process the run once list' (Manual)	☐	☐
1.2.3	**Windows Components**		
1.2.3.1	**AutoPlay Policies**		
1.2.3.1.1	Set 'Turn off Autoplay' to 'Enabled:All drives' (Automated)	☐	☐
1.2.3.2	**Windows Update**		
1.2.3.2.1	Configure 'Configure Automatic Updates' (Manual)	☐	☐
1.2.3.2.2	Configure 'Specify intranet Microsoft update service location' (Manual)	☐	☐
1.2.3.2.3	Configure 'Set the intranet statistics server' (Manual)	☐	☐
1.2.3.2.4	Configure 'Set the intranet update service for detecting updates' (Manual)	☐	☐
1.2.3.2.5	Configure 'No auto-restart with logged on users for scheduled automatic updates installations' (Manual)	☐	☐
1.2.3.2.6	Configure 'Do not display 'Install Updates and Shut Down' option in Shut Down Windows dialog box' (Manual)	☐	☐
1.2.3.2.7	Configure 'Do not adjust default option to 'Install Updates and Shut Down' in Shut Down Windows dialog box' (Manual)	☐	☐
1.2.3.2.8	Configure 'Reschedule Automatic Updates scheduled installations' (Manual)	☐	☐
1.2.3.3	**Windows Messenger**		
1.2.3.3.1	Configure 'Do not allow Windows Messenger to be run' (Manual)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.3.4	**Remote Desktop Services**		
1.2.3.4.1	**Remote Desktop Connection Client**		
1.2.3.4.1.1	Configure 'Do not allow passwords to be saved' (Manual)	☐	☐
1.2.3.4.2	**Remote Desktop Session Host**		
1.2.3.4.2.1	**Device and Resource Redirection**		
1.2.3.4.2.1.1	Configure 'Do not allow drive redirection' (Manual)	☐	☐
1.2.3.4.2.2	**Connections**		
1.2.3.4.2.2.1	Configure 'Allow users to connect remotely using Remote Desktop Services' (Manual)	☐	☐
1.2.3.4.2.3	**Security**		
1.2.3.4.2.3.1	Configure 'Set client connection encryption level' (Manual)	☐	☐
1.2.3.4.2.3.2	Configure 'Always prompt for password upon connection' (Manual)	☐	☐
1.2.3.5	**Windows Error Reporting**		
1.2.3.5.1	**Advanced Error Reporting Settings**		
1.2.3.5.1.1	Configure 'Report operating system errors' (Manual)	☐	☐
1.2.3.5.2	Configure 'Display Error Notification' (Manual)	☐	☐
1.2.3.6	**NetMeeting**		
1.2.3.6.1	Configure 'Disable remote Desktop Sharing' (Manual)	☐	☐
1.2.3.7	**Windows Installer**		
1.2.3.7.1	Set 'Always install with elevated privileges' to 'Disabled' (Automated)	☐	☐

ARCHIVE

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.3.8	**Credential User Interface**		
1.2.3.8.1	Configure 'Require trusted path for credential entry.' (Manual)	☐	☐

ARCHIVE

Appendix: Change History

Date	Version	Changes for this version
09-03-2004	1.0	Initial release to public
10-14-2004	1.0.2	Corrected document value of 3.2.1.67 MSS: AFD MaximumDynamicBacklog from 2000 to 20000.
10-20-2004	1.1	Renamed "High Security" to "Specialized Security - Limited Functionality"
10-18-2005	1.2	Corrected numbering errors in section 2 of the benchmark so that they correctly reflect numbering in section 1
10-18-2005	1.2	Altered descriptive text in several sections for accuracy and completeness
11-01-2007	1.3	Reformatted document be more inline with style guide
06-30-2009	2.1	Resovled bug 409, 448, 450, 473, 483, 363, 369.
10-01-2013	3.0	Ground-up rewrite of the benchmark.
12-03-2013	3.1.0	Addressed tickets #175, #167, #170, #172, #171, #168, #179, #177, #169, #166, #134

ARCHIVE